

Securing Your Microsoft 365 Tenant: Essential Strategies



Speakers



Lewis Barry

Principal Security Architect | inforcer

[Conditionalaccess.uk](https://conditionalaccess.uk)



Ewelina Paczkowska

Data Security & Governance Lead

 www.welkasworld.com

 [@WelkasWorld](https://twitter.com/WelkasWorld)



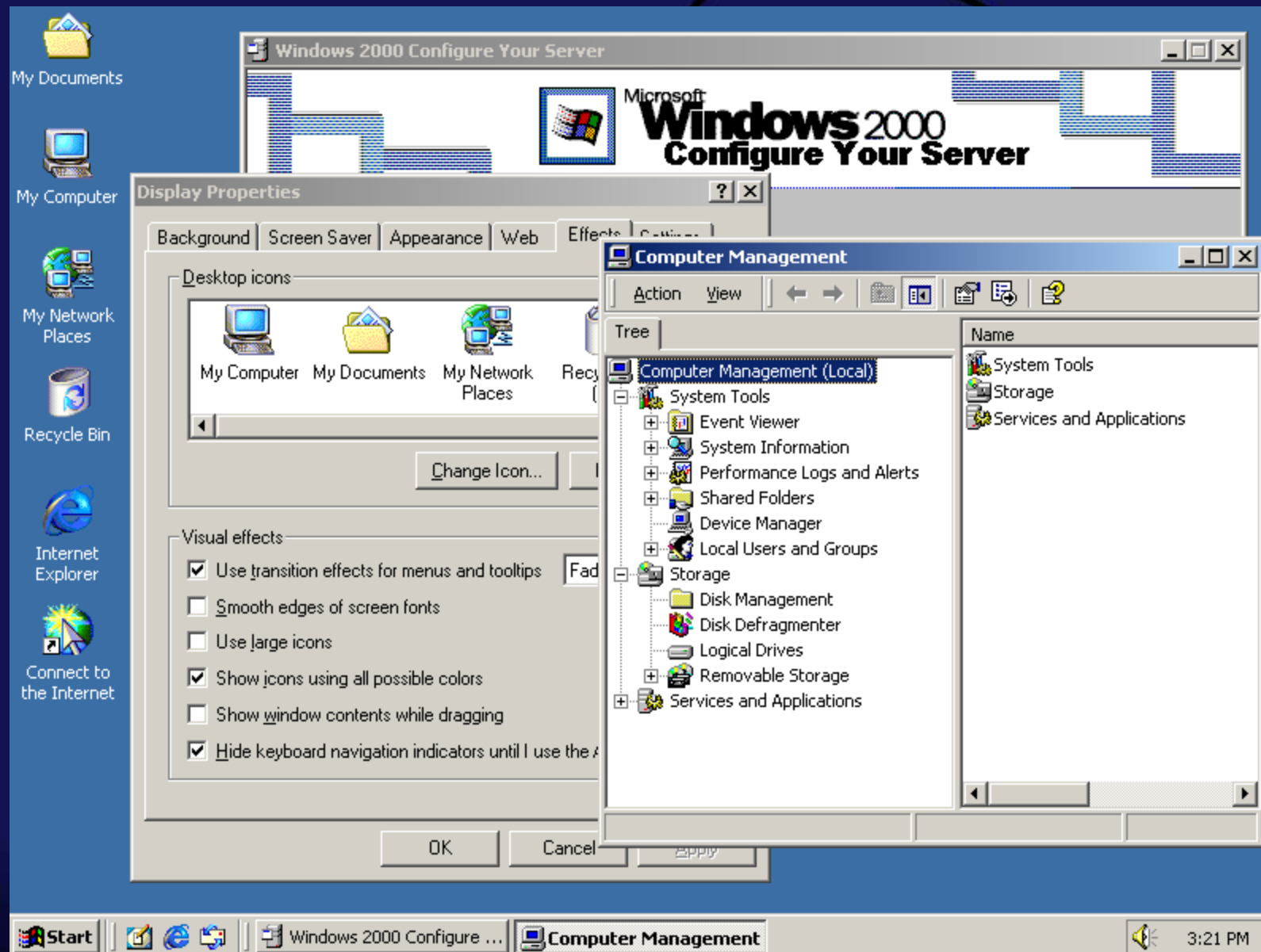
Can't see our slides? Can't hear? Need to repeat the question? Call us out!

Today, we're all security people

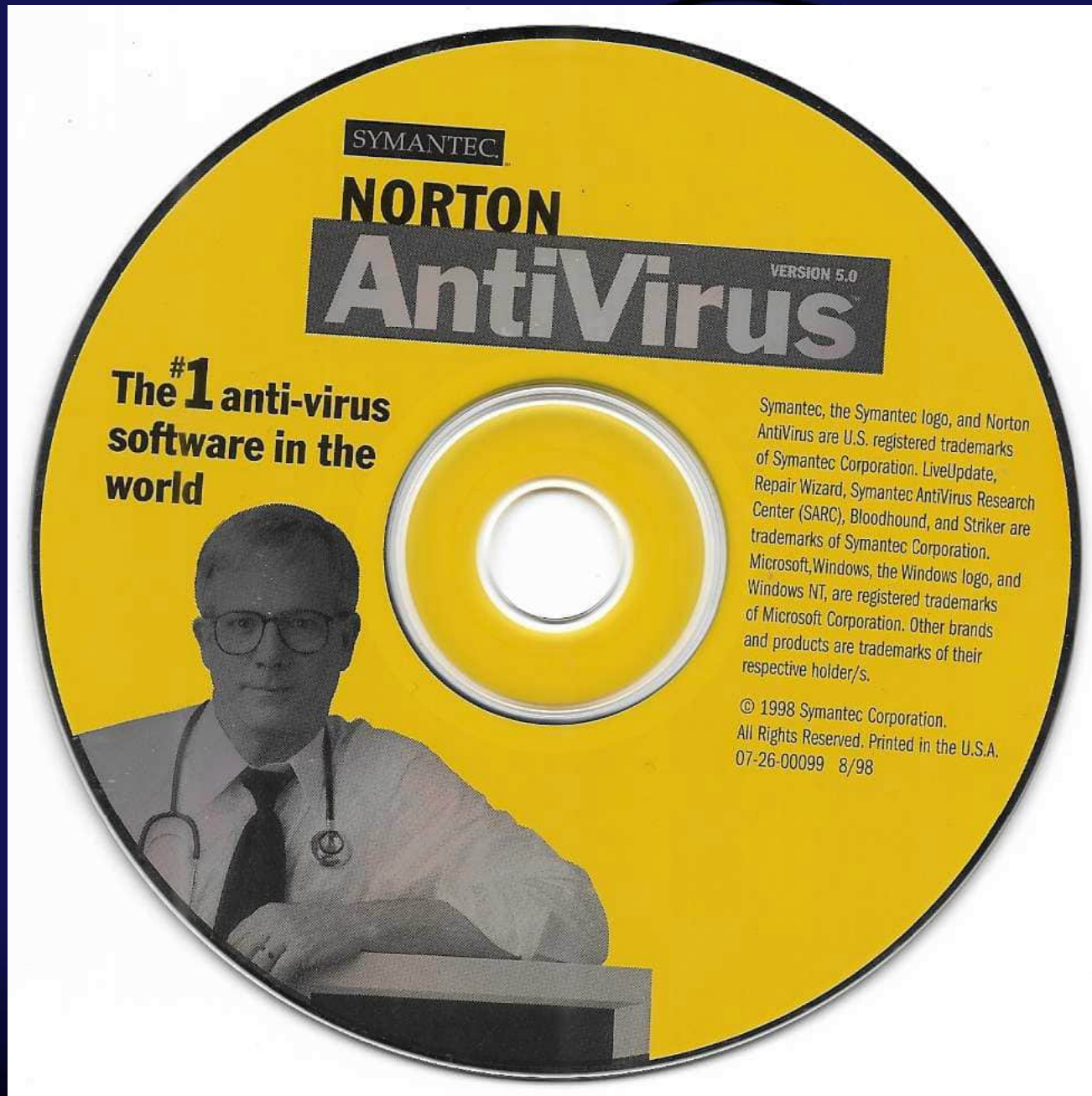
Let's see how this has changed over time.



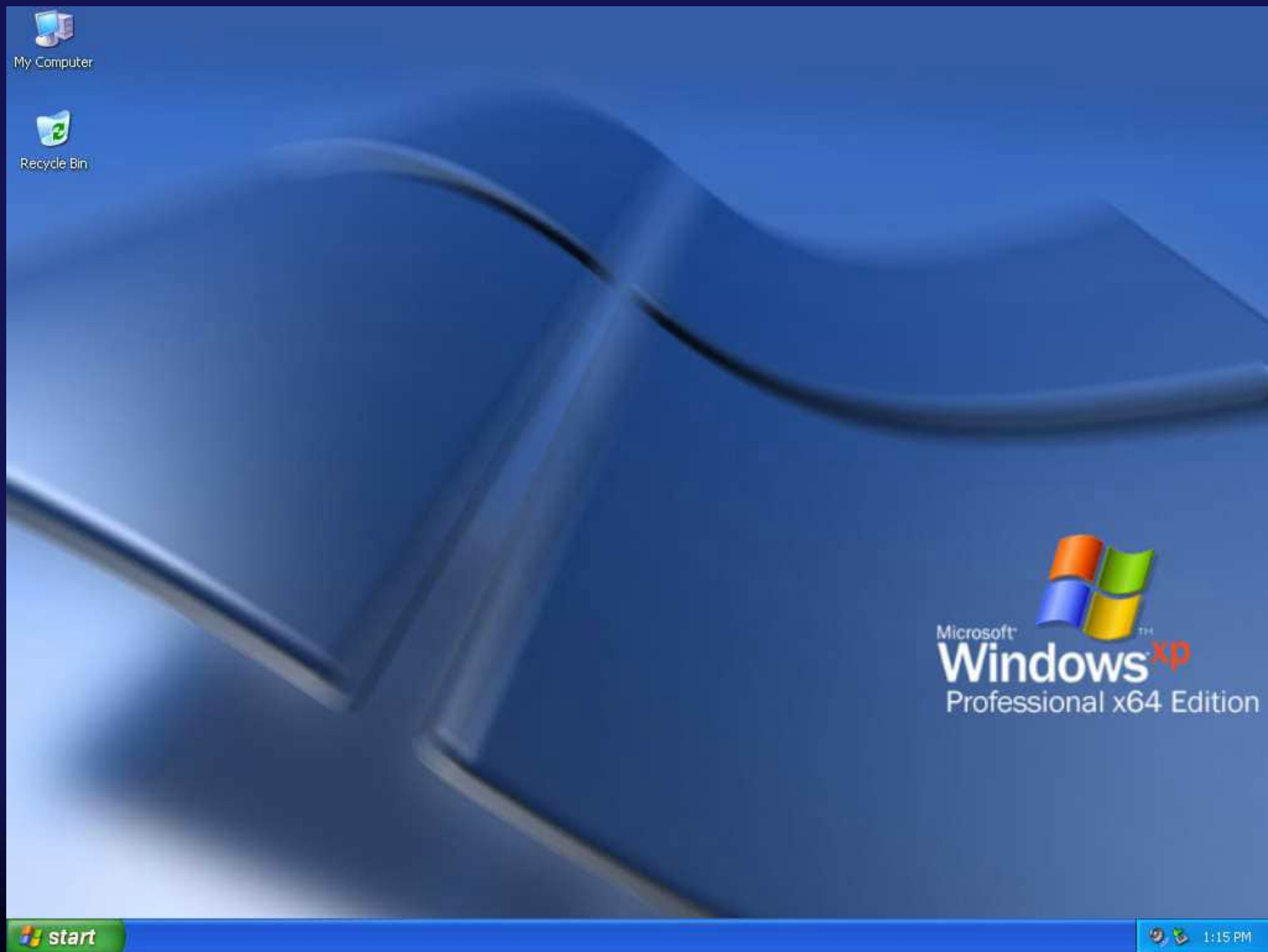
2000



2000



2005

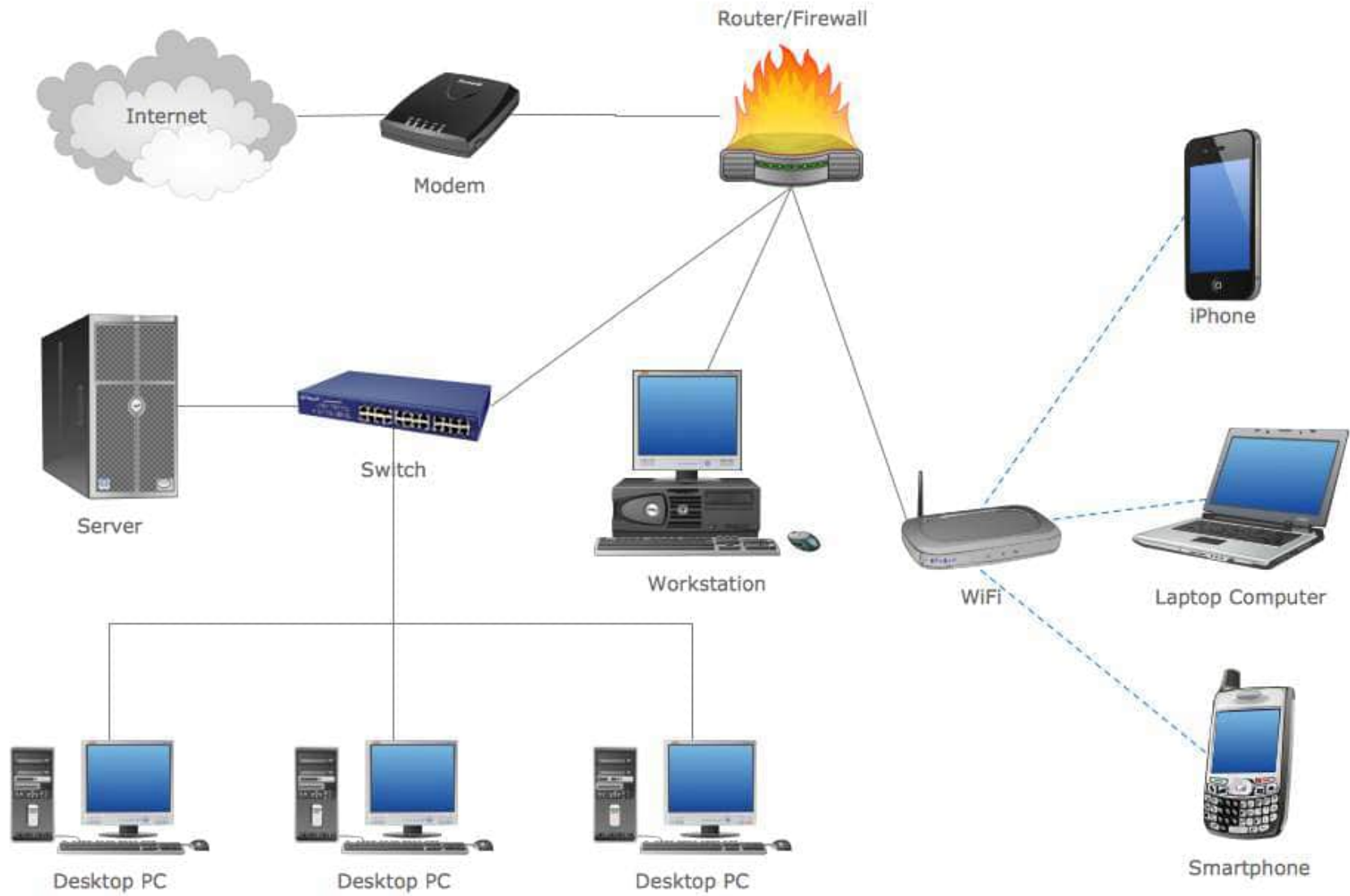


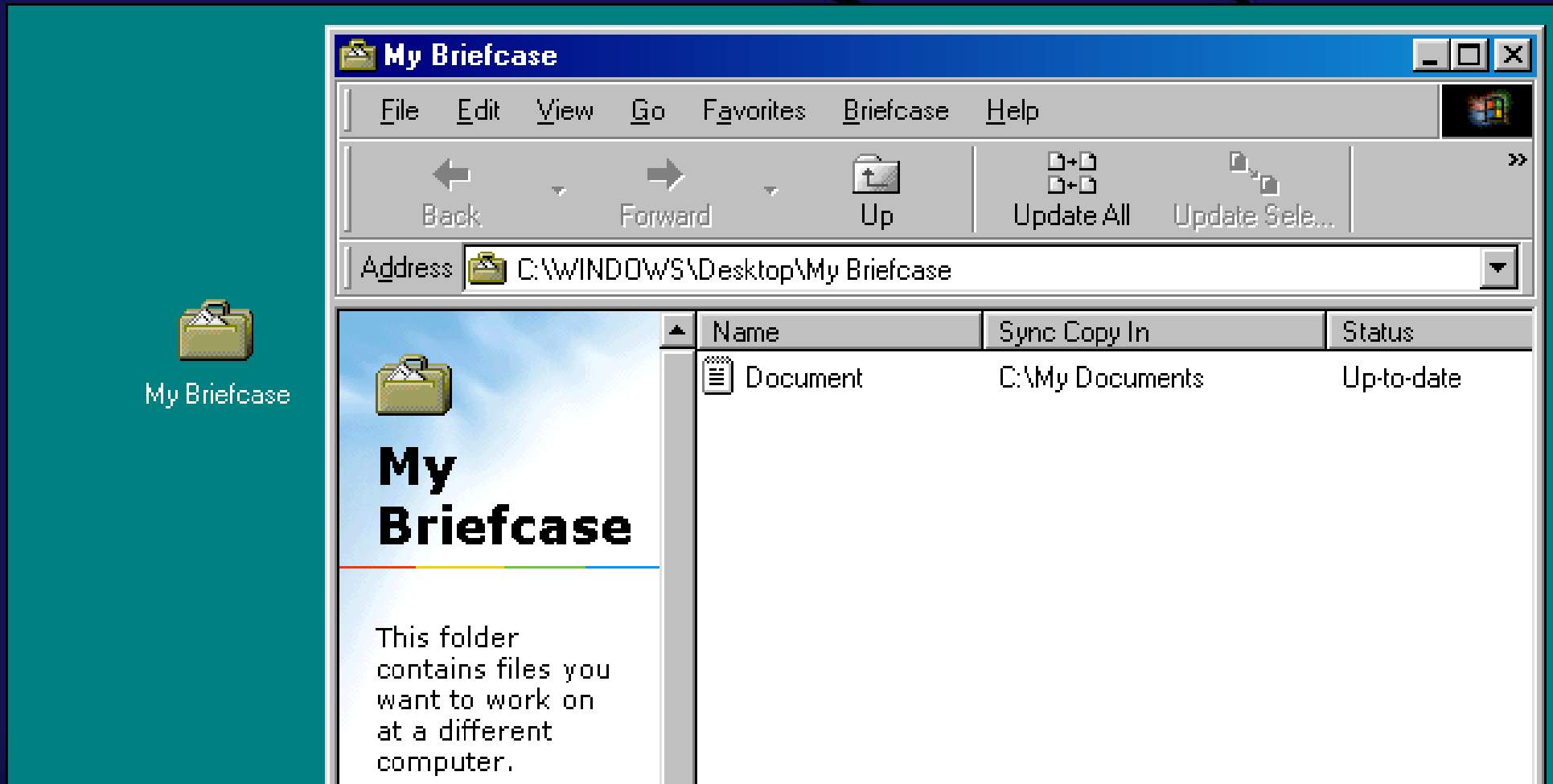
2005

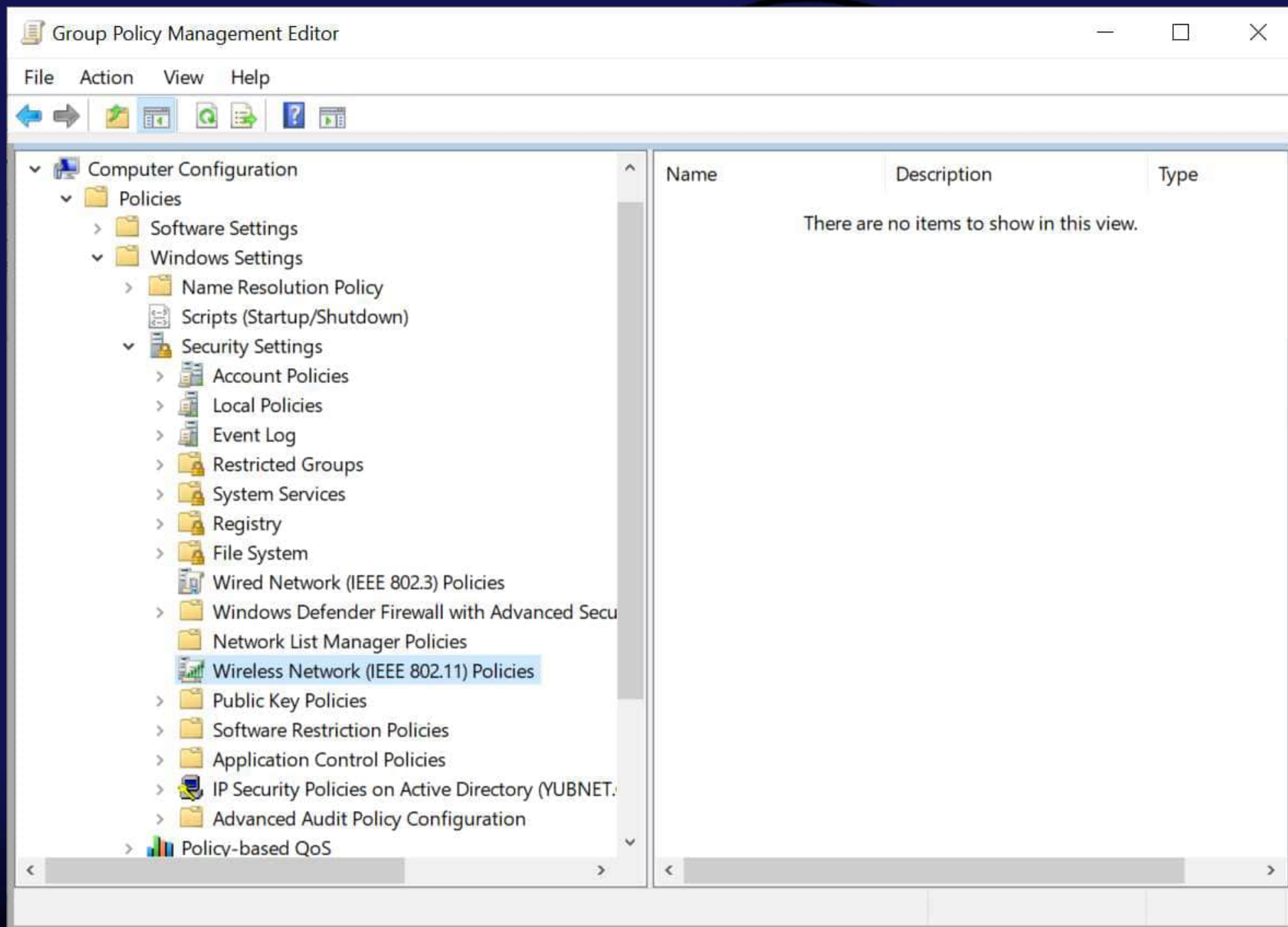


2005









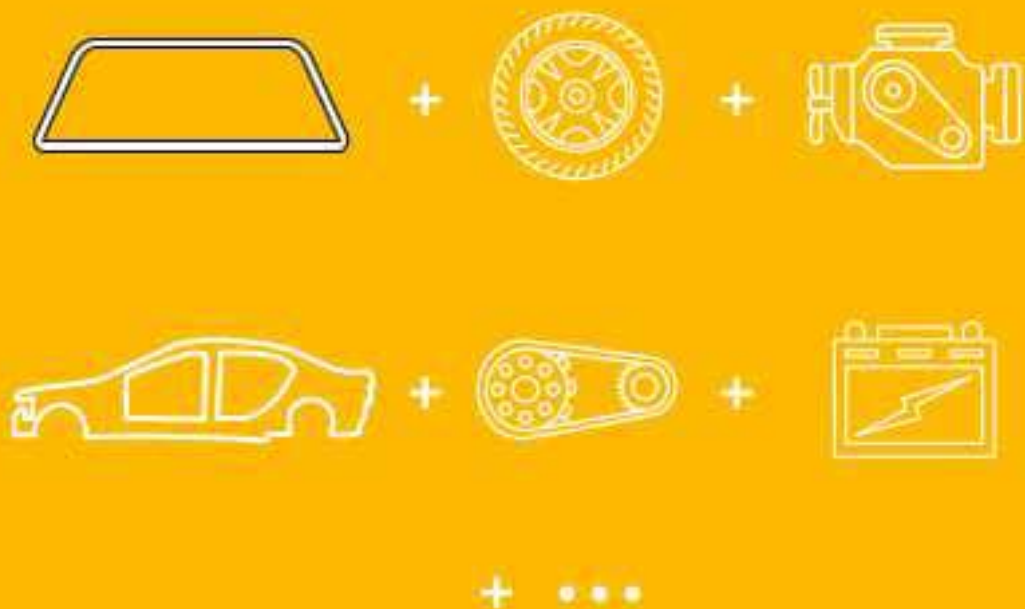
Policy Path				
Policy Path	Policy Setting Name	Windows 11	Help Text	
			This policy is supported on at least Windows Server 2008 R2.	
58 Security Options	Domain controller: Allow vulnerable Netlogon secure channel connections			
59 Security Options	Domain controller: LDAP server channel binding token requirements		Domain controller: LDAP server channel binding token requirementsThis security setting determines whether the LDAP server enforces validation of Channel Binding Tokens received from clients.	
60 Security Options	Domain controller: LDAP server signing requirements		Domain controller: LDAP server signing requirementsThis security setting determines whether the LDAP server requires signing to be negotiated with LDAP clients, as follows:None: Domain controller does not require signing. Domain controller requires signing to be negotiated with LDAP clients.	
61 Security Options	Domain controller: Refuse machine account password changes		Domain controller: Refuse machine account password changesThis security setting determines whether domain controllers will refuse requests from member computers to change their machine account password.	
62 Security Options	Domain member: Digitally encrypt or sign secure channel data (always)	Enabled	Domain member: Digitally encrypt or sign secure channel data (always)This security setting determines whether all secure channel traffic initiated by the domain member must be signed and encrypted.	
63 Security Options	Domain member: Digitally encrypt secure channel data (when possible)	Enabled	Domain member: Digitally encrypt secure channel data (when possible)This security setting determines whether a domain member attempts to negotiate encryption for all secure channel traffic.	
64 Security Options	Domain member: Digitally sign secure channel data (when possible)	Enabled	Domain member: Digitally sign secure channel data (when possible)This security setting determines whether a domain member attempts to negotiate signing for all secure channel traffic.	
65 Security Options	Domain member: Disable machine account password changes	Disabled	Domain member: Disable machine account password changesDetermines whether a domain member periodically changes its computer account password. If this setting is enabled, the domain member will not change its password.	
66 Security Options	Domain member: Maximum machine account password age	30	Domain member: Maximum machine account password ageThis security setting determines how often a domain member will attempt to change its computer account password. Default is 30 days.	
67 Security Options	Domain member: Require strong (Windows 2000 or later) session key	Enabled	Domain member: Require strong (Windows 2000 or later) session keyThis security setting determines whether 128-bit key strength is required for encrypted secure channel data. When disabled, 56-bit key strength is allowed.	
68 Security Options	Interactive logon: Display user information when the session is locked		Interactive Logon: Display user information when session is locked	
69 Security Options	Interactive logon: Do not require CTRL+ALT+DEL		Interactive logon: Do not require CTRL+ALT+DELThis security setting determines whether pressing CTRL+ALT+DEL is required before a user can log on. If this policy is enabled on a computer, the user must press CTRL+ALT+DEL before the logon screen appears.	
70 Security Options	Interactive logon: Don't display last signed-in		Interactive logon: Do not display last user nameThis security setting determines whether the name of the last user to log on to the computer is displayed in the Windows logon screen.	
71 Security Options	Interactive logon: Don't display username at sign-in			
72 Security Options	Interactive logon: Machine account lockout threshold		Interactive logon: Machine account threshold.The machine lockout policy is enforced only on those machines that have BitLocker enabled for protecting OS volumes. Please ensure that the machine account password is not lost.	
73 Security Options	Interactive logon: Machine inactivity limit	900	Interactive logon: Machine inactivity limit.Windows notices inactivity of a logon session, and if the amount of inactive time exceeds the inactivity limit, then the screen saver will run, locking the computer.	
74 Security Options	Interactive logon: Message text for users attempting to log on		Interactive logon: Message text for users attempting to log onThis security setting specifies a text message that is displayed to users when they log on. This text is often used for legal requirements.	
75 Security Options	Interactive logon: Message title for users attempting to log on		Interactive logon: Message title for users attempting to log onThis security setting allows the specification of a title to appear in the title bar of the window that contains the Interactive Logon message.	
76 Security Options	Interactive logon: Number of previous logons to cache (in case domain controller is not available)		Interactive logon: Number of previous logons to cache (in case domain controller is not available)All previous users' logon information is cached locally so that, in the event that a domain controller is not available, the user can log on with a previously cached password.	
77 Security Options	Interactive logon: Prompt user to change password before expiration		Interactive logon: Prompt user to change password before expirationDetermines how far in advance (in days) users are warned that their password is about to expire. With this advanced warning, users can change their password before it expires.	
78 Security Options	Interactive logon: Require Domain Controller authentication to unlock workstation		Interactive logon: Require Domain Controller authentication to unlockLogon information must be provided to unlock a locked computer. For domain accounts, this security setting determines whether the user must provide a password to unlock the computer.	
79 Security Options	Interactive logon: Require Windows Hello for Business or smart card		Interactive logon: Require smart cardThis security setting requires users to log on to a computer using a smart card. The options are:Enabled: Users can only log on to the computer using a smart card. Disabled: Users can log on to the computer using a password or PIN.	
80 Security Options	Interactive logon: Smart card removal behavior	Lock Workstation	Interactive logon: Smart card removal behaviorThis security setting determines what happens when the smart card for a logged-on user is removed from the smart card reader. The options are:Lock Workstation: The computer will lock when the smart card is removed. Do Not Remove: The computer will not lock when the smart card is removed.	
81 Security Options	Microsoft network client: Digitally sign communications (if server agrees)	Enabled	Microsoft network client: Digitally sign communications (always)This security setting determines whether packet signing is required by the SMB client component. The server message block (SMB) protocol provides the basis for file and printer sharing and many other networking capabilities.	
82 Security Options	Microsoft network client: Digitally sign communications (if server agrees)		Microsoft network client: Digitally sign communications (if server agrees)This security setting determines whether the SMB client attempts to negotiate SMB packet signing. The server must support SMB packet signing for this setting to take effect.	
83 Security Options	Microsoft network client: Send unencrypted password to third-party SMB servers	Disabled	Microsoft network client: Send unencrypted password to connect to third-party SMB serversIf this security setting is enabled, the Server Message Block (SMB) redirector is allowed to send unencrypted passwords to third-party SMB servers.	
84 Security Options	Microsoft network server: Amount of idle time required before suspending session		Microsoft network server: Amount of idle time required before suspending a sessionThis security setting determines the amount of continuous idle time that must pass in a Server Message Block (SMB) session before the session is suspended.	
85 Security Options	Microsoft network server: Attempt S4U2Self to obtain claim information		Microsoft network server: Attempt S4U2Self to obtain claim informationThis security setting is to support clients running a version of Windows prior to Windows 8 Consumer Preview that do not support S4U2Self.	
86 Security Options	Microsoft network server: Digitally sign communications (always)	Enabled	Microsoft network server: Digitally sign communications (always)This security setting determines whether packet signing is required by the SMB server component. The server message block (SMB) protocol provides the basis for file and printer sharing and many other networking capabilities.	
87 Security Options	Microsoft network server: Digitally sign communications (if client agrees)		Microsoft network server: Digitally sign communications (if client agrees)This security setting determines whether the SMB server will negotiate SMB packet signing with clients that request it.	
88 Security Options	Microsoft network server: Disconnect clients when logon hours expire		Microsoft network server: Disconnect clients when logon hours expireThis security setting determines whether to disconnect users who are connected to the local computer outside of their logon hours.	
89 Security Options	Microsoft network server: Server SPN target name validation level		Microsoft network server: Server SPN target name validation levelThe server message block (SMB) protocol provides the basis for file and printer sharing and many other networking capabilities.	
90 Security Options	Network access: Allow anonymous SID/name translation	Disabled	Network access: Allow anonymous SID/name translationThis security setting determines if an anonymous user can request security identifier (SID) attributes for another user. If this policy is enabled, the user can request the attributes.	
91 Security Options	Network access: Do not allow anonymous enumeration of SAM accounts	Enabled	Network access: Do not allow anonymous enumeration of SAM accountsThis security setting determines what additional permissions will be granted for anonymous connections to the local computer.	
92 Security Options	Network access: Do not allow anonymous enumeration of SAM accounts and shares	Enabled	Network access: Do not allow anonymous enumeration of SAM accounts and sharesThis security setting determines whether anonymous enumeration of SAM accounts and shares is allowed.	
93 Security Options	Network access: Do not allow storage of passwords and credentials for network authentication		Network access: Do not allow storage of credentials or .NET Passports for network authenticationThis security setting determines whether Stored User Names and Passwords saves user names and passwords for network authentication.	
94 Security Options	Network access: Let Everyone permissions apply to anonymous users		Network access: Let Everyone permissions apply to anonymous usersThis security setting determines what additional permissions are granted for anonymous connections to the local computer.	





Microsoft

Best of breed vs best of suite



Used to assembling “best of breed”
into a custom solution

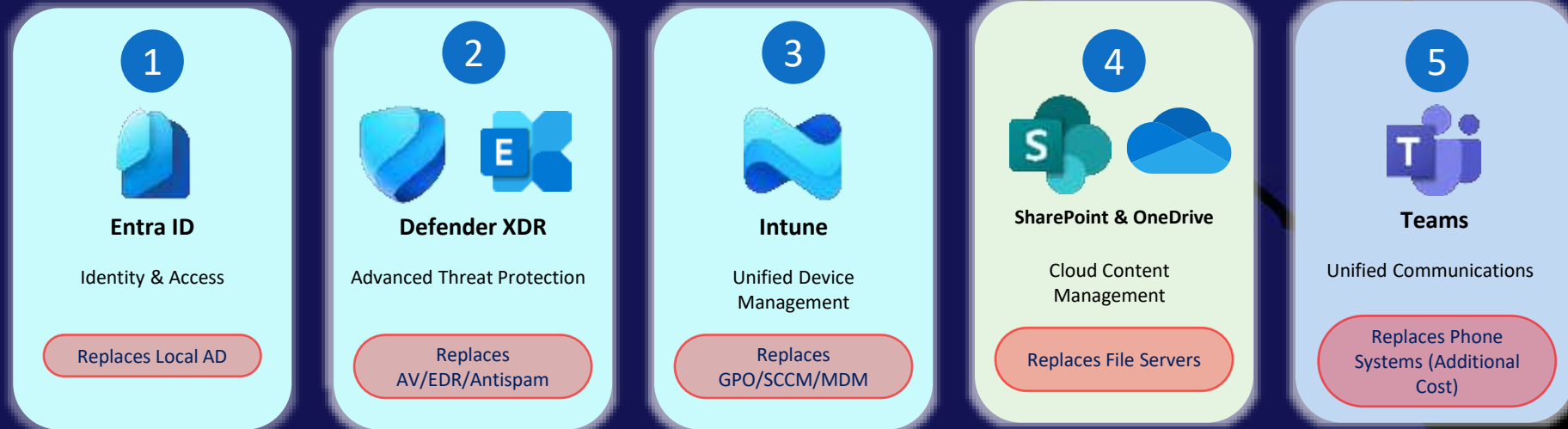


Microsoft has already integrated
security into our products



Microsoft integrates with
existing capabilities

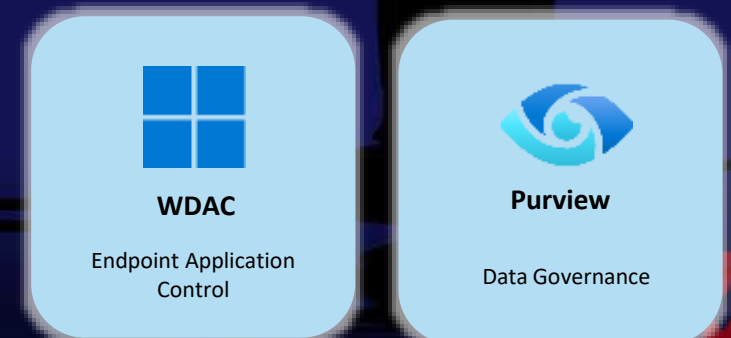
M365 Implementation Path



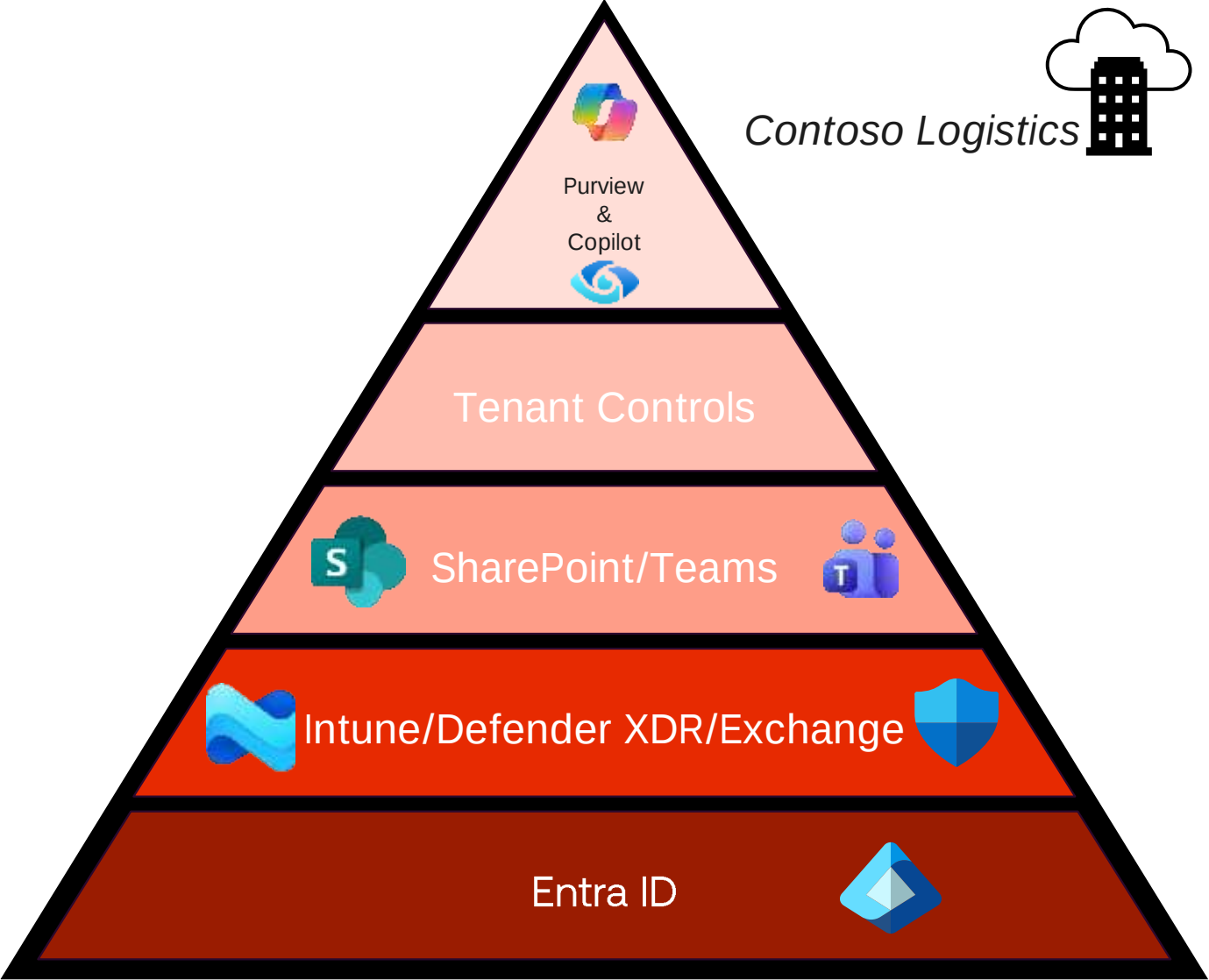
Paid Add-ons



High-Maturity Initiatives



Managing a single tenant is a full-time job



Section 1: Entra ID



Identity is the perimeter. **Fix this first**

Identity and access controls

- ↑ Understand that strong, preventative controls can be applied using Entra Conditional Access Policies
- ↓ Will buy third-party identity tools which show action(s) taken on already compromised account(s)
- ↑ Will be proactive in educating users about phish-resistant MFA and device compliance
- ↓ Allow their C-Suite to dictate to them the baseline level of security that protects their business
- ↑ Take advantage of the complete Defender XDR suite and combine device and email into their controls

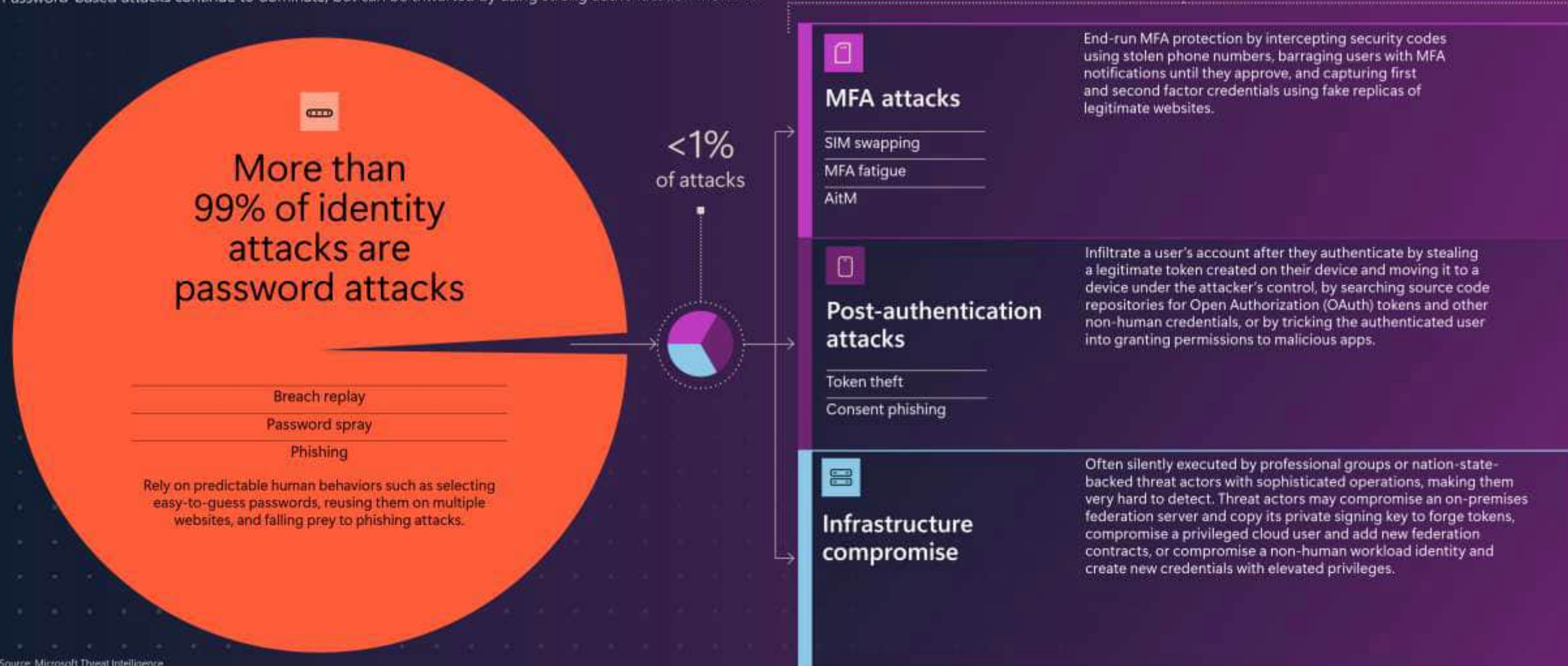
↑ Disciplined IT Dept
↓ Distracted IT Dept



Some spooky stats to scare you!!!

Identity attacks in perspective

Password-based attacks continue to dominate, but can be thwarted by using strong authentication methods.



Key takeaways

What every leader needs to know about today's threat landscape

1. Phishing-resistant MFA is the gold standard for security

No matter how much the cyber threat landscape changes, multifactor authentication (MFA) still blocks over 99% of unauthorized access attempts, making it the single most important security measure an organization can implement. Phishing-resistance provides an even more secure solution.

[Read more on p23](#)

2. Adversaries are targeting identities that enable access to data

Government organizations, information technology (IT) companies, and research and academic institutions were the most impacted by cyber threats this year. Among other data they hold that might interest adversaries, these organizations store vast amounts of personally identifiable information (PII), whose theft enables future attacks. Accessing organizational data has become a primary objective for threat actors. Government, NGO, and academic entities using legacy systems or operating with small IT teams and limited incident response capabilities should prioritize securing data and identity-facing assets.

[Read more on p17](#)

3. Adversaries are using diverse—but well-known—initial access routes

Incident response investigations found that 28% of breaches were initiated through phishing or social engineering, 18% were via unpatched web assets, and 12% leveraged exposed remote services. Not only are adversaries heavily leveraging the ClickFix social engineering method to deliver malware this year, but threat actors are incorporating exploits for known vulnerabilities faster than ever.

[Read more on p13](#)

4. Most attacks are for money, not espionage

More than half of cyberattacks with known motives had financial objectives such as extortion or ransom, while only 4% were motivated solely by espionage.

[Read more on p11](#)

5. Data exfiltration is the norm

Regardless of adversary motivations, accessing organizational data is now a primary goal for attacks. In the past year, we observed data collection in 80% of reactive engagements.

[Read more on p29](#)

6. Workload identities are under threat

As organizations implement phishing-resistant MFA and conditional access policies, adversaries are pivoting to targeting identities and elevated privileges granted to service-to-service workloads like apps, services, and scripts that access cloud resources because service-based workloads are often implemented with elevated privileges but weak security controls.

[Read more on p17](#)

7. Adversaries are conducting destructive attacks in the cloud

We have seen an 87% increase in campaigns aimed at disrupting Azure cloud customer environments through destructive actions such as ransomware or mass deletion. Additionally, over 40% of ransomware attacks now involve hybrid components.

[Read more on p41](#)

8. Adversaries are already using AI as a multiplier

Adversaries have begun implementing AI across a range of malicious activities, including for automated vulnerability discovery or phishing campaigns, malware or deepfake generation, data analysis, and to craft highly convincing fraudulent messages.

[Read more on p52](#)

9. Using AI can be both a benefit and a vulnerability

AI is driving rapid, substantial change. While it offers many benefits for organizations, particularly in cyber defense, AI can be attacked as well. As organizations implement the strengths of AI, they should also manage the weaknesses and potential exposure of sensitive data by protecting against threats like prompt injection, malicious tool invocation, and training data poisoning.

[Read more on p52](#)

10. Quantum computing could challenge cybersecurity

Quantum computing has vast economic potential, but if used by malicious actors, it could threaten the encryption of sensitive data.

[Read more on p57](#)

Target demographics and exposure

Research and academic environments remain disproportionately targeted in password spray attacks, accounting for 52% of observed spray attempts. Factors contributing to this include decentralized IT management, high user turnover, and inconsistent MFA enforcement—conditions also observed in other vulnerable sectors such as rural healthcare. A May 2025 comparative analysis with the Have I Been Pwned database revealed that 85% of usernames targeted in spray attacks appeared in known credential leaks. On average, each compromised username appeared in three separate logs, highlighting the magnitude of the global credential leak problem and the importance of users regularly changing passwords.

Recommendations

To reduce the risk and impact of password spray attacks, organizations should adopt a multi-layered identity protection strategy. This includes taking the following measures:

Enforce phishing-resistant MFA for all users

Phishing-resistant MFA remains the most effective control against unauthorized access using compromised credentials. Even when attackers possess valid usernames and passwords, MFA blocks access in over 99% of cases.

Organizations should monitor for accounts with valid credentials but unenrolled MFA and enforce enrollment policies to close this gap. Organizations should also implement conditional access policies and use risk-based conditional access to block or challenge sign-ins from suspicious IP addresses, geographies, or device types.

Monitor and block malicious IP addresses and ASNs

Continuously monitor authentication logs for error code 50053 and other indicators of spray activity. Block IP addresses and ASNs with repeated failed sign-in attempts or known malicious behavior.

Audit and decommission stale accounts

Regularly review and disable inactive accounts, which are often targeted in spray attacks. Ensure that deprovisioned accounts are removed from all authentication systems.

Educate users on credential hygiene

Promote the use of strong, unique passwords and discourage password reuse. Encourage users to check their credentials against breach databases such as Have I Been Pwned.⁴

Deploy AI-based detection and response

Use AI-driven tools to detect anomalous sign-in patterns and flag potential spray attacks in real time.

“

On average, each compromised username appeared in three separate logs, highlighting the magnitude of the global credential leak problem.



Microsoft Security

@msftsecurity



Currently, 38% of Microsoft Entra ID monthly active users use MFA. Our [@Alex_T_Weinert](#) discusses three managed Conditional Access policies that support our commitment to raise it to 80%. msft.it/6012ihVOe
[#SecureByDesign](#) [#MultifactorAuthentication](#)

And yet...

38%

of Entra ID MAU use MFA

provable threat reduction from it only

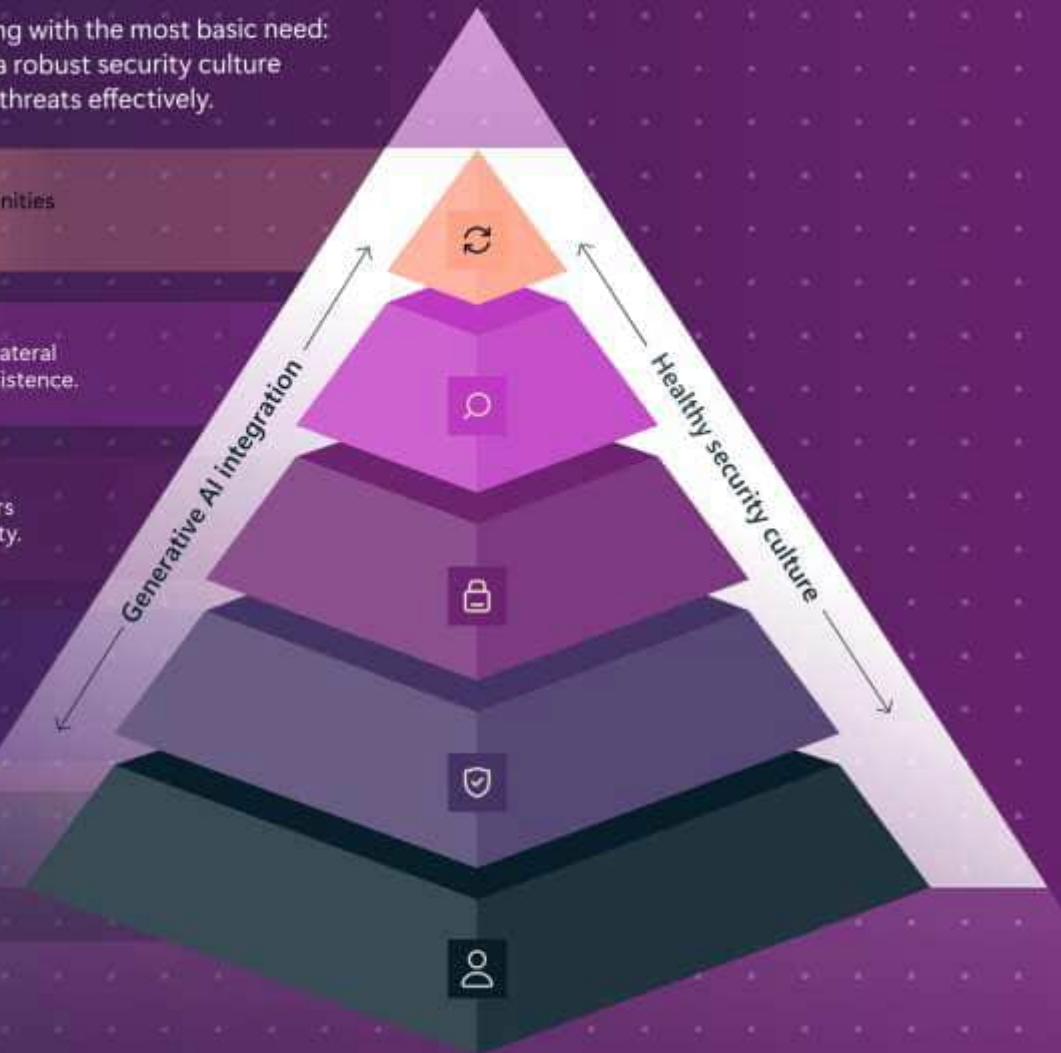
1:22

6:00 PM · Feb 12, 2024 · 18.6K Views

Hierarchy of cybersecurity needs

Drawing inspiration from Maslow's hierarchy of needs, this graphic illustrates a prioritization of cybersecurity, starting with the most basic need: protecting identities. AI has a role at each tier, underscoring its potential to enhance security measures. Cultivating a robust security culture within the organization, helps ensure the technological defenses and human practices evolve in concert to mitigate threats effectively.

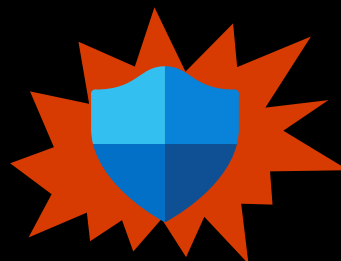
→ AUTOMATE SECURITY OPERATIONS Automating security operations is the holistic approach to building on perspectives and insights across all layers in the pyramid.	→ IMPACT... Automating processes at scale creates new opportunities for insights as well as relief for stressed defenders.
→ DETECT AND REMEDIATE THREATS Monitoring your ecosystem to identify anomalous activity and contain threats.	→ IMPACT... The ability to identify and respond quickly can limit lateral movement, contain damage to assets and deny persistence.
→ SECURE DIGITAL ASSETS Digital assets, whether code, traditional data stores, and now generative AI models are all key components of modern workloads.	→ IMPACT... Modern workloads deliver the value-add to end users who increasingly rely on their integrity and availability.
→ PROTECT ENDPOINTS Protected endpoints include the multiple dimensions of devices in use today – from PCs and mobile devices, to network and operational technology (OT), and servers in datacenters.	→ IMPACT... Effective endpoint protection can limit the repercussions of unauthorized access.
→ PROTECT IDENTITIES "Attackers don't break in, they log in." Credentials for both individuals and machines are the perimeter of the modern attack surface.	→ IMPACT... Strong identity security can greatly reduce risk exposure—particularly for ransomware attacks.



Attack Timeline

'Left of Boom'

Prevent or lessen impact of attacks



'Right of Boom'

Rapidly and effectively manage attacks



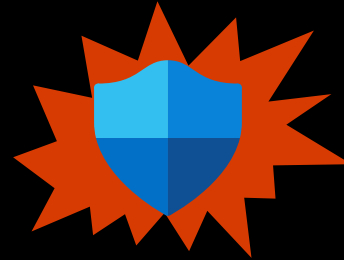
The job will never be 'done' or 'perfect', but it's important to keep doing (like cleaning a house)

[NIST Cybersecurity Framework v2](#)

Attack Timeline

'Left of Boom'

Prevent or lessen impact of attacks



'Right of Boom'

Rapidly and effectively manage attacks

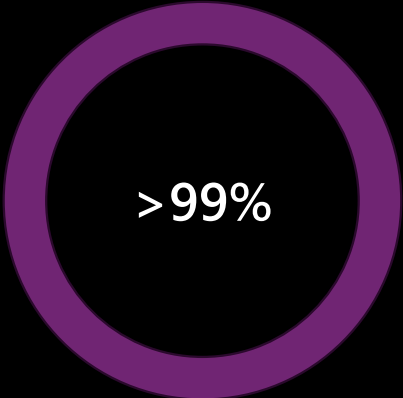
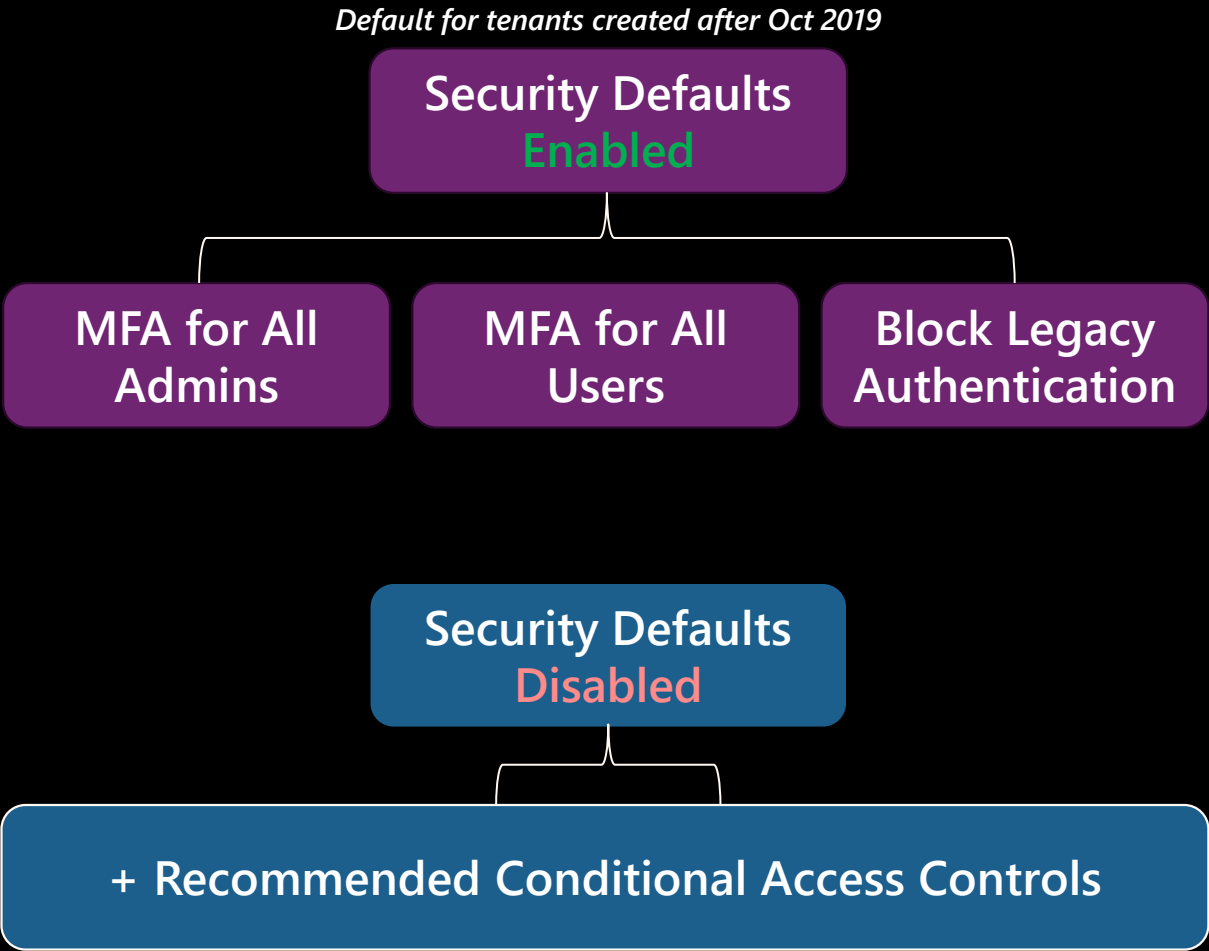


Agent of Prevention

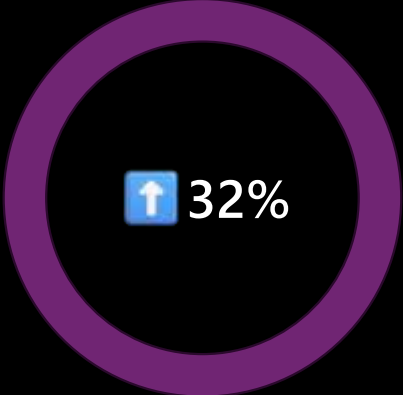


Remediator of Chaos

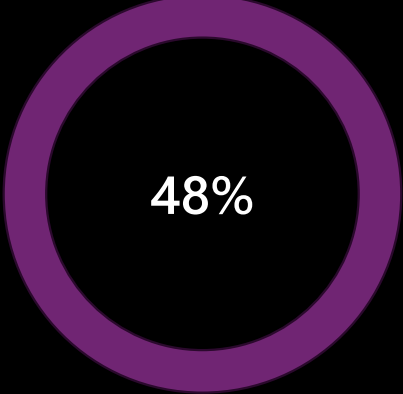
What about Security Defaults?



MFA still blocks vast majority of unauthorised sign-ins



Identity-based attacks surged 32% in H1 2025.



Nearly half of ransomware victims earn ≤\$50M revenue

Security Defaults - MFA Prompting Technical (self.msp)

submitted 6 days ago by reyzaz

I work for a small MSP and we have multiple clients that don't want to buy business premium and instead we opt to simply use security defaults on their Microsoft tenants.

Christmas eve we get a call to say someone in their business has sent out a phishing email they think his account has been hacked. We immediately assume that the person in question has been phished themselves but that turns out to not be the case.

I start investigating sign in logs and I can see successful sign ins from USA (we are UK based) but these are single factor authentication sign ins.

Here is where things get quite strange:

- 1) The user in question had his primary MFA method set to his company mobile phone. This was the only MFA method registered.
- 2) After the account was secured and his password reset I tried to logon to his device from my own device and it let me right in with no MFA prompt.
- 3) After resetting his MFA method and getting him setup with the authenticator app I tried to login again (from another new device in a new location) still no MFA prompt.

I was under the impression that security defaults would force authenticator app and if the user had SMS it was essentially disable this and force them to setup with the app. But the main concern is the fact that I was not prompted for MFA when signing in from a new location.

After doing a bit of digging it seems like security defaults does not enforce MFA on logon attempts from new devices / locations and instead uses "risk factors" to determine when it should or should not prompt the user for MFA.

Has anyone had any similar experiences to this? Personally this is the first time I've ever seen something like this and until this situation security defaults has always forced authenticator app and always forced MFA on new devices.

I'm sure they won't mind paying extra now that they've had a scare for conditional access but I'm assuming this would be the only reliable method to actually setup MFA to prompt for all new devices.



Conditional Access Policy Posture Design

Some policies I use in Conditional Access -
Conditional Access

Generated by
Lewis Barry

CA01: MFA all users all resources

Policy Enabled

Last modified: 2025-07-09

-  Risk
Not configured
-  Device platforms
Not configured
-  Client apps
Not configured
-  Filter for devices
Not configured
-  Locations
Not configured



Users

Grant access 



All cloud apps

 Include:

Users

- All

 Exclude:

Directory roles

- Directory Synchronization Accounts
- On Premises Directory Sync Account

Users

- BreakGlass

Grant Controls

-  Multifactor authentication
-  Authentication strength
-  Compliant device
-  Hybrid Azure AD joined device
-  Approved client app
-  App protection policy
-  Change password
-  Custom authentication factor
-  Terms of use

 Include:

- All

Session Controls

-  App enforced restrictions
-  Conditional Access App Control App Control Policy
-  Sign-in frequency Periodic reauthentication
-  Persistent browser session Always persistent
-  Continuous access evaluation Strictly enforce location policies
-  Disable resilience defaults
-  Token protection for session

CA02: Block Legacy Auth

Policy Enabled

Last modified: 2025-07-09

 **Risk**
Not configured

 **Device platforms**
Not configured

 **Client apps**
- Exchange ActiveSync clients
- Other legacy clients

 **Filter for devices**
Not configured

 **Locations**
Not configured



✓ **Include:**
Users
- All

Grant Controls

-  Multifactor authentication
-  Authentication strength
-  Compliant device
-  Hybrid Azure AD joined device
-  Approved client app
-  App protection policy
-  Change password
-  Custom authentication factor
-  Terms of use

✓ **Include:**
- All

Session Controls

-  App enforced restrictions
-  Conditional Access App Control
App Control Policy
-  Sign-in frequency
Periodic reauthentication
-  Persistent browser session
Always persistent
-  Continuous access evaluation
Strictly enforce location policies
-  Disable resilience defaults
-  Token protection for session



CA03: Block Unsupported OS Types

Policy Enabled

Last modified: 2025-09-13

Risk
Not configured

Device platforms
☒ **Include**
- All

☐ **Exclude**
- Android
- iOS
- Windows
- macOS

Client apps
Not configured

Filter for devices
Not configured

Locations
Not configured

Users

- ☒ **Include:**
Users
- All

Block access

All cloud apps

- ☒ **Include:**
- All

Grant Controls

- Multifactor authentication
- Authentication strength
- Compliant device
- Hybrid Azure AD joined device
- Approved client app
- App protection policy
- Change password
- Custom authentication factor
- Terms of use

Session Controls

- App enforced restrictions
- Conditional Access App Control
App Control Policy
- Sign-in frequency
Periodic reauthentication
- Persistent browser session
Always persistent
- Continuous access evaluation
Strictly enforce location policies
- Disable resilience defaults
- Token protection for session



CA04: Require App Protection (mobile)

Policy Enabled

Last modified: 2025-09-13



Risk

Not configured



Device platforms



Include

- Android
- iOS



Client apps

Not configured



Filter for devices

Not configured



Locations

Not configured



Users



Include:

Users

- All

Grant access



All cloud apps



Include:

- All

Grant Controls



Multifactor authentication



Authentication strength



Compliant device



Hybrid Azure AD joined device



Approved client app



App protection policy



Change password



Custom authentication factor



Terms of use

Session Controls



App enforced restrictions



Conditional Access App Control
App Control Policy



Sign-in frequency
Periodic reauthentication



Persistent browser session
Always persistent



Continuous access evaluation
Strictly enforce location policies



Disable resilience defaults



Token protection for session

CA06: Block Code Flow

Policy Enabled

Last modified: 2025-09-30

-  Risk
Not configured
-  Device platforms
Not configured
-  Client apps
Not configured
-  Filter for devices
Not configured
-  Locations
Not configured



Users

✓ Include:

Users

- All

✗ Exclude:

Users

- BreakGlass

Block access



All cloud apps

Grant Controls

-  Multifactor authentication
-  Authentication strength
-  Compliant device
-  Hybrid Azure AD joined device
-  Approved client app
-  App protection policy
-  Change password
-  Custom authentication factor
-  Terms of use

✓ Include:

- All

Session Controls

-  App enforced restrictions
-  Conditional Access App Control
App Control Policy
-  Sign-in frequency
Periodic reauthentication
-  Persistent browser session
Always persistent
-  Continuous access evaluation
Strictly enforce location policies
-  Disable resilience defaults
-  Token protection for session

CA12: Block Authentication Transfer Flows

Policy Enabled

Last modified: 2025-09-14

-  Risk
Not configured
-  Device platforms
Not configured
-  Client apps
Not configured
-  Filter for devices
Not configured
-  Locations
Not configured



Users

✓ Include:
Users
- All

Block access



All cloud apps

✓ Include:
- All

Grant Controls

-  Multifactor authentication
-  Authentication strength
-  Compliant device
-  Hybrid Azure AD joined device
-  Approved client app
-  App protection policy
-  Change password
-  Custom authentication factor
-  Terms of use

Session Controls

-  App enforced restrictions
-  Conditional Access App Control App Control Policy
-  Sign-in frequency Periodic reauthentication
-  Persistent browser session Always persistent
-  Continuous access evaluation Strictly enforce location policies
-  Disable resilience defaults
-  Token protection for session

CA07: Sign In Risk - Medium/High – MFA – Entra ID P2

Policy Enabled

Last modified: 2025-09-13

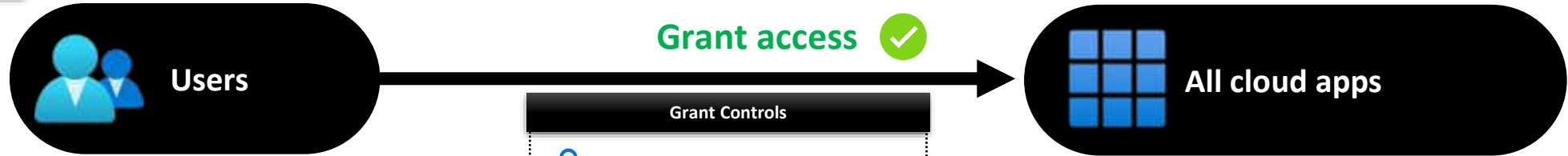
 **Risk**
Sign-in risk:
- High
- Medium

 **Device platforms**
Not configured

 **Client apps**
Not configured

 **Filter for devices**
Not configured

 **Locations**
Not configured



- ☒ **Include:**
Users
- All
- ☐ **Exclude:**
Directory roles
- Directory Synchronization Accounts
- On Premises Directory Sync Account
- Users**
- BreakGlass

Grant Controls

 Multifactor authentication

 Authentication strength

 Compliant device

 Hybrid Azure AD joined device

 Approved client app

 App protection policy

 Change password

 Custom authentication factor

 Terms of use

- ☒ **Include:**
- All

Session Controls

 App enforced restrictions

 Conditional Access App Control
App Control Policy

 Sign-in frequency
Every time

 Persistent browser session
Always persistent

 Continuous access evaluation
Strictly enforce location policies

 Disable resilience defaults

 Token protection for session

CA08: User Risk - High - Reset PW – Entra ID P2

Policy Enabled

Last modified: 2025-09-13

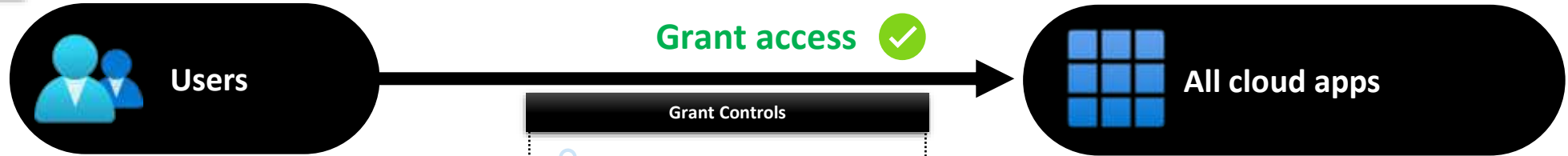
**Risk**
User risk:
- High

Device platforms
Not configured

Client apps
Not configured

Filter for devices
Not configured

Locations
Not configured



- ☒ **Include:**
Users
- All
- ☐ **Exclude:**
Directory roles
- Directory Synchronization Accounts
- On Premises Directory Sync Account

- Grant Controls**
-  Multifactor authentication
 -  Auth strength: Multifactor authentication
 -  Compliant device
 -  Hybrid Azure AD joined device
 -  Approved client app
 -  App protection policy
 -  Change password
 -  Custom authentication factor
 -  Terms of use

- ☒ **Include:**
- All

- Session Controls**
-  App enforced restrictions
 -  Conditional Access App Control App Control Policy
 -  Sign-in frequency
Every time
 -  Persistent browser session
Always persistent
 -  Continuous access evaluation
Strictly enforce location policies
 -  Disable resilience defaults
 -  Token protection for session

CA10: Breakglass Require FIDO2

Policy Enabled

Last modified: 2025-09-13

-  Risk
Not configured
-  Device platforms
Not configured
-  Client apps
Not configured
-  Filter for devices
Not configured
-  Locations
Not configured



Users

✓ Include:
Users
- BreakGlass

Grant access ✓



All cloud apps

✓ Include:
- All

Grant Controls

-  Multifactor authentication
-  Auth strength: Phishing-resistant MFA
-  Compliant device
-  Hybrid Azure AD joined device
-  Approved client app
-  App protection policy
-  Change password
-  Custom authentication factor
-  Terms of use

Session Controls

-  App enforced restrictions
-  Conditional Access App Control App Control Policy
-  Sign-in frequency Periodic reauthentication
-  Persistent browser session Always persistent
-  Continuous access evaluation Strictly enforce location policies
-  Disable resilience defaults
-  Token protection for session



CA05: Require Compliant Desktop

Policy Enabled

Last modified: 2025-09-21

Risk
Not configured

Device platforms
☒ Include

- Windows
- macOS

Client apps
Not configured

Filter for devices
Not configured

Locations
Not configured



Users

☒ Include:
Users
- All

Grant access ☒



All cloud apps

☒ Include:
- All

Grant Controls

- Multifactor authentication
- Authentication strength
- Compliant device
- Hybrid Azure AD joined device
- Approved client app
- App protection policy
- Change password
- Custom authentication factor
- Terms of use

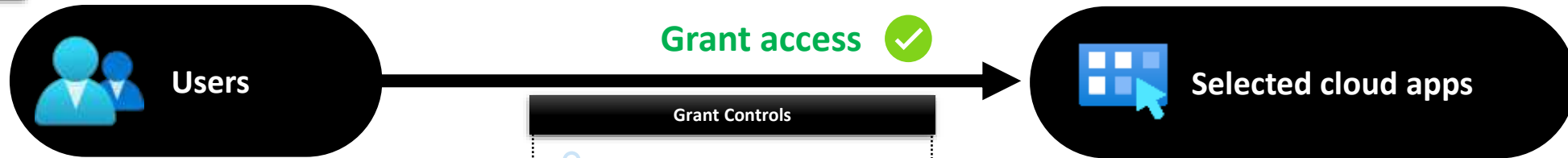
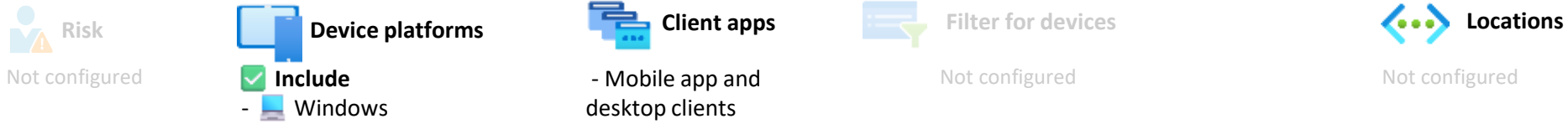
Session Controls

- App enforced restrictions
- Conditional Access App Control
App Control Policy
- Sign-in frequency
Periodic reauthentication
- Persistent browser session
Always persistent
- Continuous access evaluation
Strictly enforce location policies
- Disable resilience defaults
- Token protection for session

CA09: Windows Token Protection

Policy Report-only

Last modified: 2025-09-13



- ☒ **Include:**
Users
- All
- ☒ **Exclude:**
Users
- BreakGlass

Grant Controls	
	Multifactor authentication
	Authentication strength
	Compliant device
	Hybrid Azure AD joined device
	Approved client app
	App protection policy
	Change password
	Custom authentication factor
	Terms of use

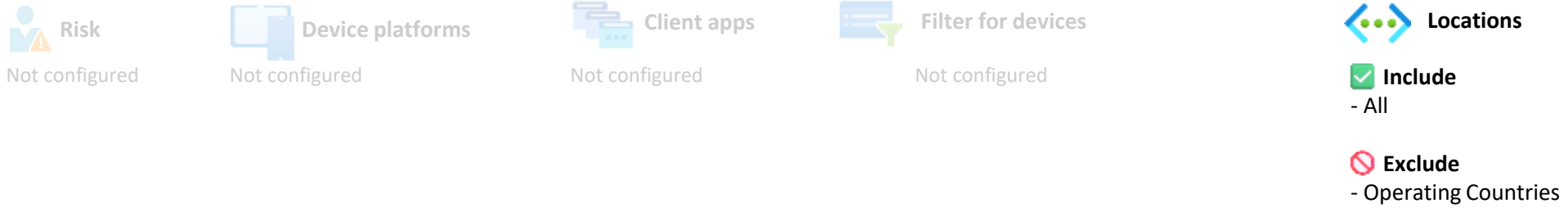
- ☒ **Include:**
- Microsoft Teams Services
- Office 365 Exchange Online
- Office 365 SharePoint Online

Session Controls	
	App enforced restrictions
	Conditional Access App Control App Control Policy
	Sign-in frequency Periodic reauthentication
	Persistent browser session Always persistent
	Continuous access evaluation Strictly enforce location policies
	Disable resilience defaults
	Token protection for session

CA11: Register Security info only in operating countries

Policy Report-only

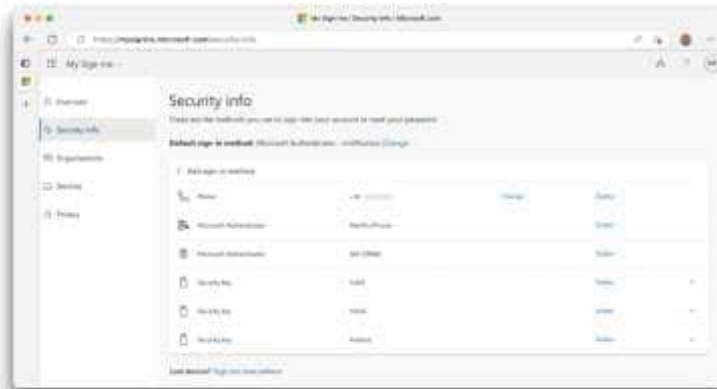
Last modified: 2025-09-14



✓ **Include:**
Users
- All

Grant Controls

- Multifactor authentication
- Authentication strength
- Compliant device
- Hybrid Azure AD joined device
- Approved client app
- App protection policy
- Change password
- Custom authentication factor
- Terms of use



Session Controls

- App enforced restrictions
- Conditional Access App Control
App Control Policy
- Sign-in frequency
Periodic reauthentication
- Persistent browser session
Always persistent
- Continuous access evaluation
Strictly enforce location policies
- Disable resilience defaults
- Token protection for session

Entra Settings to Focus on



1. Conditional Access

- ◆ MFA for all users – No Exceptions
- ◆ Block legacy authentication
- ◆ Block unsupported OS types
- ◆ Require device compliance*



2. Prevent users from consenting to Enterprise Apps

Home > Enterprise applications | User settings

Consent and permissions | User consent settings ...

«  Save  Discard |  Got feedback?

Manage

-  User consent settings
-  Admin consent settings
-  Permission classifications

Control when end users and group owners are allowed to grant consent to applications, and when they will be required to request administrator review and approval. Allowing users to grant apps access to data helps them acquire useful applications and be productive, but can represent a risk in some situations if it's not monitored and controlled carefully.

User consent for applications
Configure whether users are allowed to consent for applications to access your organization's data. [Learn more](#)

- ☒ Do not allow user consent
An administrator will be required for all apps.
- ☐ Allow user consent for apps from verified publishers, for selected permissions
All users can consent for permissions classified as "low impact", for apps from verified publishers or apps registered in this organization.
- ☐ Let Microsoft manage your consent settings (Recommended)
Automatically update your organization to Microsoft's current user consent guidelines. [Learn more](#)

 When user consent for applications is disabled, users may still be able to connect their work or school accounts with LinkedIn. You can manage LinkedIn account connects in [User Settings](#).

3. Do not exclude your office from MFA policies



💬 "We keep getting prompted for MFA"

■ Review your policies for any session controls that might be improperly configured. A device using Windows Hello as the primary sign in method will almost never prompt for additional MFA, as Windows Hello counts as MFA

💬 "We build laptops frequently, so exclude the IT or service accounts"

■ You are making the most privileged users the weakest ones. Autopilot **User-Driven** should be completed by the end user who that laptop is for, where they can complete MFA and Windows Hello config as part of the OOB

3. Do not exclude your office from MFA policies



- 💬 "Our internal network is one we trust, because we have a Next-Gen Firewall"
- Trusting the internal network is inherently against "Zero Trust" principles, and if an attacker gained remote or even physical persistence to that network, all your users are at-risk
- 💬 "We've always done it this way, since Office 365 became a thing"
- This is never an acceptable reason to continue doing anything

4. Set passwords to NOT expire

Intermittent Events

Usability considerations for intermittent events include:

- When users create and change passwords
 - Clearly communicate information on how to create and change passwords.
 - Clearly communicate password requirements, as specified in [Sec. 3.1.1](#).
 - Allow at least 64 characters in length to support the use of passphrases. Encourage users to make passwords as lengthy as they want and use any characters that they like (including spaces) to aid memorization. Ensure that user interfaces support sufficient password lengths.
 - Do not impose other composition rules (e.g., mixtures of different character types) on passwords.
 - Do not require that passwords be changed arbitrarily (e.g., periodically) unless there is a user request or evidence of authenticator compromise (see [Sec. 3.1.1](#)).
- Provide clear, meaningful, and actionable feedback when chosen passwords are rejected (e.g., when it appears on a “blocklist” of unacceptable passwords or has been used previously).

4. Set passwords to NOT expire

Don't enforce regular password expiry

Regular password changing harms rather than improves security. Many systems will force users to change their password at regular intervals, typically every 30, 60 or 90 days. This imposes burdens on the user and there are costs associated with recovering accounts.

Forcing password expiry carries no real benefits because:

- the user is likely to choose new passwords that are only minor variations of the old
- stolen passwords are generally exploited immediately
- resetting the password gives you no information about whether a compromise has occurred
- an attacker with access to the account will probably also receive the request to reset the password
- if compromised via insecure storage, the attacker will be able to find the new password in the same place



National Cyber
Security Centre

4. Set passwords to NOT expire

2.8 Passwords SHALL NOT Expire

Ensure that user passwords do not expire. Both the National Institute of Standards and Technology (NIST) and Microsoft emphasize MFA because they indicate that mandated password changes make user accounts less secure.

2.8.1 Policy

- User passwords SHALL NOT expire.

2.8.2 Resources

- [Password policy recommendations - Microsoft 365 admin | Microsoft Docs.](#)
- Eliminate bad passwords using Azure Active Directory Password Protection.
- NIST Special Publication 800-63B - Digital Identity Guidelines.



CISA
CYBER+INFRASTRUCTURE

5. Consider your Authentication Methods



Authentication methods | Policies

Conditional Access UK - Microsoft Entra ID Security

[Add external MFA](#) [Refresh](#) [Got feedback?](#)

Manage

Policies

Password protection

Registration campaign

Authentication strengths

Settings

Monitoring

Activity

User registration details

Registration and reset events

Bulk operation results

Bulk operation results (Preview)

Use authentication methods policies to configure the authentication methods your users may register and use. If a user scope for a method, they may use it to authenticate and for password reset (some methods aren't supported for some scenarios). [Learn more](#)

Migration status ✔ Complete [\(change\)](#)

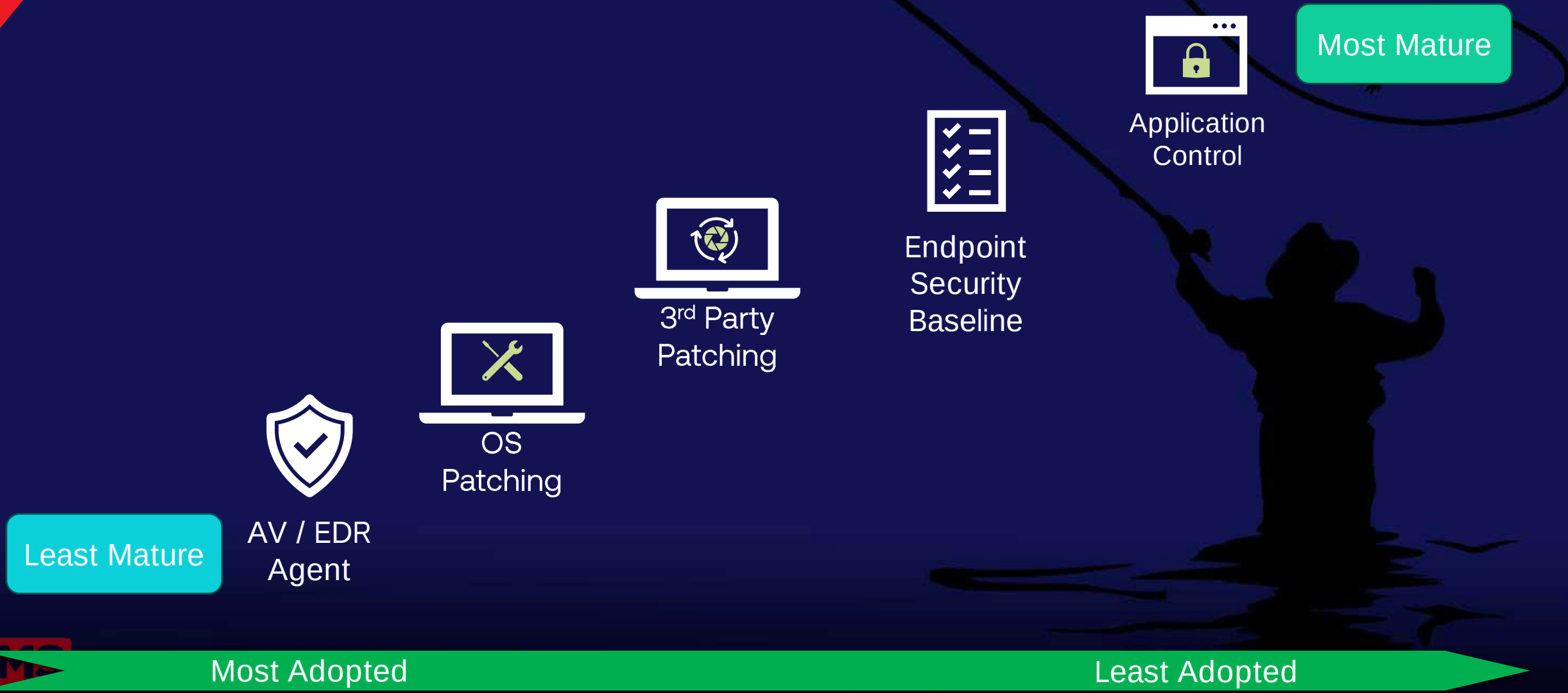
Method	Target	Enabled
Built-In		
Passkey (FIDO2)	All users	Yes
Microsoft Authenticator	All users	Yes
SMS		No
Temporary Access Pass		No
Hardware OATH tokens (Preview)		No
Software OATH tokens	All users	Yes
Voice call		No
Email OTP	All users	Yes
Certificate-based authentication		No
QR code		No

MMS

Section 2: Intune



Endpoint Security Maturity Scale



Intune Settings to Focus on



1. Device Enrollment Restrictions

Home > Devices | Enrollment

Microsoft Intune ...

MDM user scope ⓘ

☐ None ☐ Some ☒ All

MDM terms of use URL ⓘ

MDM discovery URL ⓘ

Disable MDM enrollment when adding work or school account on Windows ⓘ

☒ Yes

MDM compliance URL ⓘ

[Restore default MDM URLs](#)

1. Device Enrollment Restrictions

Home > Devices | Enrollment > Enrollment restrictions > All Users

All Users | Properties ...

>>

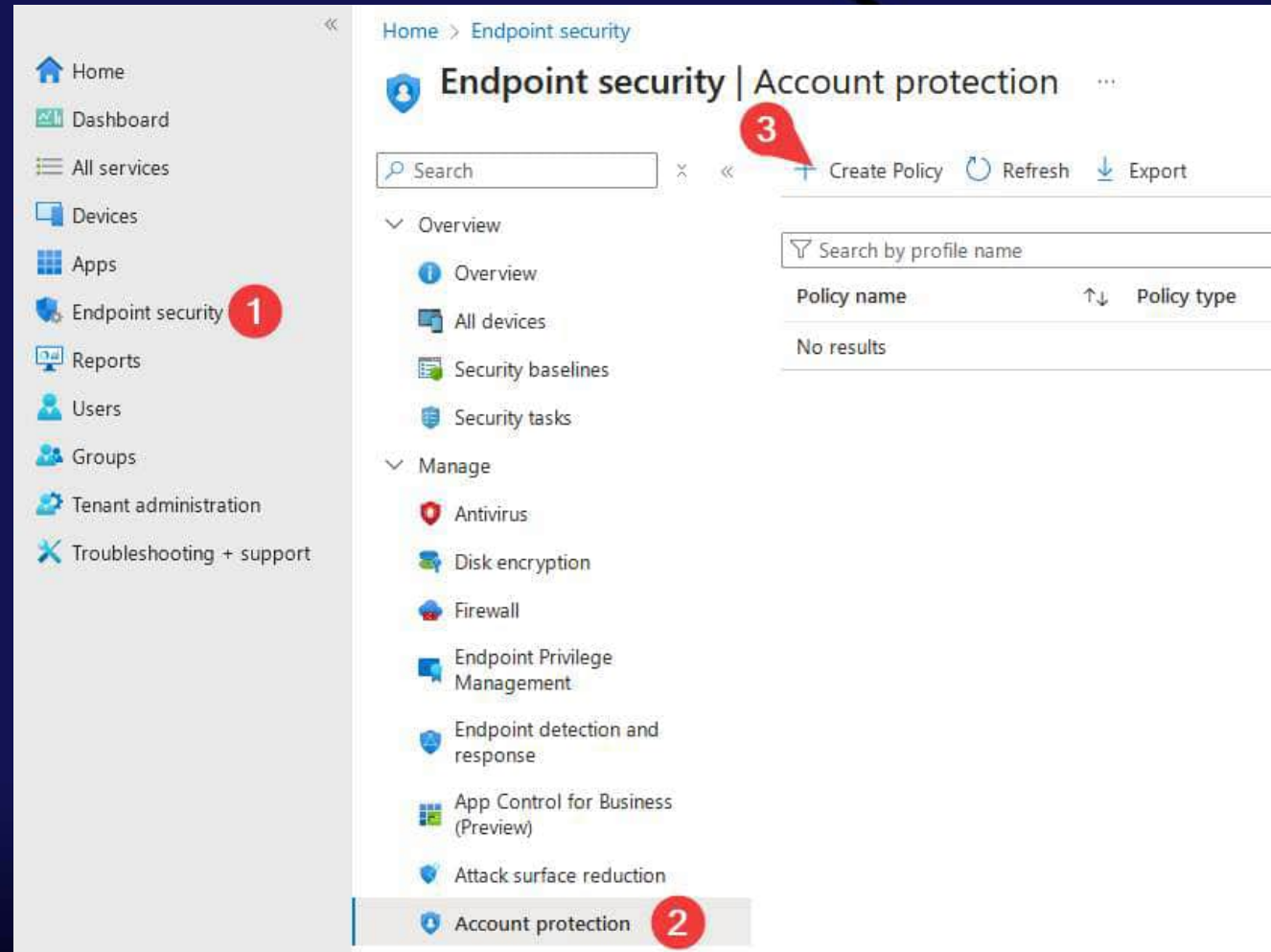
Basics

Name	All Users
Description	This is the default Device Type Restriction applied with lowest priority to all users regardless of group membership.
Platform	AllPlatforms

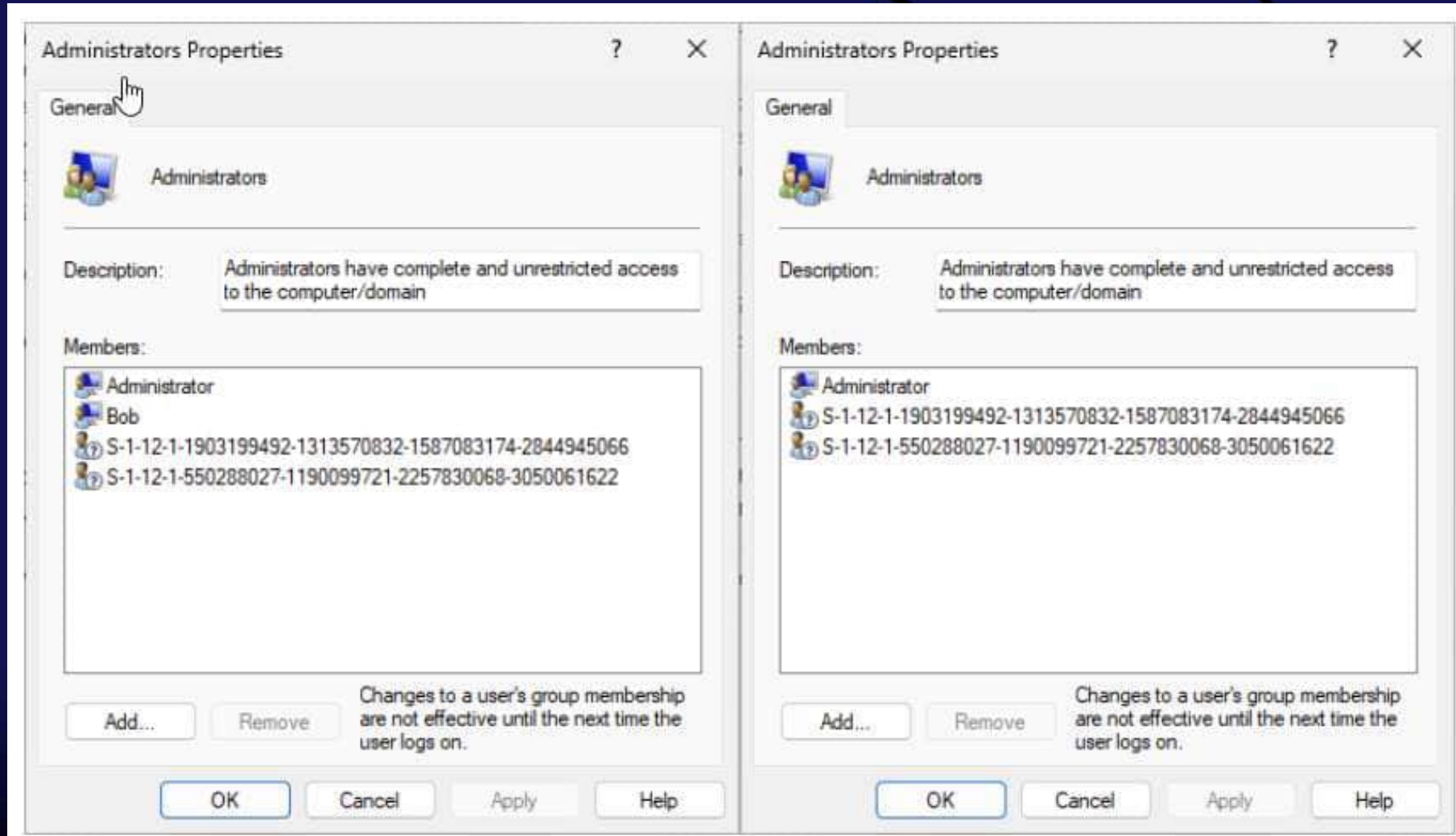
Platform settings [Edit](#)

Type	Platform	Min	Max	Personally owned	Blocked manufacturers
Android Enterprise (work profile)	Allow			Block	
Android device administrator	Allow			Block	
iOS/iPadOS	Allow			Block	N/A
macOS	Allow	N/A	N/A	Block	N/A
Windows (MDM)	Allow			Block	N/A

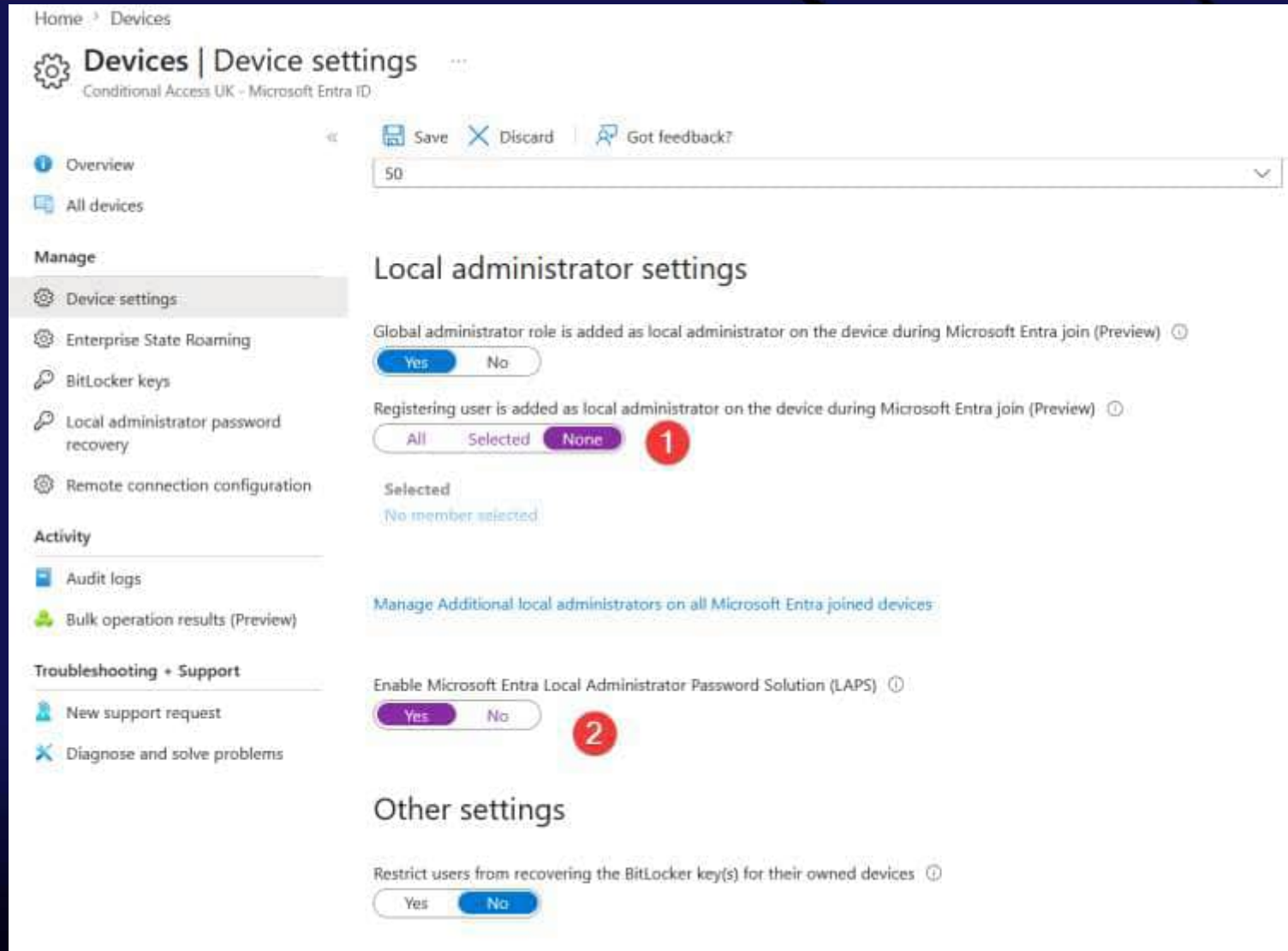
2. Remove Local Admin rights



2. Remove Local Admin rights



2. Remove Local Admin rights - LAPS



Home > Devices

Devices | Device settings

Conditional Access UK - Microsoft Entra ID

Save Discard Got feedback?

50

Local administrator settings

Global administrator role is added as local administrator on the device during Microsoft Entra join (Preview) ⓘ

Yes No

Registering user is added as local administrator on the device during Microsoft Entra join (Preview) ⓘ

All Selected None 1

Selected

No member selected

[Manage Additional local administrators on all Microsoft Entra joined devices](#)

Enable Microsoft Entra Local Administrator Password Solution (LAPS) ⓘ

Yes No 2

Other settings

Restrict users from recovering the BitLocker key(s) for their owned devices ⓘ

Yes No

2. Remove Local Admin rights - LAPS

Home > Devices | Configuration

 **Win - OIB - ES - Windows LAPS - D - LAPS Configuration (24H2+) - v3.6**  

Device configuration profile

 Delete

Selected tags: Default

Configuration settings [Edit](#)

^ LAPS

Backup Directory 	Backup the password to Microsoft Entra ID only
Password Age Days 	7
Password Complexity 	Passphrase (short words with unique prefixes)
Passphrase Length 	4
Password Length 	21
Post Authentication Actions 	Reset the password, logoff the managed account, and terminate any remaining processes: upon expiration of the grace period, the managed account password is reset, any interactive logon sessions using the managed account are logged off, and any remaining processes are terminated.
Post Authentication Reset Delay 	1

3. Implement Browser Controls

- ◆ Remove unnecessary browsers
 - ◆ Google Chrome
- ◆ Configure Edge SmartScreen
- ◆ Block sync of personal accounts
- ◆ Implement extension allow listing
- ◆ Enable “ask where to save”
- ◆ Decide if you want to use the built-in PW manager and set it



3. Implement Browser Controls – Intune or Admin Centre?

 **Win - OIB - SC - Microsoft Edge - U - User Experience - v3.4**  

Device configuration profile

 Delete

Extensions

Configure extension management settings (Device)	<pre>{"": {}, "amnbcmdbanbkjhnfoeceemmmdiepnbp": {"installation_mode": "normal_installed", "blocked_install_message": "This is terrible.", "toolbar_state": "default_hidden"}}</pre>
Configure extension management settings ⓘ	Enabled

^ Microsoft Edge - Default Settings (users can override)

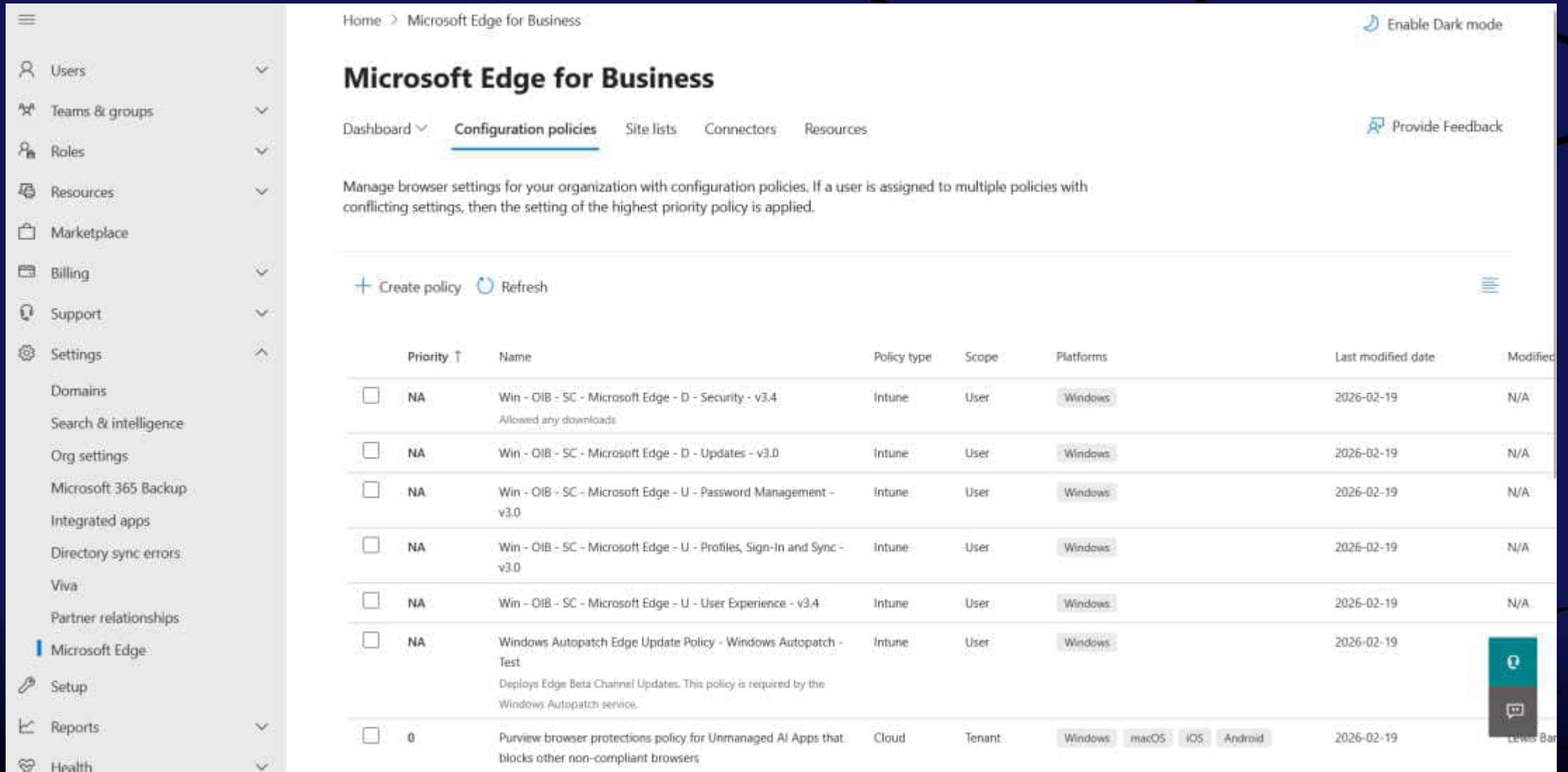
Performance

Enable startup boost (User) ⓘ	Disabled
-------------------------------	----------

Sleeping Tabs settings

Configure Sleeping Tabs (User) ⓘ	Enabled
----------------------------------	---------

3. Implement Browser Controls – Intune or Admin Centre?



Home > Microsoft Edge for Business

Enable Dark mode

Provide Feedback

Microsoft Edge for Business

Dashboard Configuration policies Site lists Connectors Resources

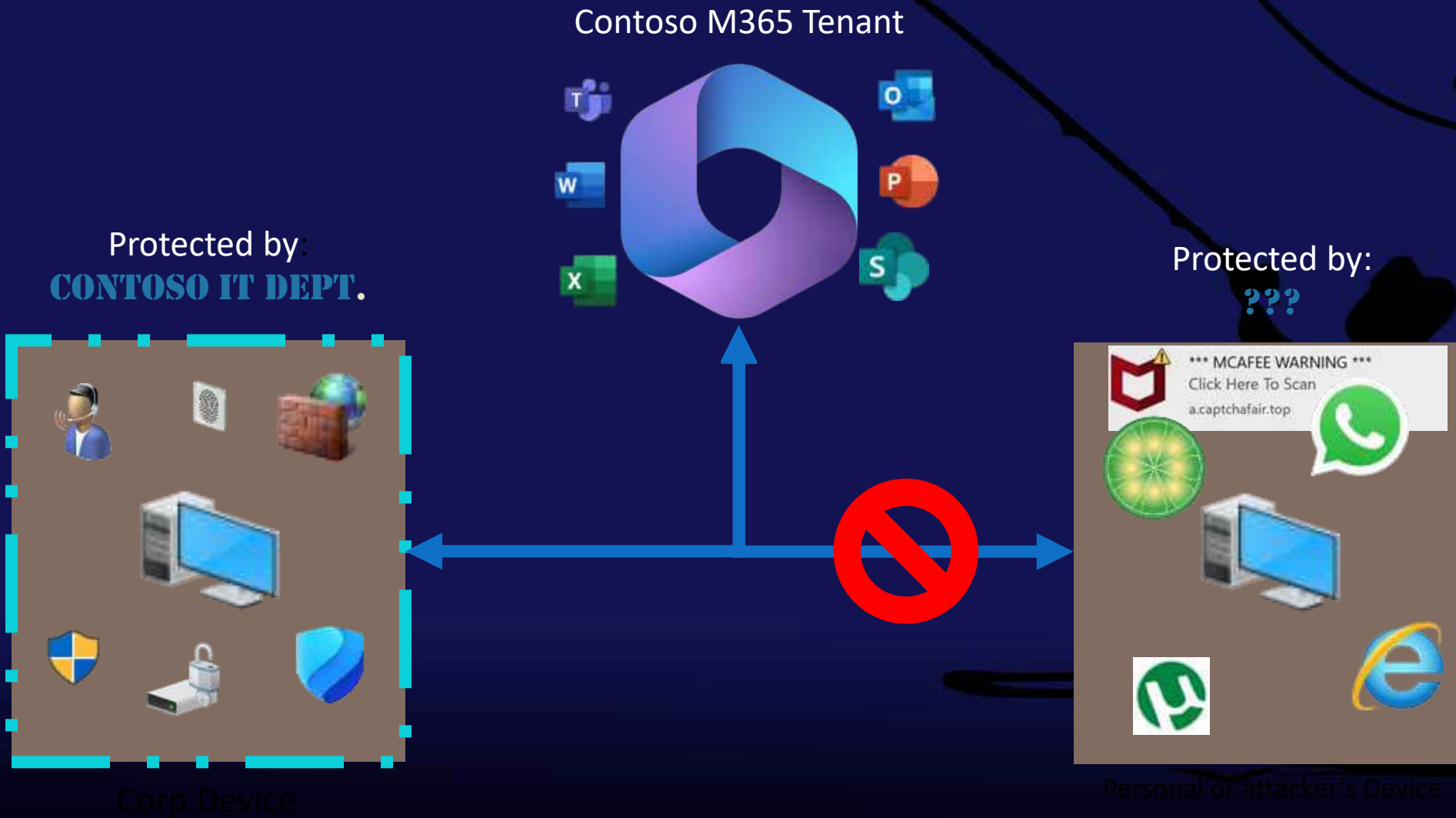
Manage browser settings for your organization with configuration policies. If a user is assigned to multiple policies with conflicting settings, then the setting of the highest priority policy is applied.

+ Create policy Refresh

	Priority ↑	Name	Policy type	Scope	Platforms	Last modified date	Modified
☐	NA	Win - OIB - SC - Microsoft Edge - D - Security - v3.4 Allowed any downloads	Intune	User	Windows	2026-02-19	N/A
☐	NA	Win - OIB - SC - Microsoft Edge - D - Updates - v3.0	Intune	User	Windows	2026-02-19	N/A
☐	NA	Win - OIB - SC - Microsoft Edge - U - Password Management - v3.0	Intune	User	Windows	2026-02-19	N/A
☐	NA	Win - OIB - SC - Microsoft Edge - U - Profiles, Sign-In and Sync - v3.0	Intune	User	Windows	2026-02-19	N/A
☐	NA	Win - OIB - SC - Microsoft Edge - U - User Experience - v3.4	Intune	User	Windows	2026-02-19	N/A
☐	NA	Windows Autopatch Edge Update Policy - Windows Autopatch - Test Deploys Edge Beta Channel Updates. This policy is required by the Windows Autopatch service.	Intune	User	Windows	2026-02-19	
☐	0	Purview browser protections policy for Unmanaged AI Apps that blocks other non-compliant browsers	Cloud	Tenant	Windows macOS iOS Android	2026-02-19	

MMS

4. Require Compliant Device



4. Require Compliant Device

Home > Devices | Compliance

Win - OIB - Compliance - U - Device Health - v3.1

Compliance policy - Windows 10 and later

 Delete

Monitor Properties

Basics [Edit](#)

Name	Win - OIB - Compliance - U - Device Health - v3.1
Description	--
Platform	Windows 10 and later
Profile type	Windows 10/11 compliance policy

Compliance settings [Edit](#)

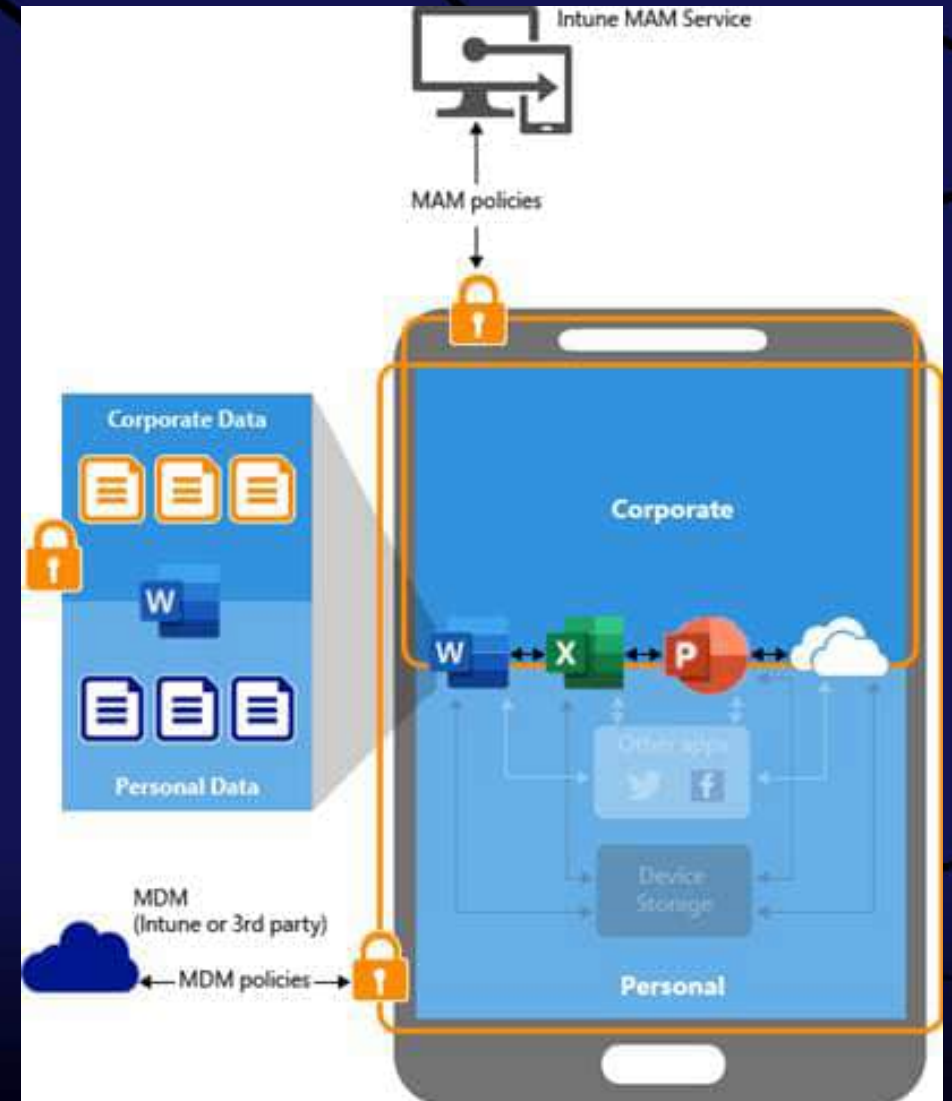
Device Health

Bitlocker	Required
Secure Boot	Required
Code Integrity	Required

Compliance policies
are only really effective
once you tie them to
Conditional Access
policies

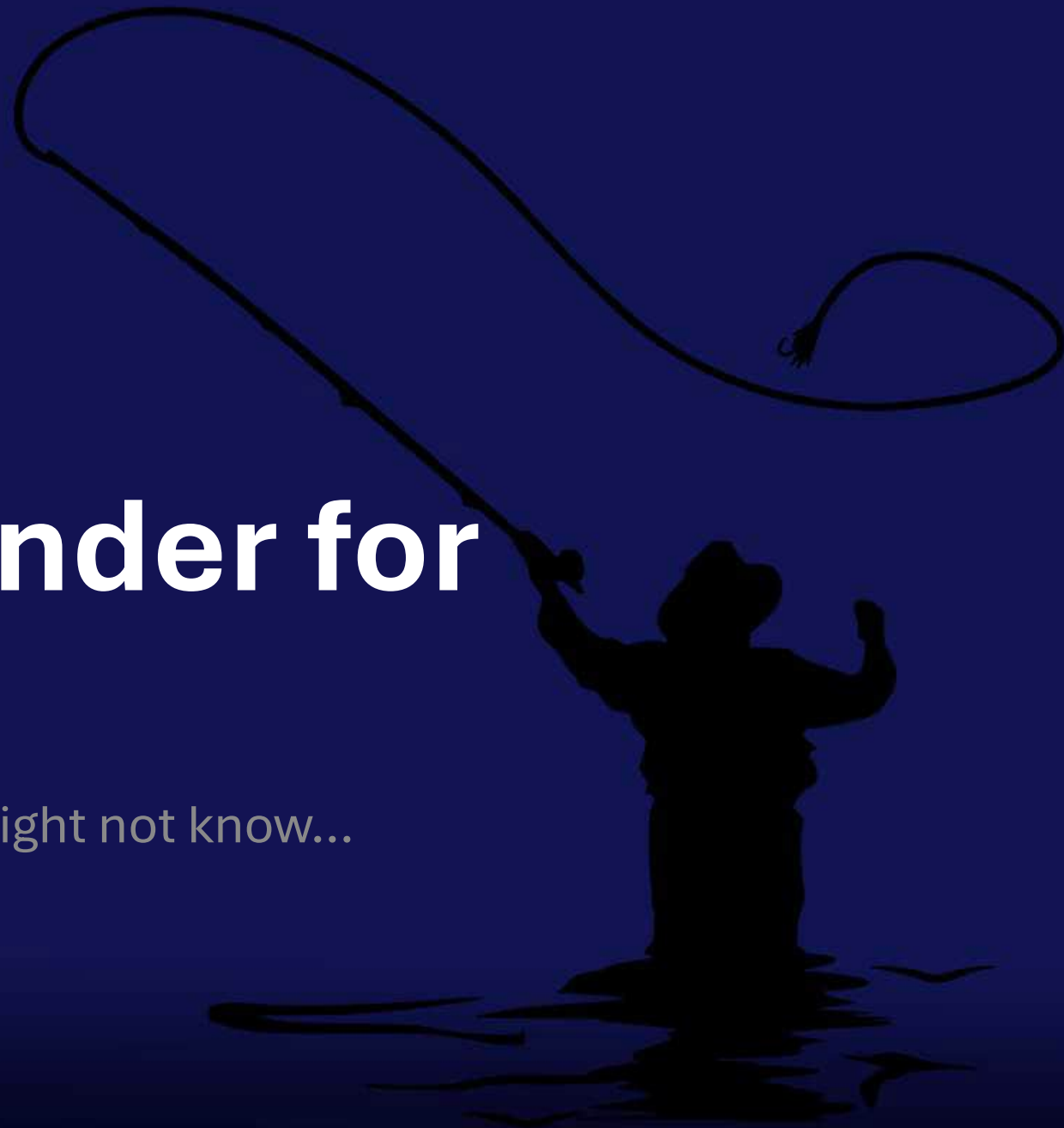
5. Implement MAM-WE as standard

- ♦ Mobile Application Management – Without Enrollment
- ♦ Create the policies in Intune
- ♦ Wait 24hrs
- ♦ Enforce with Conditional Access

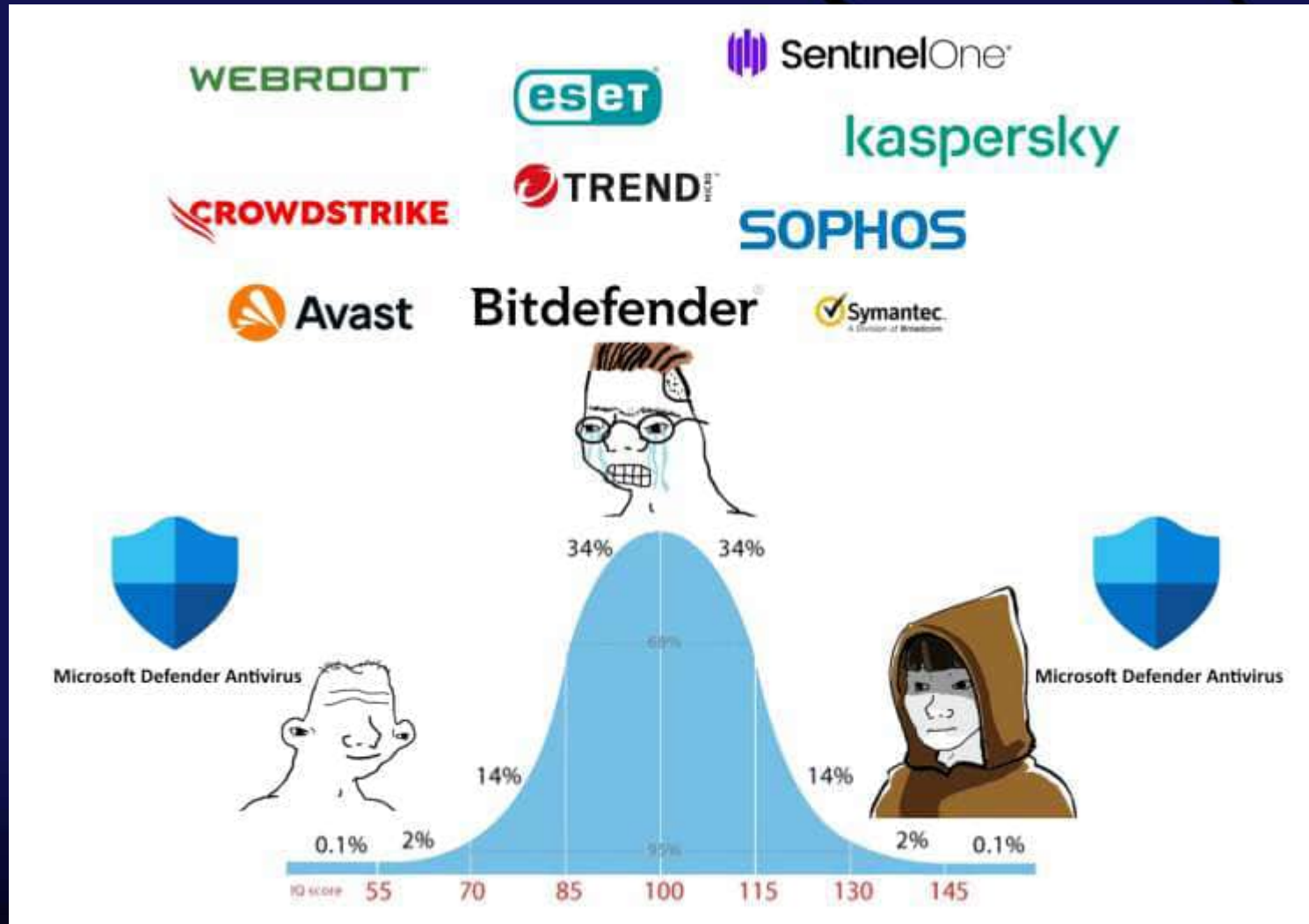


Section 3: Defender for Endpoint

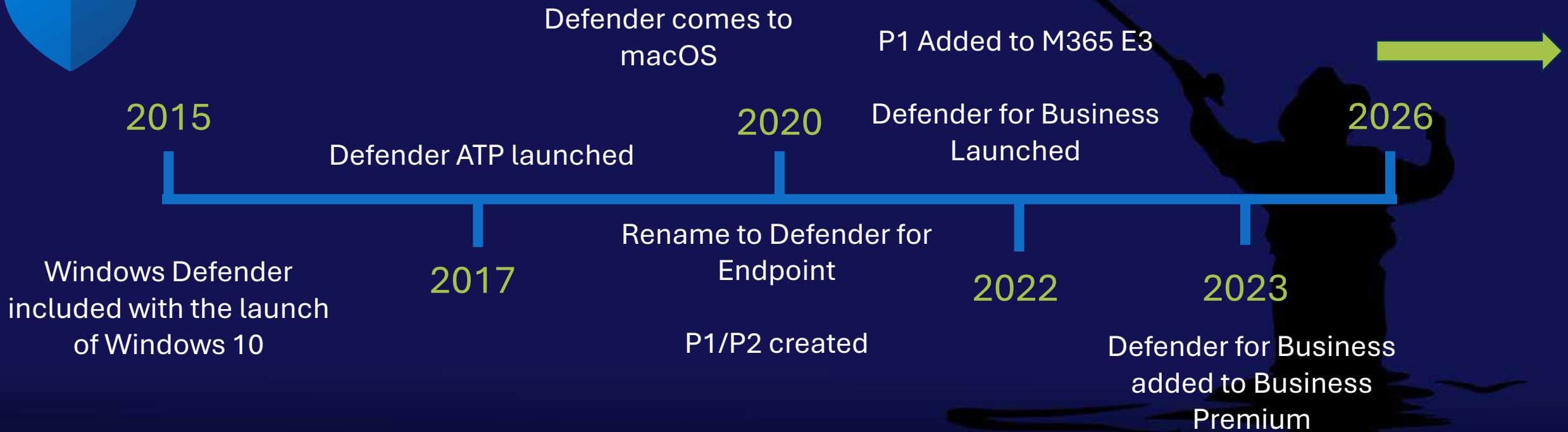
No top five for this section. Things you might not know...



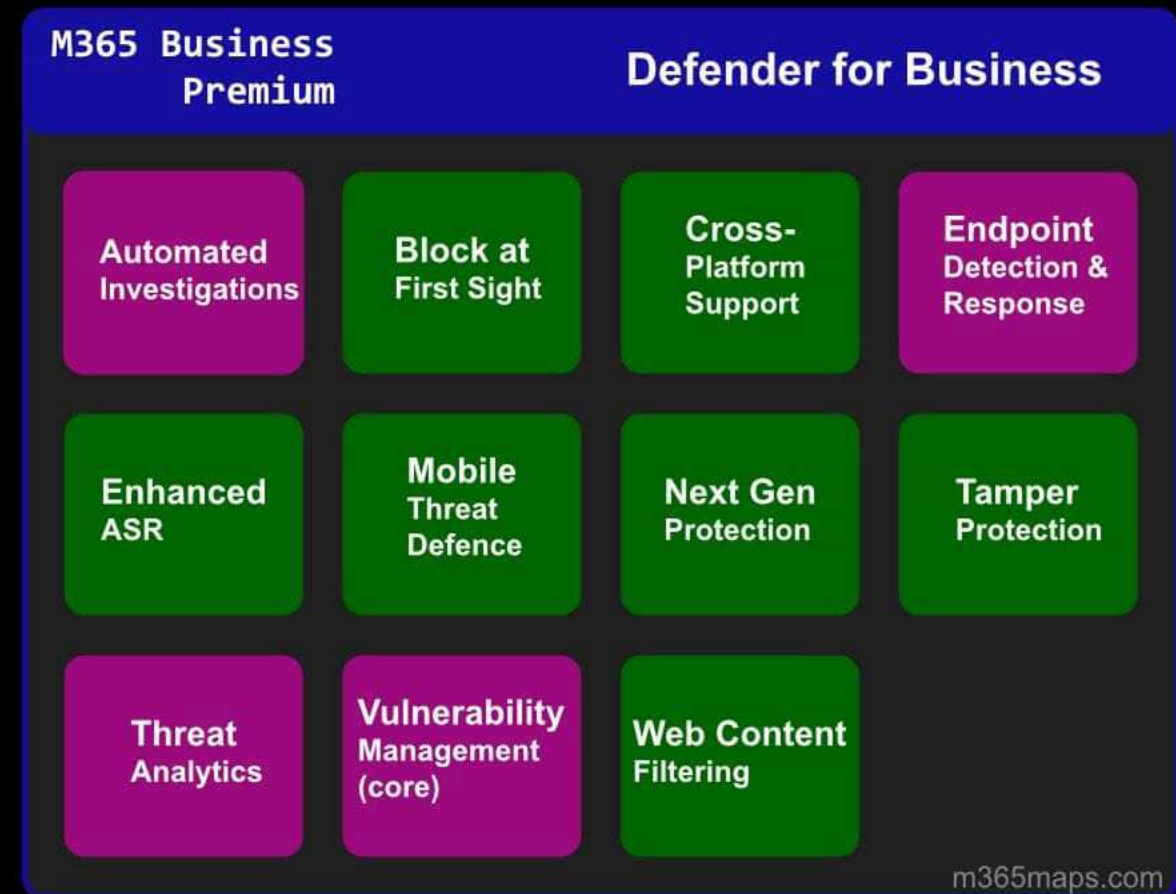
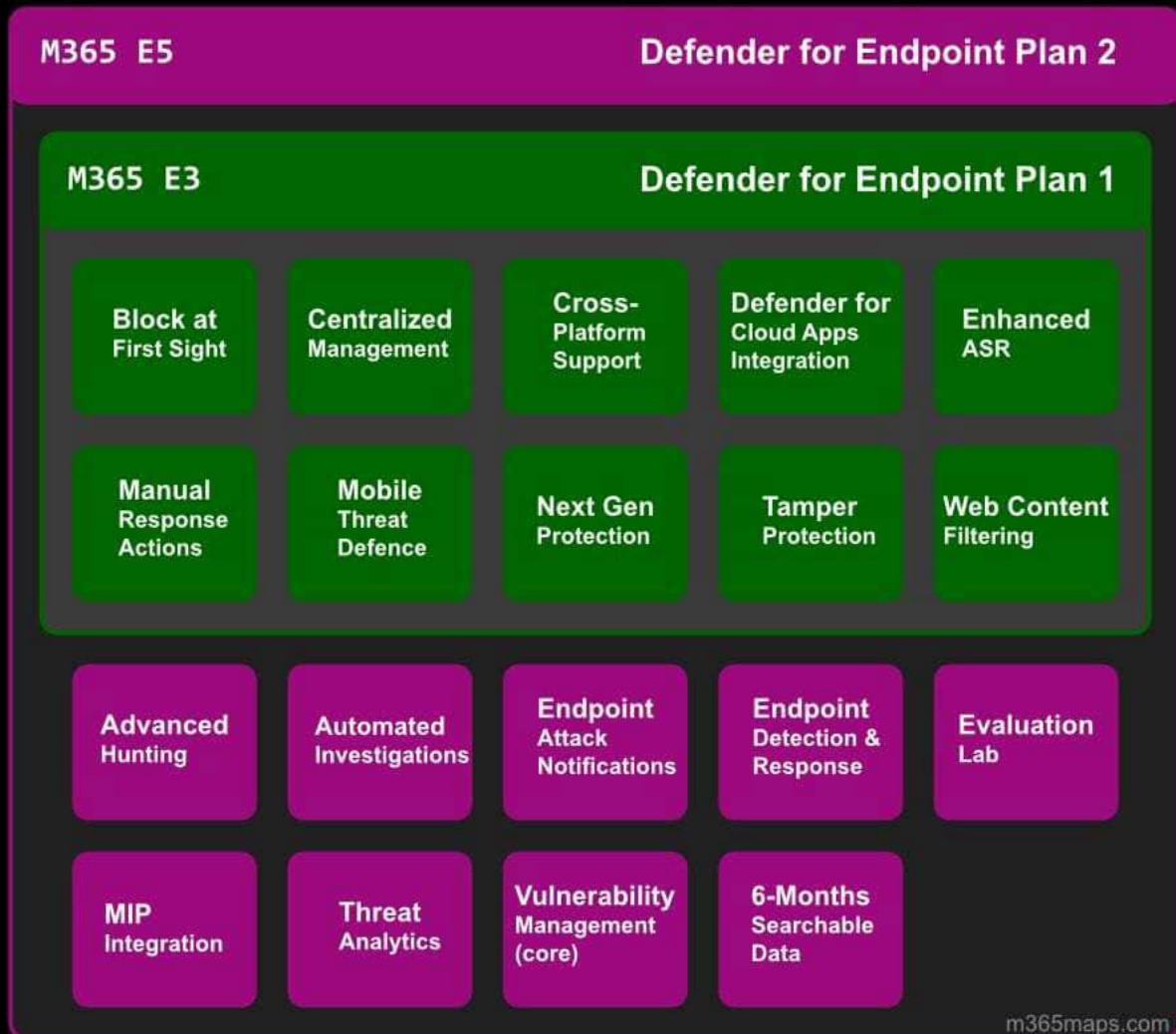
So, you picked Defender for Endpoint...

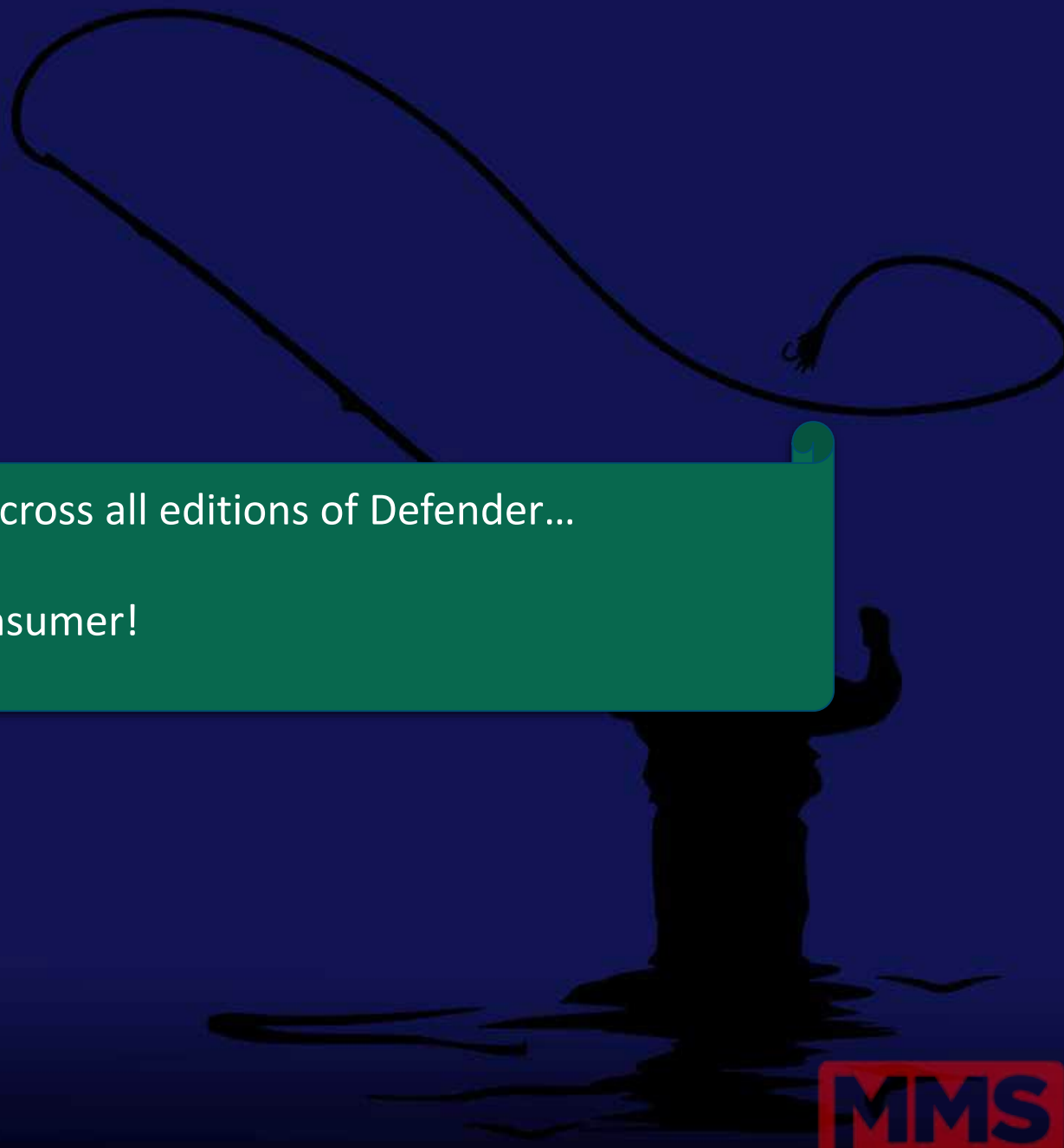


Timeline of MS Defender



Licensing and Protection Levels



A silhouette of a fisherman standing in water, holding a large fish that is curved into a loop. The background is a dark blue gradient.

The AV protection is **the same** across all editions of Defender...

Even consumer!

AV is a safety net, not your first-line



AV / EDR
Agent



OS
Patching



3rd Party
Patching



Endpoint Security
Baseline



Application
Control

Three areas to consider

1. Security Portal: General product behaviour and investigation
2. Local Settings: What are my scan times and firewall settings etc.?
3. Onboard: Send that data, get protected



Microsoft Security Portal - Settings Reference

Setting Name	Setting Value
Enable EDR in Block Mode	ON (requires P2)
Allow or block file	ON
Hide potential duplicate device records	ON
Custom network indicators	ON
Tamper Protection	ON
Skype for business integration	ON
Microsoft Defender for Cloud Apps	OFF
Web content filtering	ON
Unified audit log	ON

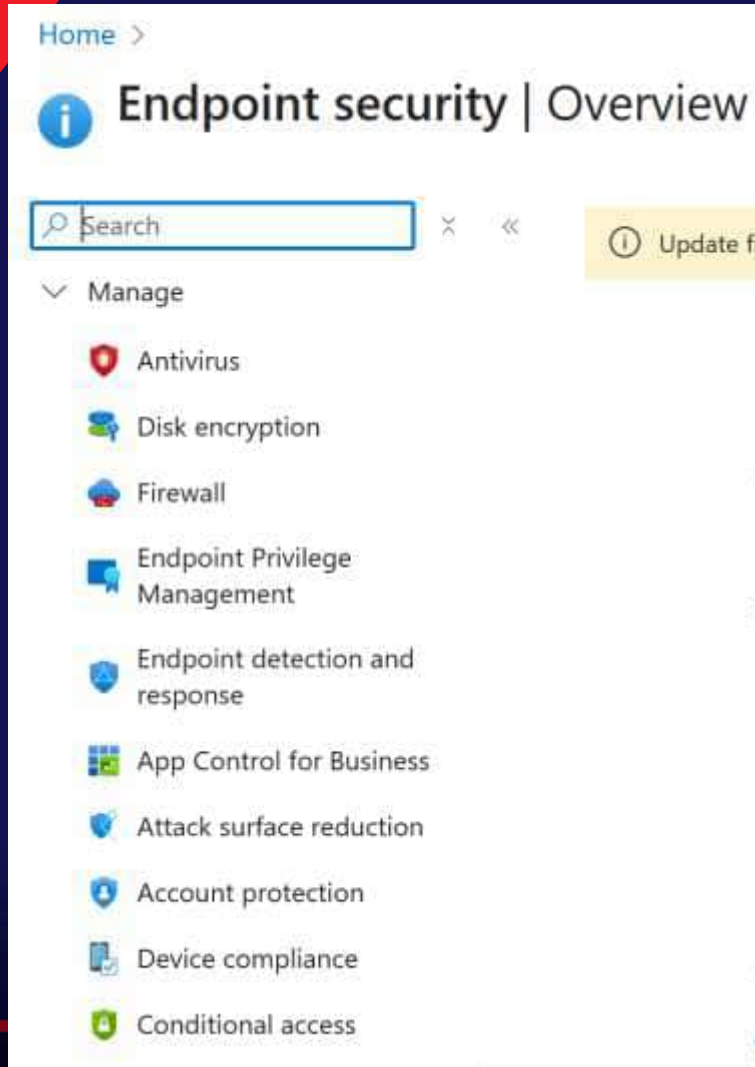
Setting Name	Setting Value
Device discovery	ON
Default to streamlined connectivity when onboarding devices in Defender portal	ON
Apply streamlined connectivity settings to devices managed by Intune and Defender for Cloud	ON
Live Response	OFF
Live Response for Servers	N/A
Live Response unsigned script execution	OFF
Share endpoint alerts with Microsoft Compliance Center	OFF
Microsoft Intune connection	ON
Authenticated telemetry	ON
Preview features	OFF

What is “Passive Mode”?

- Two components of Defender exist; AV & EDR
 - ♦ MsMPEng.exe & SenseIR.exe
- The AV component of Defender is in a disabled state
- Only if “EDR in Block Mode” is enabled will Defender kick in if the 3rd party primary AV misses something



Local Agent Settings



1. Antivirus
2. Firewall
3. Attack Surface Reduction

Endpoint Detection & Response is how we did onboarding.

Attack Surface Reduction



- ◆ Reducing the number of ways your endpoints can be exploited
- ◆ “ASR” is a name of a group of features
 - ◆ Not to be confused entirely with ASR Rules
 - ◆ Contains things like Device Control & Controlled Folder Access

ASR rule name:

Block abuse of exploited vulnerable signed drivers

Block Adobe Reader from creating child processes

Block all Office applications from creating child processes

Block credential stealing from the Windows local security authority subsystem (lsass.exe)

Block executable content from email client and webmail

Block executable files from running unless they meet a prevalence, age, or trusted list criterion

Block execution of potentially obfuscated scripts

Block JavaScript or VBScript from launching downloaded executable content

Block Office applications from creating executable content

Block Office applications from injecting code into other processes

Block Office communication application from creating child processes

Block persistence through WMI event subscription

Block process creations originating from PSExec and WMI commands

Block rebooting machine in Safe Mode

Block untrusted and unsigned processes that run from USB

Block use of copied or impersonated system tools

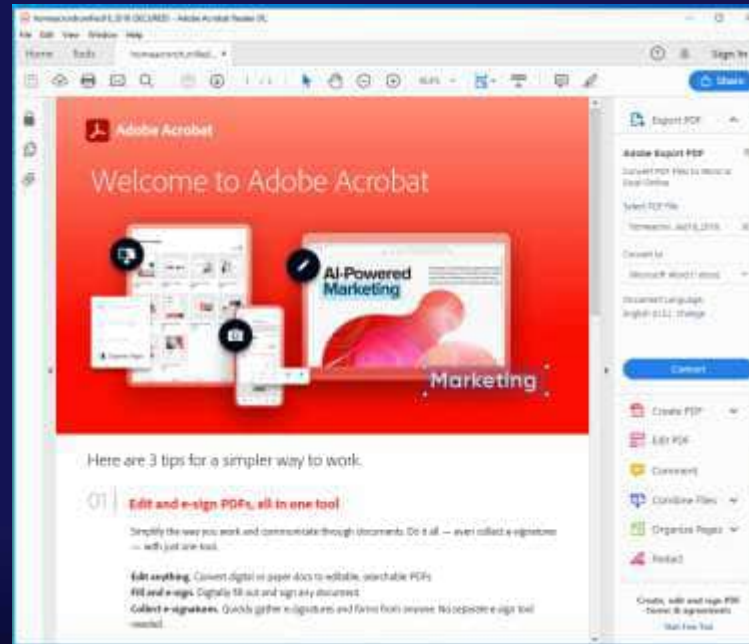
Block Webshell creation for Servers

Block Win32 API calls from Office macros

Use advanced protection against ransomware

Attack Surface Reduction Rules

Block Adobe Reader from creating child processes



ASR Rule



REMOTE_ACCESS.exe



Exclusion Guidance

Path to exclude	Pros	Cons
%userprofile%	Doesn't do what you think	Doesn't do what you think
C:*	Defender CPU usage very low	You'll get hacked
%ExchangeInstallPath%	Microsoft told me to	Microsoft told me to

- ◆ Generally speaking... process > file > folder > extension
- ◆ Contextual exclusions are cool

```
E:\Documents\TheBigOne.sql\:{Process:"C:\Program Files*\MyERPfrom1993\ERP.exe"}
```

The bottom line

- ◆ Don't bring all your exclusions across from AVSoftwareX...

Exclusions create gaps

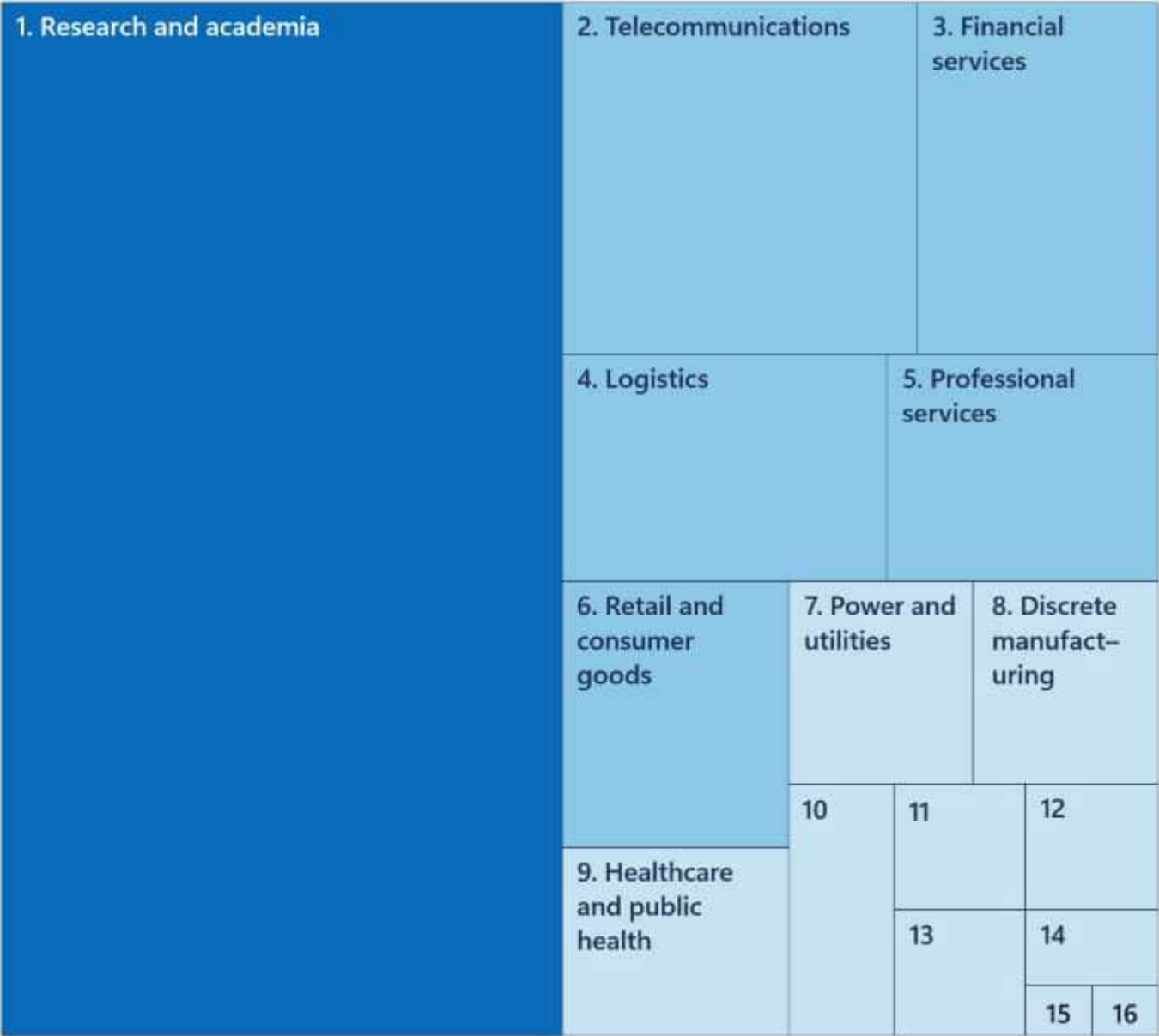
Section 4: Defender for Office

A criminally underrated email protection tool



HOT STATS

Business email compromise by sector (January-June 2025)

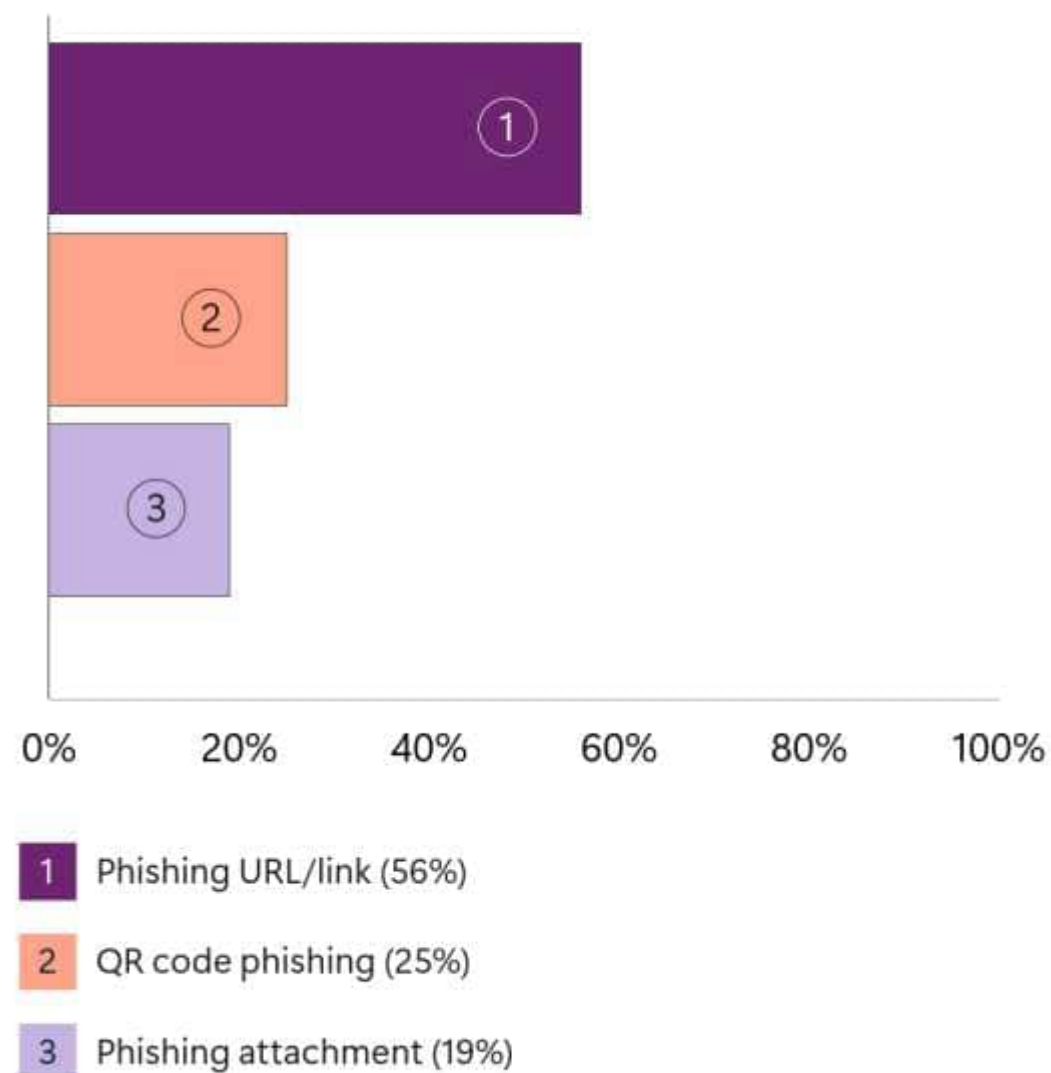


1	Research and academia	49%
2	Telecommunications	11%
3	Financial services	7%
4	Logistics	6%
5	Professional services	5%
6	Retail and consumer goods	5%
7	Power and utilities	4%
8	Discrete manufacturing	3%
9	Healthcare and public health	3%
10	Hospitality and travel	2%
11	Insurance	2%
12	Nonprofit	2%
13	Government	1%
14	Manufacturing	1%
15	Agriculture, forestry, and fishing	0.3%
16	Public safety	0.2%

775 million
email messages contained malware
(July 2023-June 2024)

Source: Microsoft Defender for Office 365

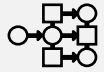
Top email phishing types



Source: Microsoft Defender Threat Experts notifications

Multi-layered protection stack

Edge protection



Network throttling



IP reputation/throttling



Domain reputation



Directory-based edge filtering



Backscatter detection



Enhanced filtering for on-premises routing

Sender intelligence



Account compromise detection



DMARC DKIM, SPF, ARC



Intra-org spoof intelligence



Cross-domain spoof intelligence



Bulk filtering



Brand impersonation



Mailbox intelligence



Mailbox intelligence impersonation*



User impersonation*



Domain impersonation*

Content filtering



Transport custom rules



AV engines



Type blocking



Attachment reputation blocking



Heuristic clustering



ML models**



Tenant allow/block lists



URL reputation blocking



Safe attachments*



Linked content detonation*



URL detonation*



Content heuristics



QR code clustering



OCR



Micro-sandboxing

Post-delivery protection



Safe links*



Phish zero-hour auto-purge



Malware zero-hour auto-purge



User contextual tips



Spam zero-hour auto-purge



Campaigns**



End-user reporting



Office clients*



OneDrive/SharePoint*



URL detonation*



Investigations, hunting and remediation*

Increasing intelligence

*Components unique to Microsoft Defender for Office 365

** Enhanced/additional items unique to Microsoft Defender for Office 365

The basics: SPF/DKIM/DMARC



DNS Records

“It’s always DNS”

- DNS is the public identifier for most things your company does
- It’s where web traffic goes
- Where emails get directions
- It’s part of how people log into most services

It is really important that access to the DNS management is secure.

Maybe don’t give web developers access to it either... 😊

SPF – Sender Policy Framework

- ◆ This dictates who has permission to send email on behalf of your domain

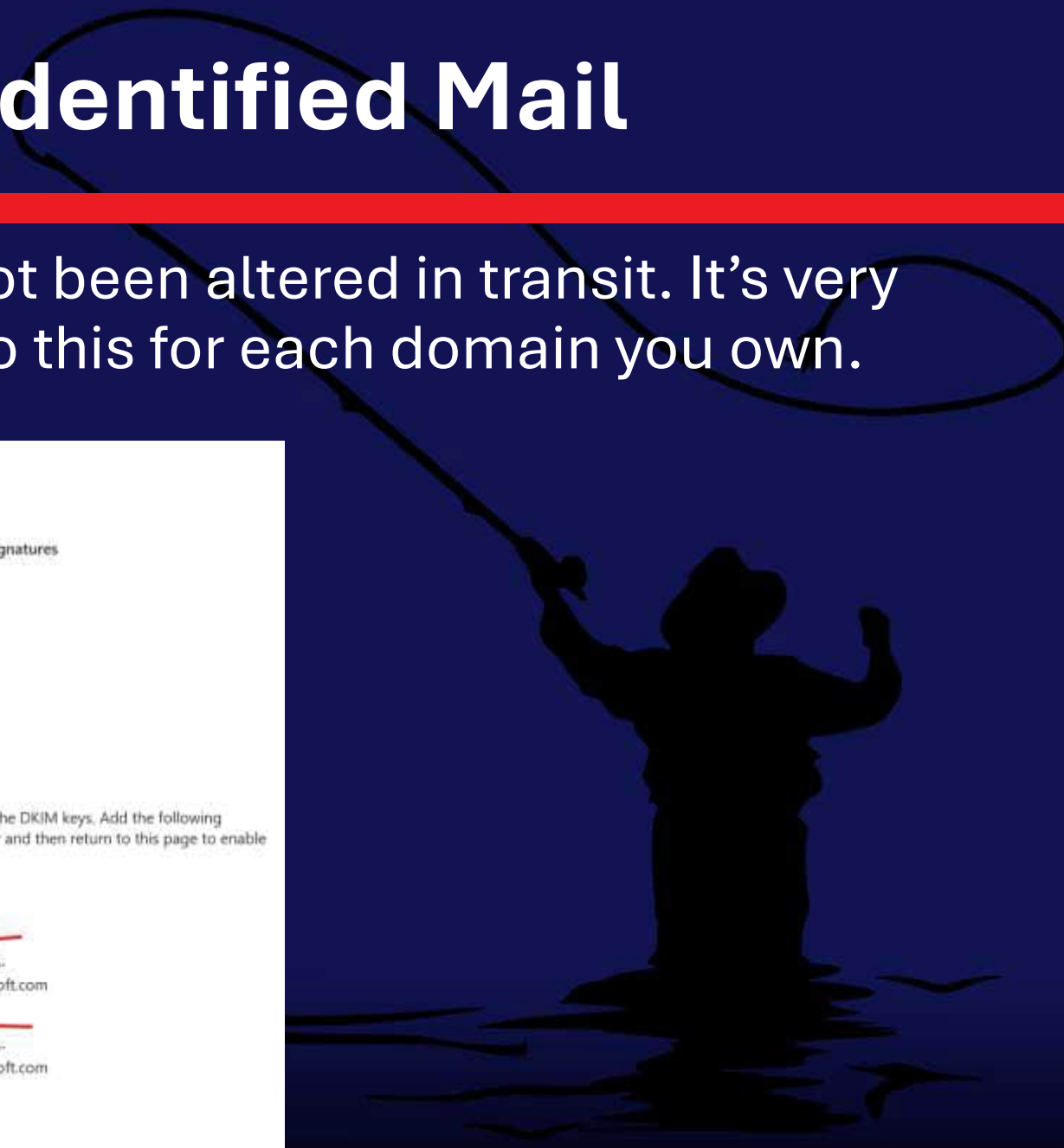
This is what the default SPF record should look like when you only send mail from Exchange Online:

```
v=spf1  
include:spf.protection.outlook.com -all
```

If you have other services like MailChimp, Hubspot, or a PSA tool, you will need to add them to your record. If you don't, your email very likely ends up in recipient junk.

DKIM - DomainKeys Identified Mail

- ◆ DKIM verifies that an email has not been altered in transit. It's very easy to enable with no impact. Do this for each domain you own.



lb365.co.uk

Sign messages for this domain with DKIM signatures
☒ Enabled

Status
Signing DKIM signatures for this domain.

Last checked date
4 Apr 2024 11:33:53

Publish CNAMEs

It might take several minutes to synchronize the DKIM keys. Add the following CNAME records at your DNS hosting provider and then return to this page to enable DKIM.

[Learn more about DKIM](#)

Host Name : selector1._domainkey →
Points to address or value: selector1-lb365-co-uk._domainkey.conditionalaccessuk.onmicrosoft.com

Host Name : selector2._domainkey →
Points to address or value: selector2-lb365-co-uk._domainkey.conditionalaccessuk.onmicrosoft.com

[Copy](#)

DMARC - Domain-based Message Authentication, Reporting and Conformance

- ♦ DMARC is a critical configuration to prevent people from spoofing emails from your domain. If you care about doing your bit for preventing global spam, get this one done.

Example:

```
v=DMARC1; p=reject; rua=mailto:3fc936581c31.a@dmarcinput.com;  
ruf=mailto:3fc936581c31.f@dmarcinput.com; sp=none; fo=1
```

P can equal:

1. None
2. Quarantine
3. Reject

Advanced Tip 1 – add DMARC to your .onmicrosoft.com domain!

- ♦ Attackers can try to spoof your root domain.

DEMO

Advanced Tip 2 – Block invites from *.onmicrosoft.com

- ♦ Attackers can use official Microsoft invites, then embed their phish info.

Hackers Leverages Microsoft Entra Tenant Invitations to Launch TOAD Attacks



Advanced Tip 2 – Block invites from *.onmicrosoft.com

The screenshot shows a search results page in Microsoft 365. The search bar at the top contains the query 'from:invites@microsoft.com'. Below the search bar, there are several refiners: 'Read', 'Mentions me', 'Flagged', 'High importance', 'To me', and 'Close search'. The results are displayed in a table with columns 'From', 'Subject', and 'Received'. The first result is from 'Microsoft Invitations on behalf of The McNulty's' with the subject 'Nathan McNulty invited you to access applications within their organization' and received on '2025-09-29'. The second result is from 'Microsoft Invitations on behalf of sky made simple' with the subject 'Jonas Bøgvad invited you to access applications within their organization' and received on '2024-05-20'.

← from:invites@microsoft.com

Refiners: Read, Mentions me, Flagged, High importance, To me, Close search

Search Tools

Results

From	Subject	Received
> Microsoft Invitations on behalf of The McNulty's	Nathan McNulty invited you to access applications within their organization Y	Inbox 2025-09-29
> Microsoft Invitations on behalf of sky made simple	Jonas Bøgvad invited you to access applications within their organization Y...	Inbox 2024-05-20

Jonas Bøgvad invited you to access applications within their organization



Microsoft Invitations on behalf of sky made simple<invites@microsoft.com>

To:  Lewis Barry

You don't often get email from invites@microsoft.com. [Learn why this is important](#)

 Please only act on this email if you trust the individual and organization represented below. In rare cases, individuals may receive fraudulent invitations from bad actors posing as legitimate companies. If you were not expecting this invitation, proceed with caution.

Sender: Jonas Bøgvad (Jb@skymadesimple.io)
Organization: sky made simple
Domain: skymadesimple.io

If you accept this invitation, you'll be sent to

[43](#)

[Accept invitation](#)

[Block future invitations](#) from this organization.

This invitation email is from sky made simple (skymadesimple.io) and may include advertising content. sky made simple has not provided a link to their privacy statement for you to review. Microsoft Corporation facilitated sending this email but did not validate the sender or the message.

Microsoft respects your privacy. To learn more, please read the [Microsoft Privacy Statement](#).
Microsoft Corporation, One Microsoft Way, Redmond, WA 98052



MMS

Advanced Tip 2 – Block invites from *.onmicrosoft.com

Block Invites from .onmicrosoft.com

[Edit rule conditions](#) [Edit rule settings](#)

Status: Disabled

Enable or disable rule
☐ Disabled

Rule settings

Rule name	Mode
Block Invites from .onmicrosoft.com	Audit
Severity	Set date range
Low	Specific date range is not set
Senders address	Priority
Matching HeaderOrEnvelope	1
For rule processing errors	
Ignore	

Rule description

Apply this rule if

*Is received from 'invites@microsoft.com'
and Includes these patterns in the message subject: 'Domain\'s+([A-Za-z0-9]+)\.onmicrosoft\.com'*

Do the following

*Set audit severity level to 'Low'
and reject the message and include the explanation 'Invite not permitted' with the status code: '5.7.1'
and Send the incident report to lewis@conditionalaccess.uk; include these message properties in the report: sender, recipients, subject*

Rule comments

[TLD-TABL-Block/README.md at main · jkerai1/TLD-TABL-Block · GitHub](#)

Configurations Reference

Policies



Anti-phishing



Anti-spam



Anti-malware



Safe Attachments



Safe Links

Anti-Phishing

Users, groups, and domains	
Included Recipient Domains	The domains you use in production
Phishing threshold & protection	
Phishing threshold	3- More Aggressive
User impersonation protection	On for VIPs
Domain impersonation protection	On for owned domains
Trusted impersonated senders and domains	Ideally off
Mailbox intelligence	On
Mailbox intelligence for impersonations	On
Actions	
If a message is detected as user impersonation	Quarantine the message
If a message is detected as domain impersonation	Quarantine the message
If a Mailbox Intelligence detects an impersonated user	Quarantine the message
If the message is detected as spoof and DMARC Policy is set as p=quarantine	Quarantine the message
If the message is detected as spoof and DMARC Policy is set as p=reject	Reject the message
If the message is detected as spoof by spoof intelligence	Move the message to Junk
First contact safety tip	On
User impersonation safety tip	On
Domain impersonation safety tip	On
Unusual characters safety tip	On
Unauthenticated senders symbol (?) for spoof	On
Show "via" tag	On
Honor DMARC record policy when the message is detected as spoof	On

Domain Impersonation Protection

- Will spot typo-squatted or matched sender addresses and send them to spam/quarantine
- Add custom domains to protect — these can be your own domains or ***domains that belong to partners or suppliers.***

User Impersonation Protection

- Requires manual setup — limited to 350 entries
- Will spot typo-squatted or matched sender addresses and send them to spam/quarantine
- Add finance users, senior leadership teams, and IT teams into this list

☒ **Enable domains to protect (1)**

Enable impersonation protection for these internal and external sender domains.

☒ Include domains I own ⓘ
[View my domains](#)

☐ Include custom domains ⓘ
[Manage 0 custom domain\(s\)](#)

Manage senders for impersonation protection

Add up to 350 internal and external senders to protect from being impersonated by attackers. We recommend adding people in key roles.
[Learn more about adding senders to protect](#)

 Add user

1 item



☐ Display name ▾	☐ Sender email address ▾
☐ Lewis Barry	lewis@conditionalaccess.uk

Impersonation Insight

Domains (0) **Users (7)**

Impersonation protection received strong signals that the following messages are suspicious. Based on our analysis, you need to review each impersonation attempt. If it's appropriate, you can add the senders as trusted senders in the impersonation settings in an anti-phishing policy.

Our Recommendation: Based on our analysis, your policy is configured appropriately - [view your impersonation policies](#).

↓ Export ↺ Refresh

☐ Sender	Message count	Impersonation type	Impersonated user(s)	User type	Policy	Allowed to impersonate
☐ notification@branchpoint.com	33	User in display name	[REDACTED]	Protected user	☐ AntiPhishing	No
☐ [REDACTED]	15	User in display name		Protected user	☐ AntiPhishing	No
☐ officialspac@branchpoint.com	2	User in display name		Protected user		No
☐ no-reply@branchpoint.com	2	User in display name		Protected user	☐ AntiPhishing	No
☐ jincyates9@branchpoint.com	2	User in display name		Protected user		No
☐ branchoffice@branchpoint.com	2	User in display name		Protected user		No
☐ privatechat@branchpoint.com	1	User in display name		Protected user	☐ AntiPhishing	No
☐ giftmail819@branchpoint.com	1	User in display name		Protected user	☐ AntiPhishing	No
☐ henainneh@branchpoint.com	1	User in display name		Protected user		No
☐ branchoffice@branchpoint.com	1	User in display name		Protected user		No

Anti-spam

Inbound

Bulk email threshold & spam properties	
Bulk email threshold	6
URL to .biz or .info websites	Off [1]
Image links to remote sites	Off
URL Redirect to other port	Off
Empty Messages	Off
JavaScript or VBScript in HTML	Off
Object tags in HTML	Off
Frame or iframe tags in HTML	Off
Embedded tags in HTML	Off
Form tags in HTML	Off
Web bugs in HTML	Off
Sensitive words	Off
SPF record: hard fail	On
Conditional Sender ID filtering: hard fail	Off
Backscatter	Off
Test mode action	None
International spam – languages	Off
International spam – regions	Off
Actions	
Spam message action	Move message to Junk Email folder
High confidence spam message action	Quarantine message
Phishing message action	Move message to Junk Email folder
High confidence phishing message action	Quarantine message
Apply the following quarantine policy:	Contoso Admin Release
Bulk message action	Move message to Junk Email folder
Intra-Organizational messages to take action on	Default
Enable spam safety tips	On
Enable for spam messages	On
Enable for phishing messages	On
Retain spam in quarantine for this many days	30
Allowed and blocked senders and domains	
Allowed senders	[See TABL]
Blocked senders	
Allowed domains	
Blocked domains	

[1] Use TABL instead

Bulk-Email

Spam threshold and properties

Bulk email threshold ⓘ

💡 23 messages identified as bulk at the current BCL threshold of 6 in the last 60 days. [View bulk senders insight](#)

 6

A higher bulk email threshold means more bulk email will be delivered

Bulk complaint level (BCL)	All email	Delivered at current BCL threshold
1	0	0
2	455	455
3	66	66
4	30	30
5	6	6
6	15	0
7	8	0
8	0	0
9	0	0

Email delivered at current BCL threshold.

557

Email identified at current BCL threshold.

23

Bulk senders insight

💡 This insight contains data from the last 60 days. Don't try to compare or reconcile this data with data from other reports. [Learn more](#)

A higher bulk email threshold means more bulk email will be delivered

Current bulk email threshold

 6

New bulk email threshold ⓘ

 6

Simulation sender quality threshold ⓘ

 50

Simulate

	Bulk complaint level (BCL) All email	Delivered at current BCL threshold	Delivered at new BCL threshold	
1	0	0	0	Email delivered at current BCL threshold. 557
2	455	455	455	Email identified at current BCL threshold. 23
3	66	66	66	Email delivered at new BCL threshold. 557
4	30	30	30	Email identified at new BCL threshold. 23
5	6	6	6	
6	15	0	0	
7	8	0	0	
8	0	0	0	
9	0	0	0	

Export All senders

2 items Search

Sender	BCL	Simulation sender quality threshold	Potential false positive	Potential false negative
☐ resources@cventevents.com	5	0	False	True
☐ notifications@erpNext.com	4	0	False	True

Anti-spam

Outbound

Protection Settings	
Restrict sending to external recipients (per hour)	0
Restrict sending to internal recipients (per hour)	0
Maximum recipient limit per day	0
Over limit action	Restrict the user from sending mail until the following day
Automatic Forwarding	Automatic – System-controlled
Send a copy of suspicious outbound messages or message that exceed these limits to these users and groups	Off
Notify these users and groups if a sender is blocked due to sending outbound spam	Off

Anti-Malware

Protection Settings	
Enable the common attachments filter	On
Customize file types	Ensure common archive files are added: .zip, .zipx, .rar, .7z, .tar, .gz, .bz2, .xz, .arj
When these file types are found	Reject the message with a non-delivery receipt (NDR)
Enable zero-hour auto purge for malware	On
Notify an admin about undelivered messages from internal senders	
Notify an admin about undelivered messages from external senders	
Customize notifications	
Quarantine policy	Contoso Admin Release

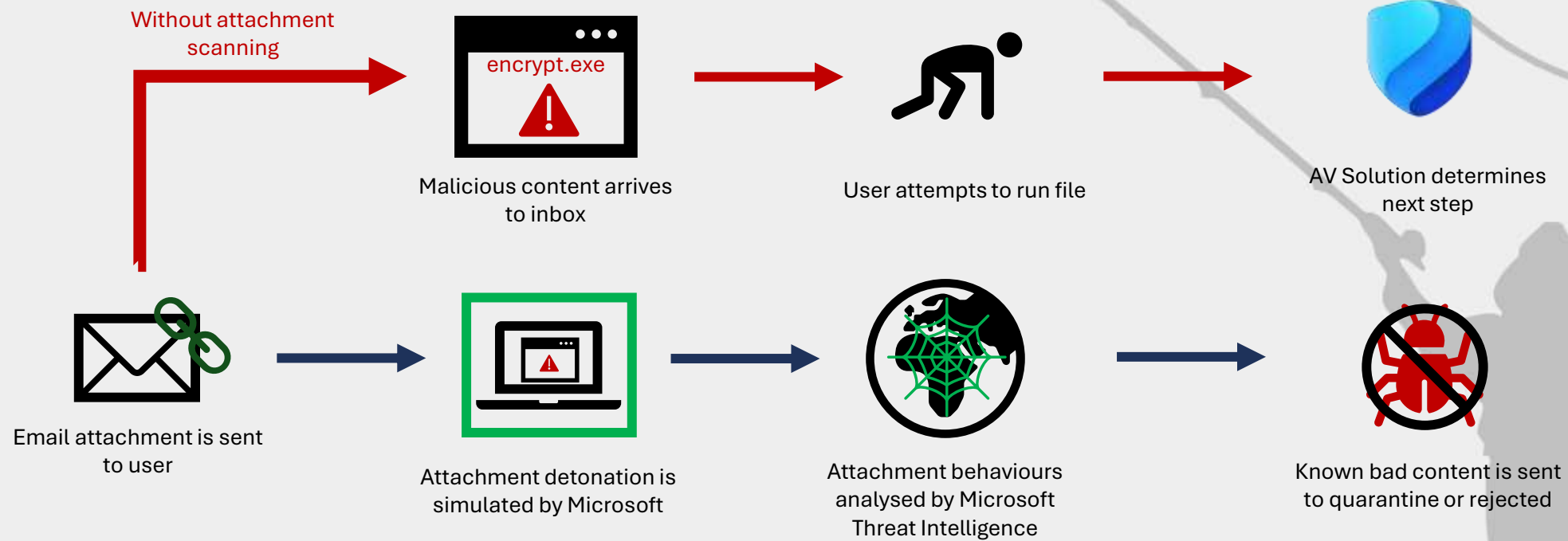
Safe Attachments

Users and Domains	
Included recipient domains	Domains used in production
Settings	
Safe attachments detection response	Block
Redirect attachments	Disabled
Quarantine Policy	Contoso Admin Release

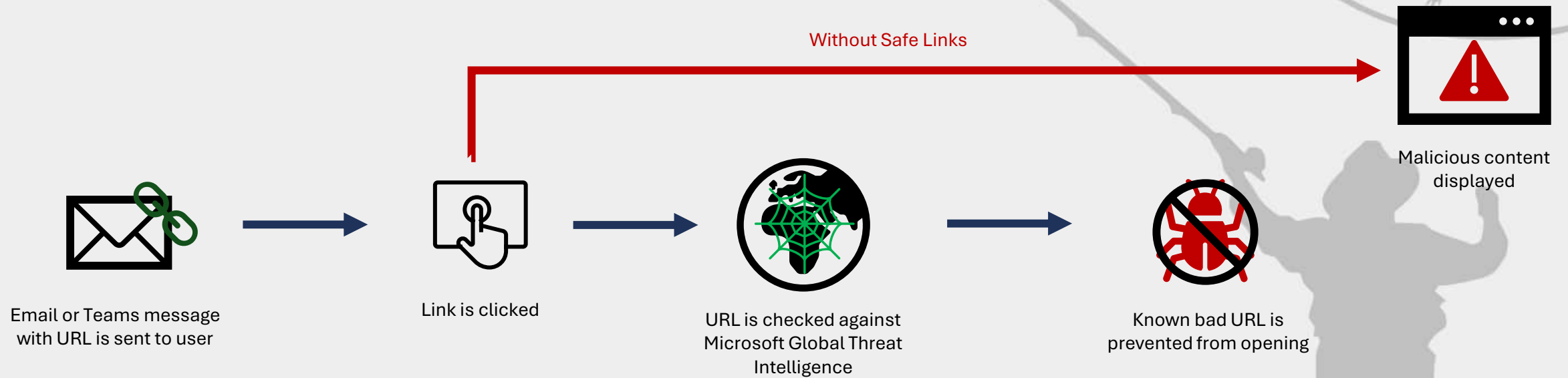
Safe Links

Users and Domains	
Included recipient domains	Domains used in production
Protection Settings	
Email	On
Apply Safe Links to email messages sent within the organisation	On
Apply real-time URL scanning for suspicious links and links that point to files	On
Wait for URL scanning to complete before delivering the message	On
Do not rewrite URLs, do checks via Safe Links API only.	Off
Do not rewrite the following URLs in email (0)	Blank
Teams	On
Office 365 Apps	On
User Clicks	
Track user clicks	On
Let users click through to the original URL	Off
Display the organization branding on notification and warning pages	On
Notification Settings	
User custom notification text	Not Set

Safe Attachments



Safe Links

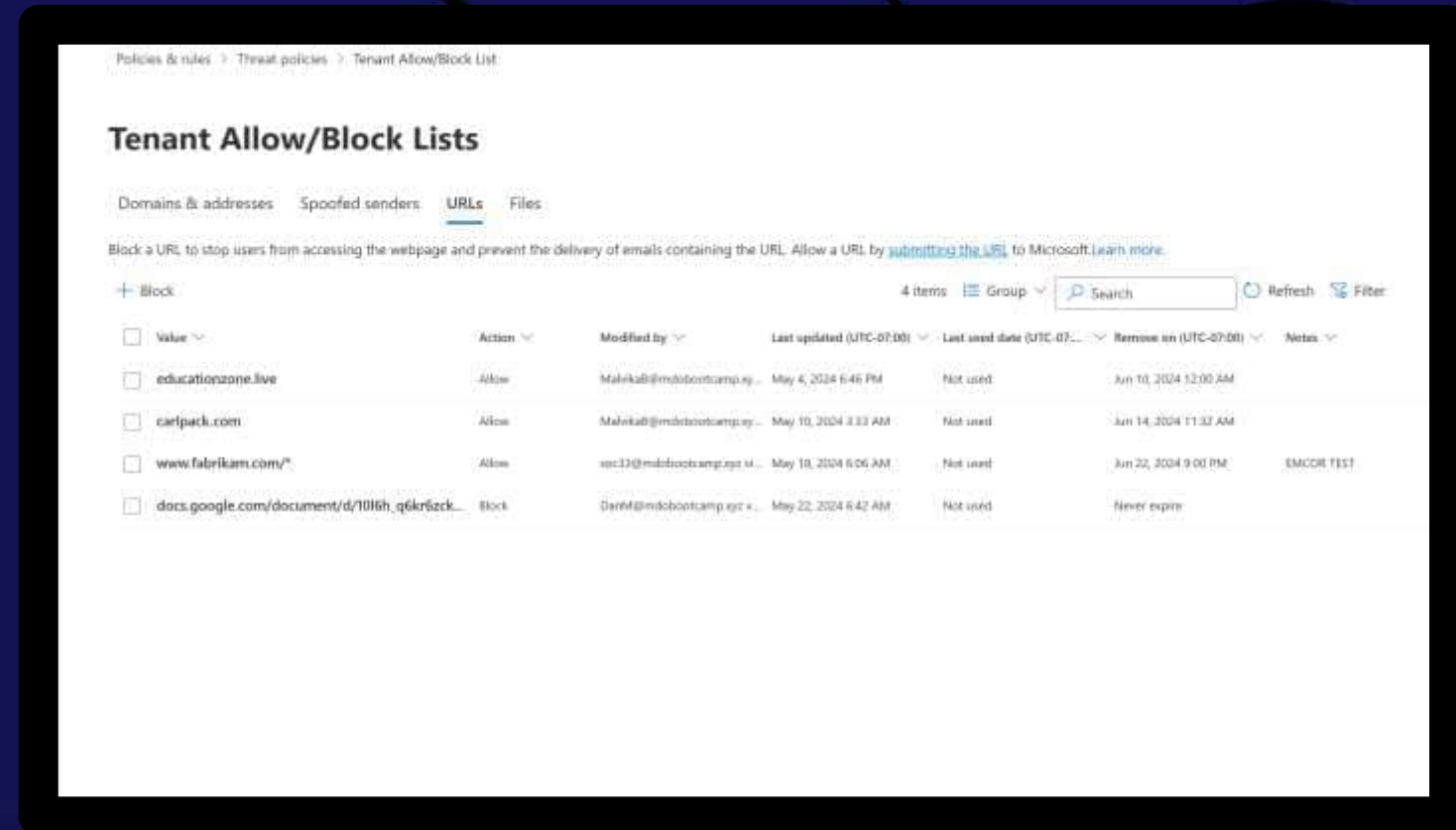


Advanced Techniques: Tenant Allow Block List (TABL)



Tenant Allow/Block Lists

- TABL: manually override domains, email address, spoofed senders, files and URLs from the tenant allow/block list
- This is extremely powerful when used correctly



TABL means business

- Blocked items are marked as high-confidence phish

- Block entries in the Tenant Allow/Block List:

 Expand table

Filtering stack verdict	Email address/domain	Spoof	File	URL
Malware	Filter wins: Email quarantined	Filter wins: Email quarantined	Organization wins: Email quarantined	Filter wins: Email quarantined
High confidence phishing	Organization wins: Email quarantined	Filter wins: Email quarantined	Organization wins: Email quarantined	Organization wins: Email quarantined
Phishing	Organization wins: Email quarantined	Organization wins: Spoof action in the applicable anti-phishing policy	Organization wins: Email quarantined	Organization wins: Email quarantined
High confidence spam	Organization wins: Email quarantined	Organization wins: Spoof action in the applicable anti-phishing policy	Organization wins: Email quarantined	Organization wins: Email quarantined
Spam	Organization wins: Email quarantined	Organization wins: Spoof action in the applicable anti-phishing policy	Organization wins: Email quarantined	Organization wins: Email quarantined
Bulk	Organization wins: Email quarantined	Organization wins: Spoof action in the applicable anti-phishing policy	Organization wins: Email quarantined	Organization wins: Email quarantined
Not spam	Organization wins: Email quarantined	Organization wins: Spoof action in the applicable anti-phishing policy	Organization wins: Email quarantined	Organization wins: Email quarantined

Blocking stuff seems like manual work.

Policies & rules > Threat policies > Tenant Allow/Block List

Tenant Allow/Block Lists

Domains & addresses Spoofed senders URLs Files IP addresses Teams domains

+ Add ▾

95 items

≡ Group ▾

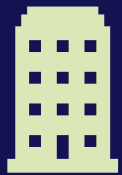
🔍 Search

🔄 Refresh

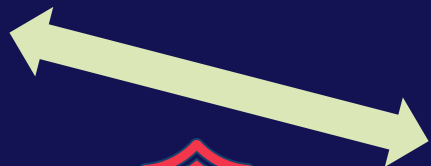
🔍 Filter

☐ Value ▾	Action ▾	Override verdicts ▾	Modified by ▾	Last updated (UTC) ▾	Last used date (UTC) ↑
☐ *.email	Block	Upto malware	ladmin@conditionalaccess.uk	16 Aug 2025 12:38	16 September 2025
☐ *.support	Block	Upto malware	ladmin@conditionalaccess.uk	16 Aug 2025 12:39	15 October 2025
☐ *.airforce	Block	Upto malware	ladmin@conditionalaccess.uk	16 Aug 2025 12:38	Not used
☐ *.am	Block	Upto malware	ladmin@conditionalaccess.uk	16 Aug 2025 12:38	Not used
☐ *.army	Block	Upto malware	ladmin@conditionalaccess.uk	16 Aug 2025 12:38	Not used
☐ *.autos	Block	Upto malware	ladmin@conditionalaccess.uk	16 Aug 2025 12:38	Not used
☐ *.ax	Block	Upto malware	ladmin@conditionalaccess.uk	16 Aug 2025 12:38	Not used

Minimising Risk



Contoso
Financial
Advisors



.com .uk .jp .org
.co.uk .fr .nl .gov
.ca .de .net

.xyz .ws .biz
.lol .ru .email
.zip .cn .top

PowerShell can help you import a block list

```
#Install-Module ExchangeOnlineManagement
Import-Module ExchangeOnlineManagement
Connect-ExchangeOnline

$BlockList = Invoke-WebRequest -URI 'https://raw.githubusercontent.com/jkerai1/TLD-TABL-Block/refs/heads/main/Abused%20TLDs.txt' | Select -expand Content
$exclusion = @('info','example')

foreach($line in $BlockList.Split([Environment]::NewLine)){
    # Trim whitespace and check if line is not empty, doesn't start with #, and isn't in exclusion list
    $trimmedLine = $line.Trim()

    if (-Not [string]::IsNullOrEmpty($trimmedLine) -and
        -Not $trimmedLine.StartsWith("#") -and
        ($exclusion -notcontains $trimmedLine)){

        Write-Host($trimmedLine)
        $TLD = "*" + $trimmedLine
        New-TenantAllowBlockListItems -ListType Sender -Block -Entries $TLD -NoExpiration -Notes "Blocked TLD https://github.com/jkerai1/TLD-TABL-Block/tree/main"
    }
}
```

[TLD-TABL-Block/InfoSecCA-TLDBlockScript.ps1 at main · jkerai1/TLD-TABL-Block · GitHub](https://github.com/jkerai1/TLD-TABL-Block/blob/main/InfoSecCA-TLDBlockScript.ps1)

How can I measure the impact BEFORE

Run query

Set in query

Save

Share link

Create summary rule

Create detection rule

Query

```
1 let AbusedTLDs = externaldata(TLD: string)[@"https://raw.githubusercontent.com/jkerai1/TLD-TABL-Block/refs/heads/main/LargerCombinedBadTLDs.txt"] with (format="csv", ignoreFirstRecord=false);
2 EmailEvents
3 | where Timestamp > ago(30d)
4 | where isnotempty(SenderFromAddress)
5 | extend SenderDomain = tostring(split(SenderFromAddress, "@")[1])
6 | extend SenderTLD = tostring(split(SenderDomain, ".")[-1])
7 | where SenderTLD in (AbusedTLDs)
8 | project Timestamp, SenderFromAddress, SenderDomain, SenderTLD, RecipientEmailAddress, DeliveryAction, DeliveryLocation
```

Getting started

Results

Query history

Export

Show empty columns

2 items

Search

00:01.277

Low

Chart type

Full screen

Filters:

Add filter

☐	Timestamp	SenderFromAddress	SenderDomain	SenderTLD	RecipientEmailAddress	DeliveryAction	DeliveryLocation
☐	> 4 Jan 2026 13:22:39	[REDACTED]ns.run.events	comms.run.events	events	lewis@conditionalaccess.uk	Blocked	Quarantine
☐	> 23 Dec 2025 16:39:08	[REDACTED]engage.affinity.studio	engage.affinity.studio	studio	lewis@conditionalaccess.uk	Blocked	Quarantine

KQL Queries – Utilising Blocklists

Sender address contains an abused TLD

- Matching the sender address

Mail contains URL from abused TLD

- Matching a URL within the email itself
- If email is released to end-user by request and the URL is clicked from Outlook, it will present a Defender warning page in Edge

TABL Block = Send messages to Quarantine

SharePoint Online



Prevent guests from sharing content they don't own

- ◆ Restrict guests from sharing files they haven't created
- ◆ Guests should never be content distribution vectors
- ◆ Set default permissions to prevent unnecessary sharing of sensitive content
- ◆ Use sharing policies to enforce this restriction consistently





Home

Sites

Active sites

Deleted sites

SharePoint Embedded

Policies

Sharing

Access control

Settings

Content services

Migration

Reports

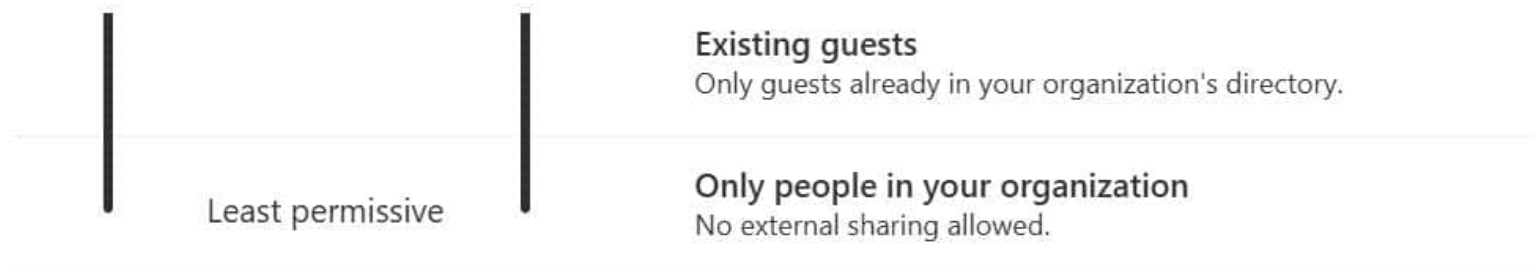
Advanced

More features

Sharing

Use these settings to control sharing at the organization level in SharePoint and OneDrive.

[Learn more about managing sharing settings](#)



You can further restrict sharing for each individual site and OneDrive. [Learn how](#)

More external sharing settings

- ☐ Limit external sharing by domain
- ☐ Allow only users in specific security groups to share externally
- ☐ Allow guests to share items they don't own

☒ Guest access to a site or OneDrive will expire automatically after this many days

☒ People who use a verification code must reauthenticate after this many days [Learn more](#)

Use 'specific people' as default sharing setting

- ◆ Set default sharing options to “specific people” rather than “anyone.”
- ◆ Prevent accidental data exposure by limiting sharing capabilities
- ◆ Ensure sharing is strictly controlled and monitored



Home



Sites

Active sites

Deleted sites



SharePoint Embedded



Policies



Sharing

Access control



Settings



Content services



Migration



Reports



Advanced



More features

Sharing

Use these settings to control sharing at the organization level in SharePoint and OneDrive.

[Learn more about managing sharing settings](#)

File and folder links

Choose the type of link that's selected by default when users share files and folders in SharePoint and OneDrive.

- ☒ Specific people (only the people the user specifies)
- ☐ Only people in your organization
- ☐ Anyone with the link

Choose the permission that's selected by default for sharing links.

- ☒ View
- ☐ Edit

Configure idle session sign-out on unmanaged devices

- ◆ Automatically sign out users after a period of inactivity on unmanaged devices
- ◆ Implement session timeouts to reduce risks from abandoned devices
- ◆ People walk away from unlocked laptops. This mitigates that.
- ◆ Notify users before signing them out to avoid disruptions

- Home
- Sites
 - Active sites
 - Deleted sites
- SharePoint Embedded
- Policies
- Sharing
 - Access control**
- Settings
- Content services
- Migration
- Reports
- Advanced
- More features

Access control

Use these settings to restrict how users are allowed to access your SharePoint content.

Unmanaged devices

Restrict access from devices that aren't compliant or managed by your organization.

Idle session sign-out

Automatically sign out users from inactive browser sessions.

Network location

Allow access only from specific IP addresses.

Apps that don't use modern authentication

Block access from Office 2010 and other apps that can't use modern authentication.

Idle session sign-out

Warn and then sign out users on unmanaged devices after a period of inactivity. This setting applies when users don't select to stay signed in.

[Learn more about signing out inactive users](#)

Sign out inactive users automatically

☒ On

Sign out users after:

30 minutes

Give users this much notice before signing them out:

5 minutes

Save



Use step-up authentication for SharePoint sites

- ◆ **Recommendation:** Use authentication context for step-up authentication on sensitive sites
- ◆ For particularly sensitive sites, you can use step-up authentication with authentication context to enforce Conditional Access at a site level. For example, you may allow general BYOD access on SharePoint, but specific sites require a compliant device.

Where to find it:

Microsoft Entra admin centre > Protection > Conditional Access > Authentication context > Create new context (e.g., "Require compliant device") > Create Conditional Access policy targeting that context with required controls
SharePoint admin centre > Active sites > Select site > Policies tab > Edit > Authentication context > Select the context created > Save.

OR

Use the following script

```
PS C:\Windows\System32> connect-SPOService -Url https://[redacted]-admin.sharepoint.com/  
PS C:\Windows\System32> Set-SPOSite -Identity https://[redacted].sharepoint.com/sites/HR -ConditionalAccessPolicy AuthenticationContext  
-AuthenticationContextName "Sensitive SharePoint location"  
PS C:\Windows\System32>
```

Microsoft Teams



Block communication from Teams trial tenants

- ◆ Trial tenants are increasingly used for phishing. Block them.
- ◆ Prevent phishing attacks from trial tenants by blocking federated chat
- ◆ Keep trial tenants from contacting your users through Teams
- ◆ Set strict communication rules for external Teams interactions

Microsoft Teams admin center

Search

Dashboard

Add-on Licenses

Teams

Users

External collab...

Overview

Guest access

External access

B2B member access

Teams devices

Teams apps

Meetings

Messaging

People in my org can chat and have meetings with external users who have unmanaged Microsoft accounts

On

People in my org can join external meetings and receive new chats from users who have unmanaged Microsoft accounts.

People in my organization can communicate with accounts in trial Teams tenant

Off

Block specific users from communicating with people in my organization

On

+ Add a user

×

Remove

|

1 item

Blocked users

nealpatel@live.co.uk

People in my organization can communicate with users who are using custom applications built with Azure Communication Services

Off

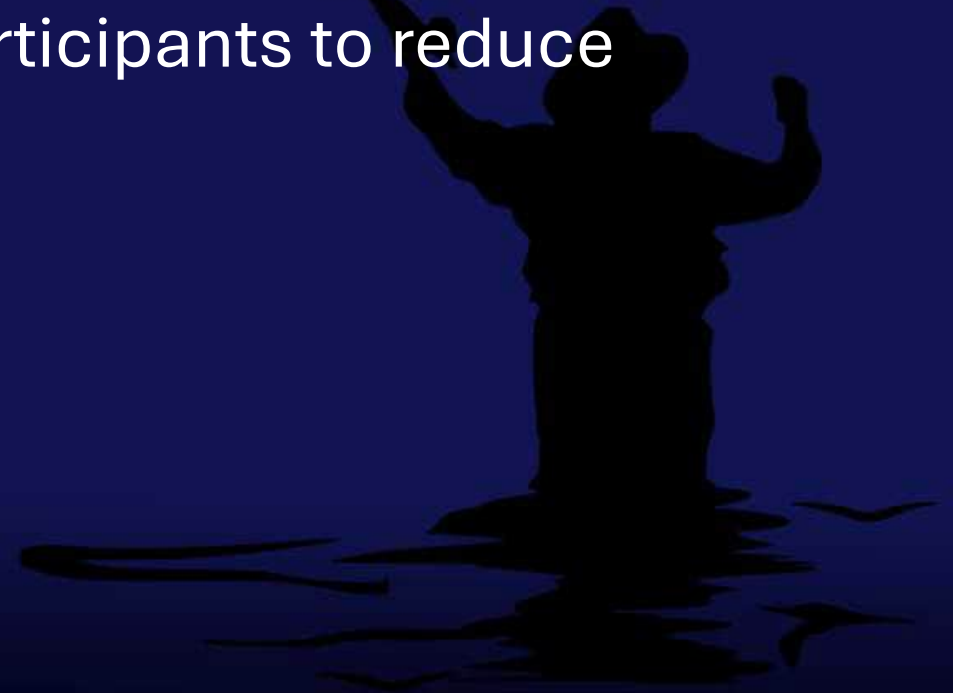
Allow my security team to manage blocked domains and blocked users

Off

Turning on this setting lets your security operations team edit the blocked domains and blocked users lists from Defender for Office 365.

Require CAPTCHA for anonymous meeting joiners

- ◆ Introduce CAPTCHA to block bots and malicious agents from joining meetings
- ◆ Strengthen security for anonymous users in online meetings
- ◆ Enforce CAPTCHA for all anonymous participants to reduce meeting risks



Microsoft Teams admin center

Search

Teams

Users

External collab...

Teams devices

Teams apps

Meetings

Audio Conferencing

Meeting policies

Customization policies

Meeting settings

Live events policies

Live events settings

Meeting templates

Meeting join & lobby

Meeting join and lobby settings let you control how people join meetings and allow you to manage the lobby for Teams meetings. [Learn more about meeting join and lobby settings](#)

Anonymous users can join a meeting unverified ⓘ

Find related settings at [Meetings > Meeting settings](#)

On

Anonymous users can join a meeting after verifying ⓘ

Premium

Find related settings at [External collaboration > External access](#)

By email code

Anonymous users and dial-in callers can start a meeting ⓘ

Off

Who can bypass the lobby ⓘ

People in my org and guests

Who can admit from the lobby ⓘ

Organizers, co-organizers, and presenters

People dialing in can bypass the lobby ⓘ

Off

Show meeting info on join screen ⓘ

Users allowed to by pass the lobby

People can join external meetings hosted by ⓘ

Anyone

Require a verification check from ⓘ

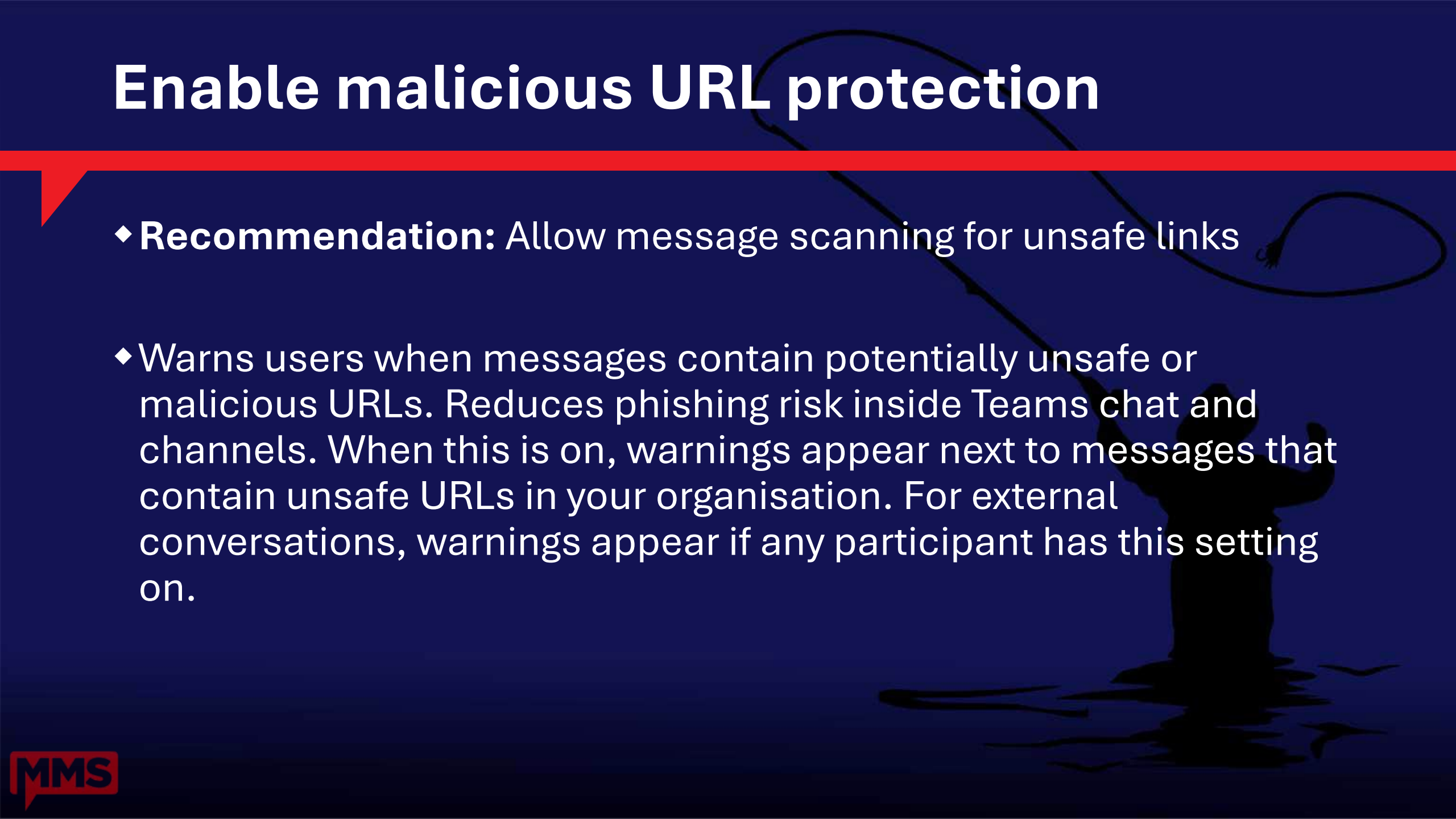
Anonymous users and people from untrusted organizations

Allow numeric-only meeting passcodes ⓘ

Off

The logo for MMS (Microsoft Management System) is located in the bottom right corner. It features the letters "MMS" in a bold, blue, sans-serif font, with a red speech bubble-like shape behind the letters.

Enable malicious URL protection

A background illustration of a fisherman in a dark blue suit standing in water, holding a large cod fish. The fish is curved upwards, and its head is near the top right of the frame. The fisherman is standing in the water, and his reflection is visible below him.

- ◆ **Recommendation:** Allow message scanning for unsafe links
- ◆ Warns users when messages contain potentially unsafe or malicious URLs. Reduces phishing risk inside Teams chat and channels. When this is on, warnings appear next to messages that contain unsafe URLs in your organisation. For external conversations, warnings appear if any participant has this setting on.

- ◆ **Where to find it:** Teams admin centre > Messaging settings > Messaging safety > Malicious URL protection (On)

Microsoft Teams admin center Search

Messaging safety

Control which chat and channel messaging safety features are available to users in your organization. [safety](#)

Weaponizable file protection ☒ On
When this is on, messages in your organization are scanned and blocked when they contain file types that aren't allowed. For external conversations, messages are scanned and blocked if any participant has this setting on. [Learn more about blocked file types in messages](#)

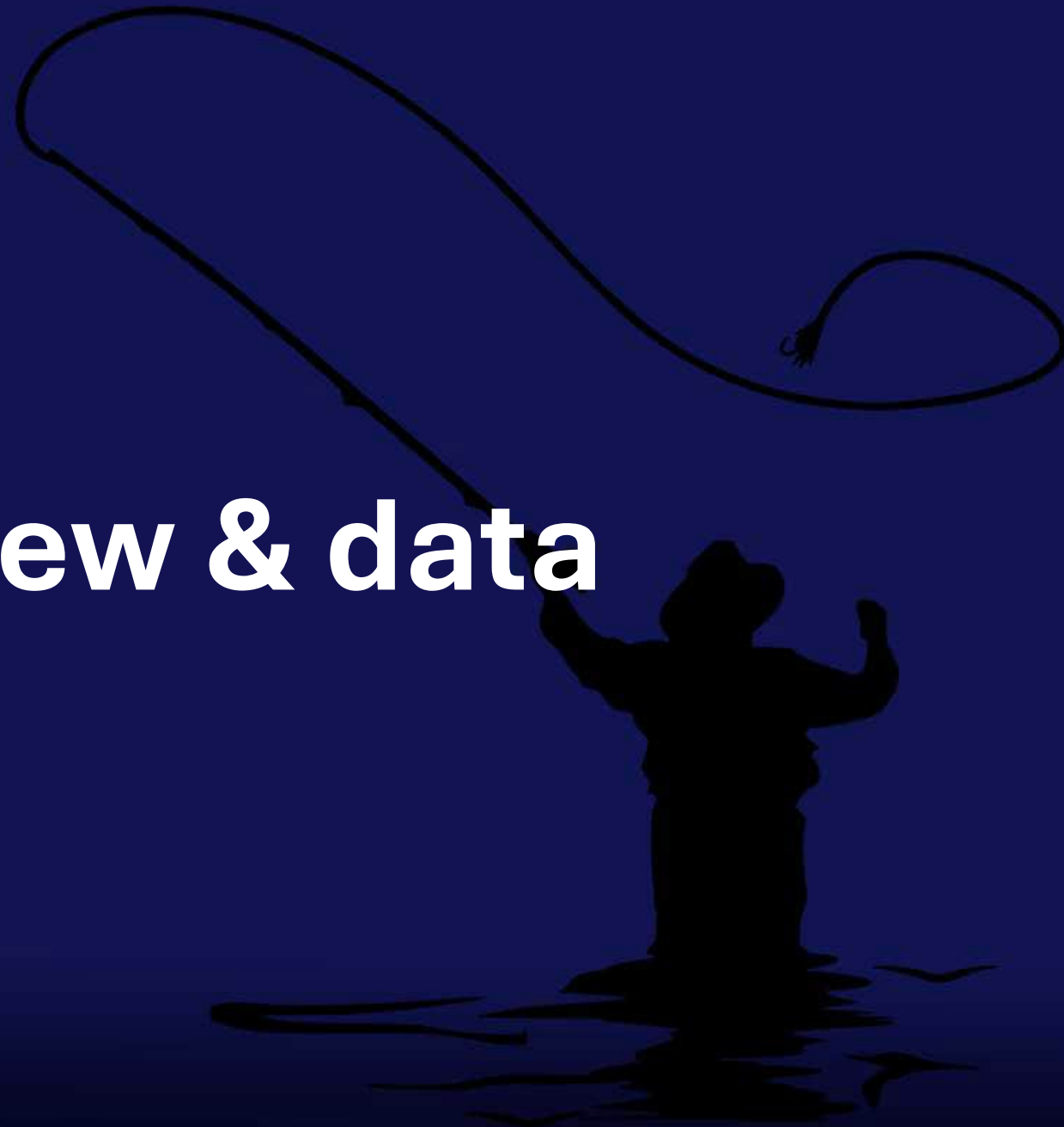
Malicious URL protection ☒ On
When this is on, warnings appear next to messages that contain unsafe URLs in your organization. For external conversations, warnings appear if any participant has this setting on. [Learn more about unsafe URLs in messages](#)

Report incorrect security detections ☒ On
When this is on, report incorrect security detections is enabled. [Learn more about report incorrect security detections in messages](#)

Left sidebar:

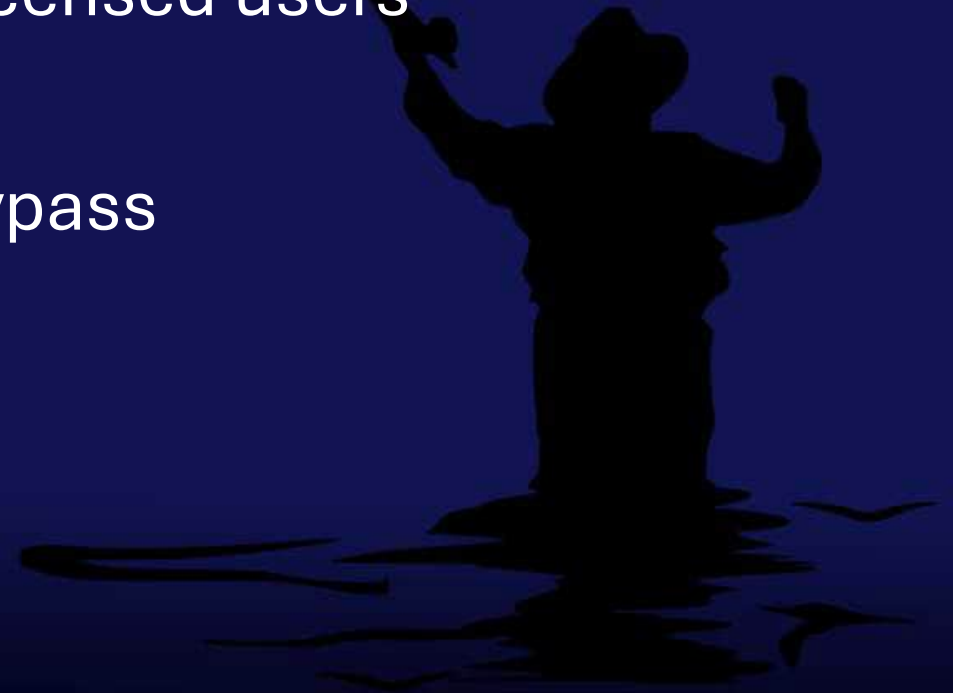
- Teams devices
- Teams apps
- Meetings
- Messaging
- Messaging policies
- Messaging settings**
- Voice
- Teams client health
- Locations
- Frontline

Microsoft Purview & data security

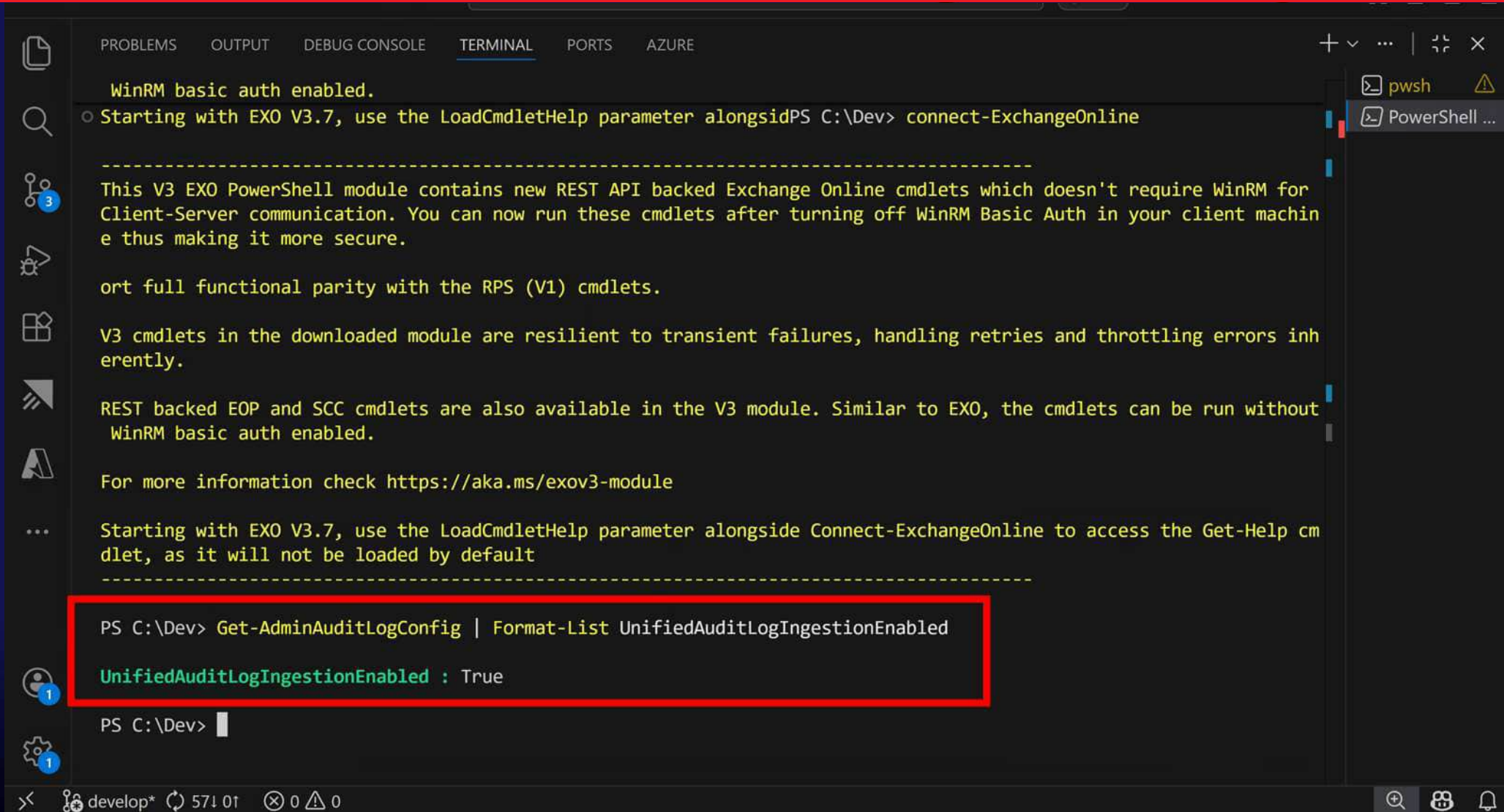


Microsoft Purview Audit enablement

- ◆ Ensure Purview Audit logging is enabled
- ◆ Ensure SearchQueryInitiatedExchange and SearchQueryInitiatedSharePoint are enabled for logging
- ◆ Ensure Audit (Premium) is enabled for licensed users
- ◆ Ensure mailbox auditing is enabled
- ◆ Control and monitor mailbox auditing bypass
- ◆ Set up a policy for audit log retention



Ensure Purview Audit logging is enabled



```
WinRM basic auth enabled.
Starting with EXO V3.7, use the LoadCmdletHelp parameter alongside PS C:\Dev> connect-ExchangeOnline

-----
This V3 EXO PowerShell module contains new REST API backed Exchange Online cmdlets which doesn't require WinRM for Client-Server communication. You can now run these cmdlets after turning off WinRM Basic Auth in your client machine thus making it more secure.

Port full functional parity with the RPS (V1) cmdlets.

V3 cmdlets in the downloaded module are resilient to transient failures, handling retries and throttling errors inherently.

REST backed EOP and SCC cmdlets are also available in the V3 module. Similar to EXO, the cmdlets can be run without WinRM basic auth enabled.

For more information check https://aka.ms/exov3-module

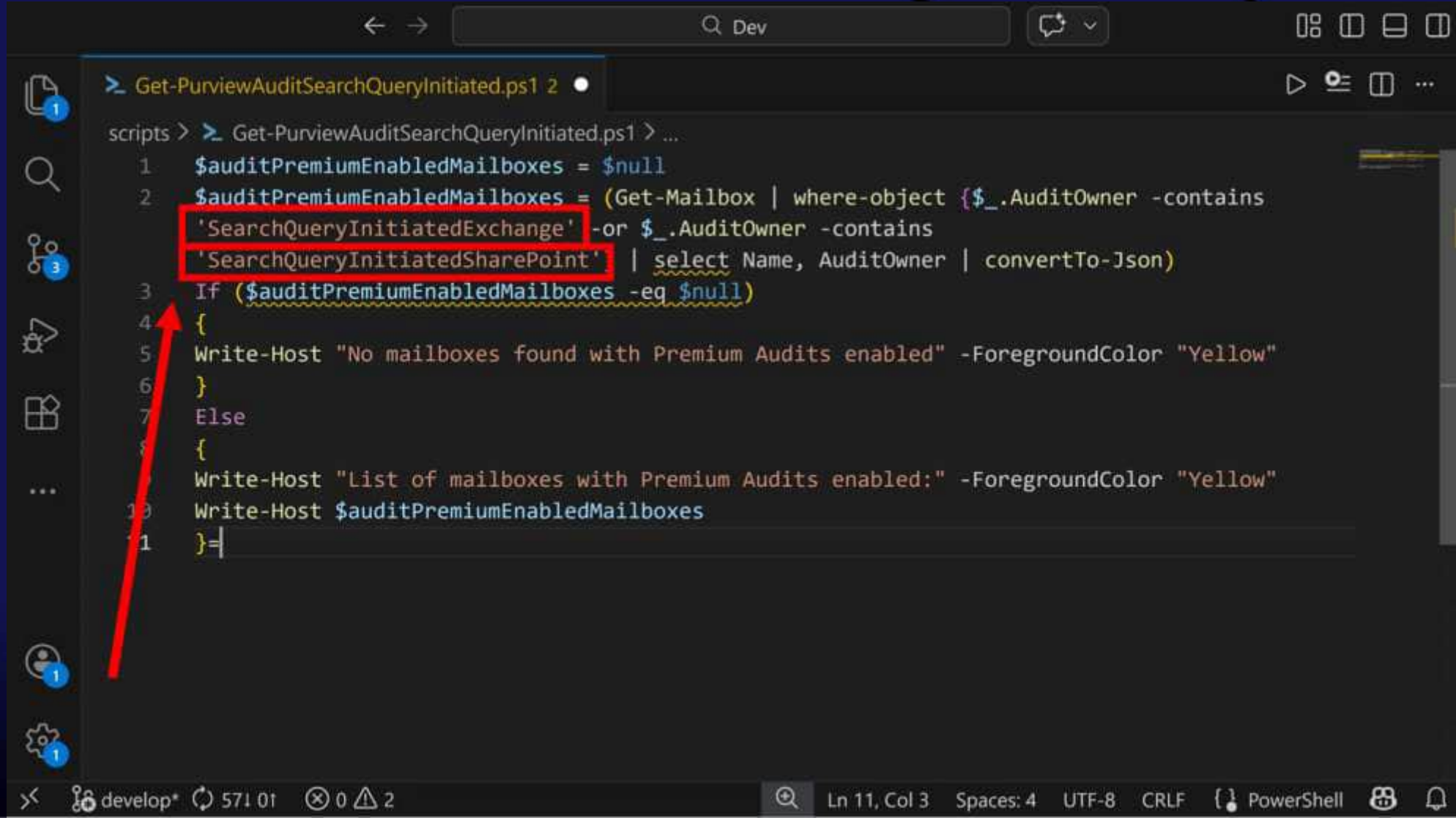
Starting with EXO V3.7, use the LoadCmdletHelp parameter alongside Connect-ExchangeOnline to access the Get-Help cmdlet, as it will not be loaded by default
-----

PS C:\Dev> Get-AdminAuditLogConfig | Format-List UnifiedAuditLogIngestionEnabled

UnifiedAuditLogIngestionEnabled : True

PS C:\Dev>
```

SearchQueryInitiatedExchange and SearchQueryInitiatedSharePoint enablement



```
scripts > > Get-PurviewAuditSearchQueryInitiated.ps1 > ...
1 $auditPremiumEnabledMailboxes = $null
2 $auditPremiumEnabledMailboxes = (Get-Mailbox | where-object {$_ .AuditOwner -contains
   'SearchQueryInitiatedExchange' -or $_.AuditOwner -contains
   'SearchQueryInitiatedSharePoint' | select Name, AuditOwner | convertTo-Json)
3 If ($auditPremiumEnabledMailboxes -eq $null)
4 {
5     Write-Host "No mailboxes found with Premium Audits enabled" -ForegroundColor "Yellow"
6 }
7 Else
8 {
9     Write-Host "List of mailboxes with Premium Audits enabled:" -ForegroundColor "Yellow"
10    Write-Host $auditPremiumEnabledMailboxes
11 }
```

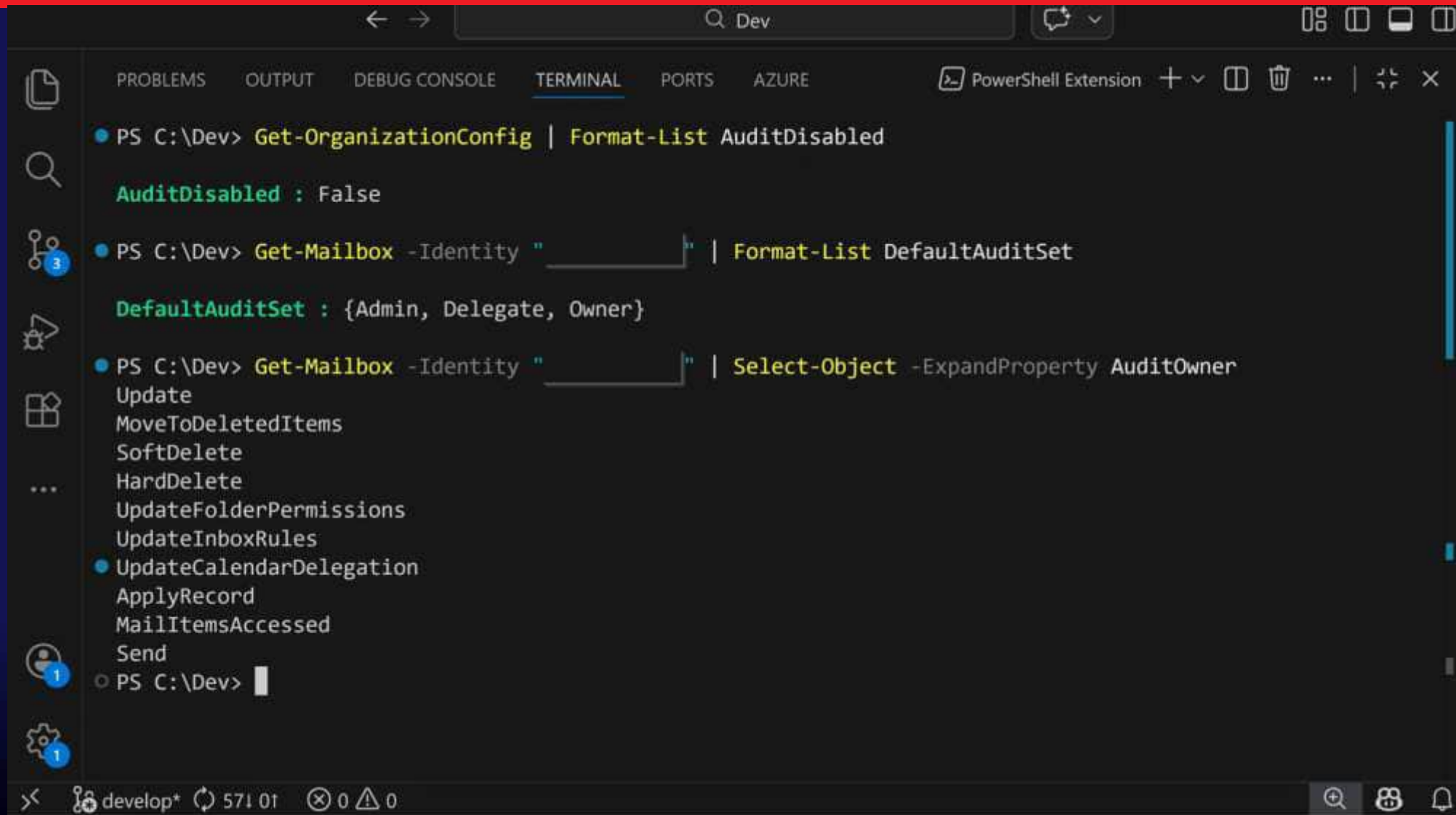
Audit Premium (gotchas)

The screenshot displays the Microsoft 365 Admin Center interface. On the left, a navigation pane lists various management areas: Home, Copilot, Agents, Users, Active users, Contacts, Guest users, Deleted users, Teams & groups, Roles, Resources, and Marketplace. The main content area is titled 'Manage apps & services' and shows a list of applications with checkboxes for assignment. A user profile card for 'Ewelina Paczkowska' (ewelina@wellnessworld.com) is overlaid on the right. This card lists several Microsoft 365 services with checkboxes indicating their assignment status:

- ☐ Insights by MyAnalytics Backend (Note: This app is assigned at the organization level. It can't be assigned per user.)
- ☒ Intune A Direct
- ☒ Microsoft 365 Advanced Auditing (highlighted with a red box)
- ☒ Microsoft 365 Apps for Enterprise
- ☒ Microsoft 365 Audit Platform
- ☒ Microsoft 365 Communication Compliance
- ☒ Microsoft 365 Defender

A 'Save' button is located at the bottom of the user profile card.

Ensure mailbox auditing is enabled



The screenshot shows a PowerShell terminal window with the following commands and output:

```
PS C:\Dev> Get-OrganizationConfig | Format-List AuditDisabled

AuditDisabled : False

PS C:\Dev> Get-Mailbox -Identity " " | Format-List DefaultAuditSet

DefaultAuditSet : {Admin, Delegate, Owner}

PS C:\Dev> Get-Mailbox -Identity " " | Select-Object -ExpandProperty AuditOwner
Update
MoveToDeletedItems
SoftDelete
HardDelete
UpdateFolderPermissions
UpdateInboxRules
UpdateCalendarDelegation
ApplyRecord
MailItemsAccessed
Send
PS C:\Dev>
```

The terminal window has a dark theme and includes a sidebar with icons for file explorer, search, and other tools. The status bar at the bottom shows the current session as 'develop*' with 571 lines of code and 0 errors.

Control and monitor mailbox auditing bypass

```
PS C:\Dev> Get-MailboxAuditBypassAssociation -Identity ""

ObjectId      : 
AuditBypassEnabled : False
Name          : 
Identity      : 
Id            : 
IsValid       : True
ExchangeVersion : 0.20 (15.0.0.0)
DistinguishedName : CN=,OU=.com,OU=Microsoft Exchange Hosted
                  Organizations,DC=EURPR01A008,DC=PROD,DC=OUTLOOK,DC=COM
ObjectCategory : EURPR01A008.PROD.OUTLOOK.COM/Configuration/Schema/Person
ObjectClass    : {top, person, organizationalPerson, user}
WhenChanged    : 28/01/2026 18:14:28
WhenCreated    : 03/09/2021 13:06:16
WhenChangedUTC : 28/01/2026 18:14:28
WhenCreatedUTC : 03/09/2021 12:06:16
ExchangeObjectId : 7e263311-36dd-4279-ad82-42fa83c962c0
OrganizationalUnitRoot : .onmicrosoft.com
OrganizationId : EURPR01A008.PROD.OUTLOOK.COM/Microsoft Exchange Hosted
                  Organizations/.onmicrosoft.com - EURPR01A008.PROD.OUTLOOK.COM/Config
                  urationUnits/onmicrosoft.com/Configuration
Guid           : 162c0
```

Set up a policy for audit log retention

The screenshot shows the Microsoft Purview web interface. The left sidebar contains navigation links: Home, Solutions, Usage center (preview), Audit, DSPM, and eDiscovery. The 'Audit' link is highlighted with a red box. The main content area is titled 'Policies' and contains a red box around the 'Create audit retention policy' button. A red arrow points from this button to the 'Policy name' column header in the table below. The table lists existing policies with their names, priorities, and record types.

Microsoft Purview

Search for solutions, users, articles, and ...

Copilot

Home

Solutions

Usage center (preview)

Audit

DSPM

eDiscovery

Audit

Search

Policies

Pay-as-you-go usage report

Related solutions

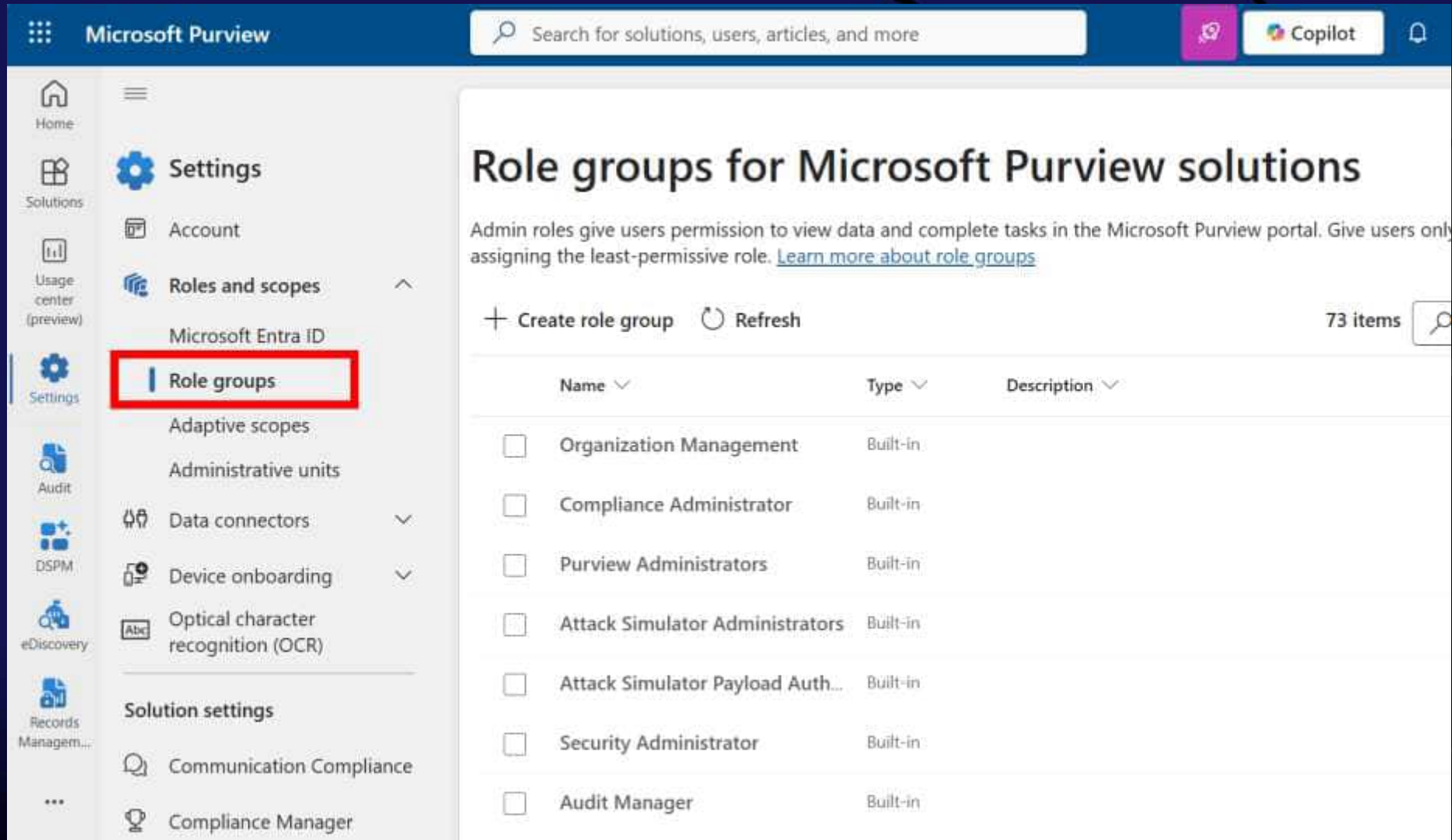
- eDiscovery
- Data Security Investigations

Policies

Create audit retention policy Delete

☐ Policy name ▾	Prior... ▾	Record Type ▾
☐ Audit-AllUsers-CopilotInteractions-90days	1	CopilotInteraction
☐ Audit-AllUsers-AllActivities-1year	2	

Protect Purview RBAC with PIM for Groups



Microsoft Purview

Search for solutions, users, articles, and more

Copilot

Home

Solutions

Usage center (preview)

Settings

Audit

DSPM

eDiscovery

Records Management

Settings

Account

Roles and scopes

Microsoft Entra ID

Role groups

Adaptive scopes

Administrative units

Data connectors

Device onboarding

Optical character recognition (OCR)

Solution settings

Communication Compliance

Compliance Manager

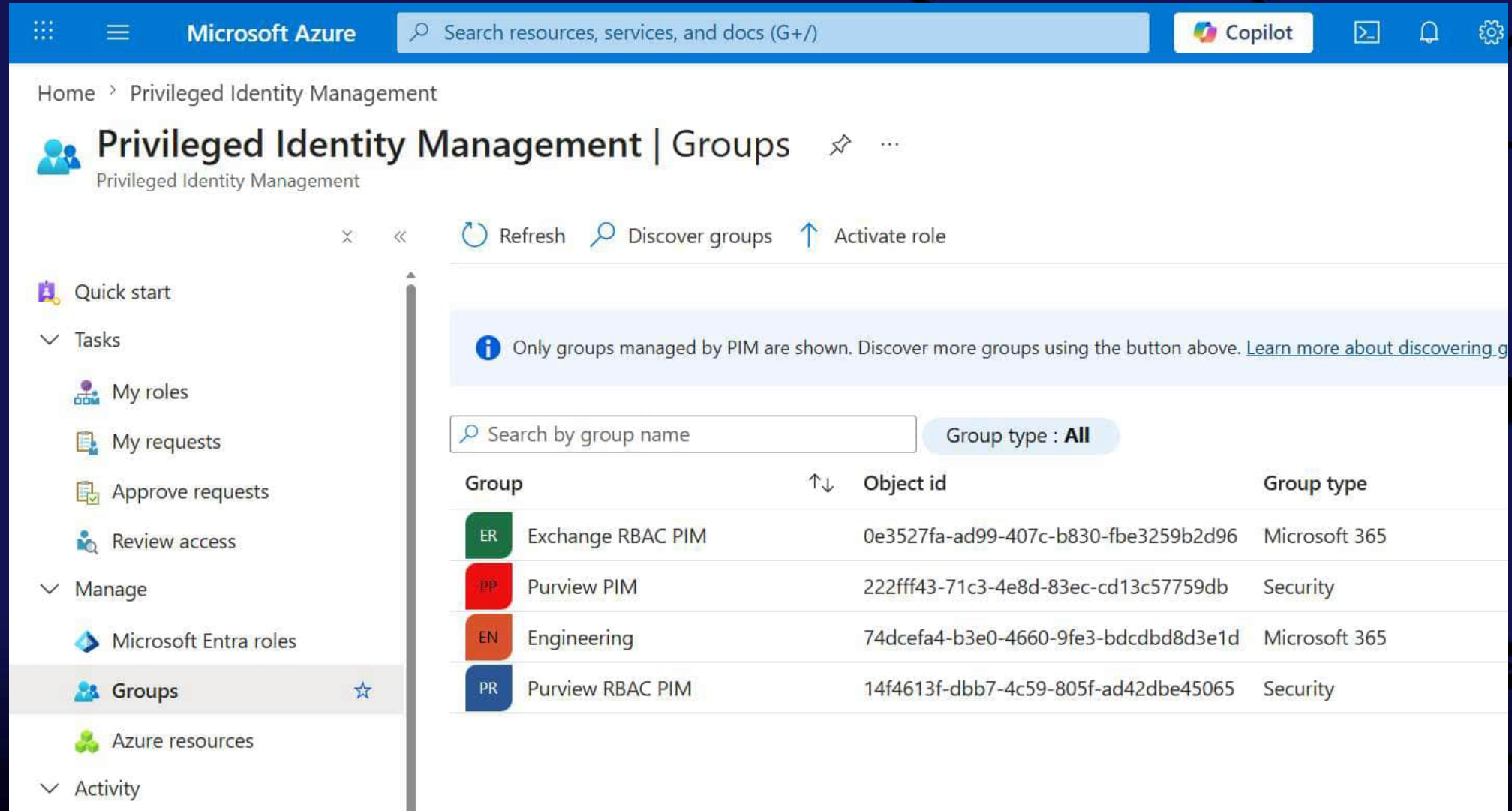
Role groups for Microsoft Purview solutions

Admin roles give users permission to view data and complete tasks in the Microsoft Purview portal. Give users only assigning the least-permissive role. [Learn more about role groups](#)

+ Create role group Refresh 73 items

Name	Type	Description
☐ Organization Management	Built-in	
☐ Compliance Administrator	Built-in	
☐ Purview Administrators	Built-in	
☐ Attack Simulator Administrators	Built-in	
☐ Attack Simulator Payload Auth...	Built-in	
☐ Security Administrator	Built-in	
☐ Audit Manager	Built-in	

Protect Purview RBAC with PIM for Groups



Microsoft Azure

Search resources, services, and docs (G+)

Copilot

Home > Privileged Identity Management

Privileged Identity Management | Groups

Privileged Identity Management

Refresh Discover groups Activate role

Quick start

Tasks

- My roles
- My requests
- Approve requests
- Review access

Manage

- Microsoft Entra roles
- Groups**
- Azure resources
- Activity

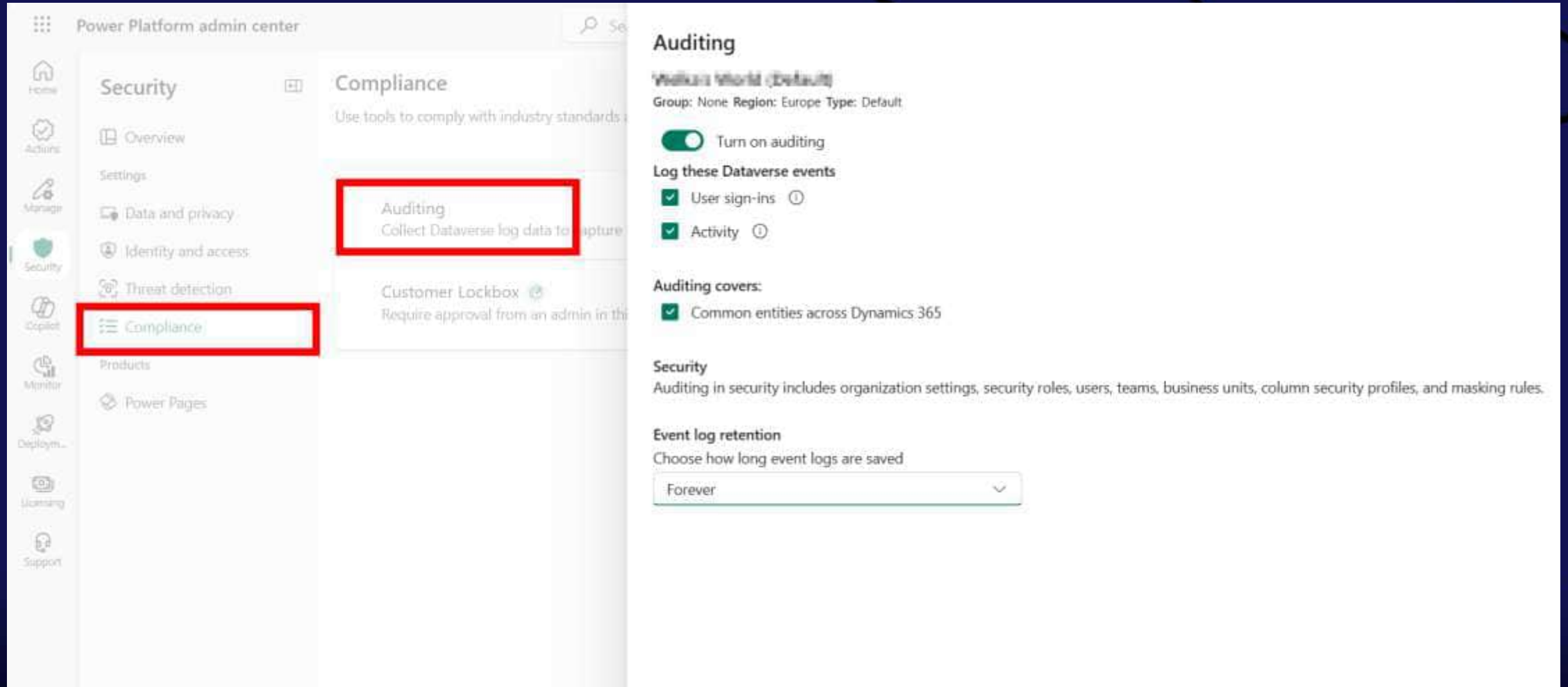
Only groups managed by PIM are shown. Discover more groups using the button above. [Learn more about discovering groups](#)

Search by group name

Group type : All

Group	Object id	Group type
ER Exchange RBAC PIM	0e3527fa-ad99-407c-b830-fbe3259b2d96	Microsoft 365
PP Purview PIM	222fff43-71c3-4e8d-83ec-cd13c57759db	Security
EN Engineering	74dcefa4-b3e0-4660-9fe3-bdcdbd8d3e1d	Microsoft 365
PR Purview RBAC PIM	14f4613f-dbb7-4c59-805f-ad42dbe45065	Security

Enable Audit for all Power Platform environments



The screenshot displays the Power Platform admin center interface. On the left, the 'Compliance' menu item is highlighted with a red box. In the main content area, the 'Auditing' section is also highlighted with a red box. The 'Auditing' settings are as follows:

- Auditing**
 - Group: None Region: Europe Type: Default
 - ☒ Turn on auditing
- Log these Dataverse events**
 - ☒ User sign-ins ⓘ
 - ☒ Activity ⓘ
- Auditing covers:**
 - ☒ Common entities across Dynamics 365
- Security**

Auditing in security includes organization settings, security roles, users, teams, business units, column security profiles, and masking rules.
- Event log retention**

Choose how long event logs are saved

Forever

Set up a data policy in Power Platform

Power Platform admin center

Search for settings, pages, and more

Security

- Overview
- Settings
 - Data and privacy**
 - Identity and access
 - Threat detection
 - Compliance
- Products
 - Power Pages

DLP Policies > Edit Policy

- Policy name: 1-Global
- Prebuilt connectors
- Custom connectors
- Scope
- Review

Assign connectors

Business (43) | Non-business (1590) | Default | **Blocked (4)**

Blocked connectors can't be used where this policy is applied.

	Name	Blockable	Endpoint configu...	Class
	Dropbox	Yes	No	Standard
	Face API	Yes	No	Standard
	Pinterest	Yes	No	Standard
	Facebook channel in Copilot Studio	Yes	No	Built-In

Copilot governance & security



Block Bring Your Own Copilot

The screenshot displays the Microsoft Intune admin center interface. The left-hand navigation pane includes links to Home, Dashboard, All services, Explorer, Devices, **Apps**, Endpoint security, Agents, Reports, Users, Groups, Tenant administration, and Troubleshooting + support. The **Apps** link is highlighted with a red rectangle. The main content area is titled 'Apps | Policies for Microsoft 365 apps'. A search bar is present. Below the search bar, a list of categories is shown: Android, Manage apps, Configuration, Protection, iOS app provisioning profiles, S mode supplemental policies, **Policies for Microsoft 365 apps**, App selective wipe, Quiet time, Policy sets, Organize apps, Assignment filters, App categories, eBooks, Help and support, and Help and support. The 'Policies for Microsoft 365 apps' category is highlighted with a red rectangle. The 'Configure' pane on the right shows a progress bar with steps: Basics, Scope, **Policies**, and Review and publish. The 'Policies' step is active. Below the progress bar, a table shows 'Total' (2) and 'Security Baseline' (0). The 'Policy' dropdown is set to 'Multiple account access to Copilot for work documents'. The 'Calculate multiple account access' button is visible. A modal window titled 'Multiple account access to Copilot for work documents' is open. It displays the following information:

- Platforms:** Windows, Mac, iOS, Android, Office on the web
- Applications:** Office
- Description:** This policy setting controls multiple account access to Copilot, which allows your users to use Copilot in Microsoft 365 apps on...
- Show more:** [Show more](#)
- Configuration setting:** Disabled

At the bottom of the modal, there are 'Apply' and 'Cancel' buttons.

EU Data Warning

AI providers operating as Microsoft subprocessors

Manage whether your organization can use AI models outside of Microsoft facilities to power your Copilot and Microsoft generative AI experiences. This setting does not control the use of AI models to support and develop Microsoft Online Services.

[Learn more about AI subprocessors](#)

Available subprocessors for your organization

Anthropic

Disabled by default

Anthropic as a Microsoft subprocessor will be available for use effective January 7, 2026.

Terms and conditions

Microsoft offers an optional capability to use Anthropic AI models to enhance Copilot and generative AI experiences in Microsoft Online Services. Your Microsoft [Product Terms](#) and [Data Protection Addendum](#) apply to your use of Anthropic AI models from within Microsoft Online Services unless otherwise documented in [Anthropic as a Subprocessor](#).

Note: Anthropic AI models operating within Microsoft Online Services are not in scope for EU Data Boundary commitments.

By enabling the use of Anthropic AI models, you acknowledge and agree to the above terms.

Select your preference

- ☒ Enable Anthropic as a Microsoft subprocessor subject to the above terms
- ☐ Disable Anthropic as a Microsoft subprocessor

Save

SAVE THE DATES

Oct 25-28, 2026



May 2-6, 2027



Oct 10-13, 2027



Extended Q&A



2Pint

Recast

robopack
empowered by SOFTWARE
CENTRAL

SquaredUp

CODETWO

baramundi

ninjaOne

Rimo3



TeamViewer

numecent

aiden